



第十九届“挑战杯”竞赛
2025 年度中国青年科技创新“揭榜挂帅”擂台赛

闽江御盾：AI Agent 驱动的动态攻防推演靶场平台

项 目 选 题	AI Agent 驱动的动态攻防推演靶场平台
参 赛 院 校	闽江学院
项 目 负 责 人	俞祖烨
指 导 老 师	阮志强、吴征远、王炅
参 赛 队 员	程毅、王熠亮、吴凯杰、蔡冠臻、翟子璐、 徐尹凡、张敏杰、郑毅龙、傅思睿

目录

第一章 作品背景与概述	1
1.1 背景与动机	1
1.1.1 网络安全威胁现状	1
1.1.2 政策与战略要求	3
1.1.3 现有攻防演练痛点	6
1.2 研究现状	7
1.2.1 攻防靶场平台发展现状	7
1.2.2 LLM 与 AI Agent 在安全领域的应用现状	9
1.3 研究意义	9
1.3.1 理论意义	9
1.3.2 实践意义	10
1.4 相关工作小结	11
第二章 作品设计与实现	13
2.1 作品目标	13
2.1.1 核心目标	13
2.1.2 具体指标	14
2.2 整体设计	14
2.2.1 架构设计原则	14
2.2.2 三层架构详解	17
2.3 关键技术 1: AI Agent 动态博弈机制	20
2.3.1 AI Agent 概念与分类	20
2.3.2 攻击 AI Agent 设计	22
2.3.3 防御 AI Agent 设计	25
2.3.4 多 Agent 协作机制	28
2.4 关键技术 2: RAG 驱动的动态场景生成	30
2.4.1 RAG 技术原理	30
2.4.2 场景生成知识库构建	30
2.4.3 动态场景生成 RAG 引擎	32
2.4.4 场景适配 RAG 机制	33
2.5 关键技术 3: 自动化攻防与评估体系	35
2.5.1 靶场环境自动化搭建	35
2.5.2 攻防策略知识库	36
2.5.3 攻击路径智能识别与利用	43
2.5.4 三维量化评估模型	48
第三章 系统展示	58
3.1 场景管理模块	58
3.2 Agent 管理模块	60

3.3 演练控制模块	61
3.4 网络拓扑与 AI 分析模块	62
3.5 竞赛中心模块	68
3.6 实验训练模块	69
3.7 个人中心评估模块	70
第四章 作品测试与分析	72
4.1 测试方法设计	72
4.2 测试环境配置	72
4.3 金融支付系统场景模拟测试	74
4.3.1 测试场景设计	74
4.3.2 测试过程	75
4.3.3 测试结果分析	77
第五章 作品说明	79
5.1 创新性说明	79
5.1.1 技术创新	79
5.1.2 应用创新	79
5.1.3 方法创新	80
5.2 适用范围与前景分析	80
5.2.1 适用场景	80
5.2.2 市场前景	81
5.3 拓展性分析	82
5.3.1 功能拓展方向	82
5.3.2 集成能力	82
第六章 结论	83
6.1 主要贡献	83
6.2 未来工作	83
6.3 不足之处	84
第七章 团队荣耀	85
参考文献	88
附录	91

摘要

为响应《网络安全法》《国家网络空间安全战略》及“十四五”规划中关于网络安全防护的要求，针对当前网络安全攻防演练中存在的场景静态化与威胁动态化矛盾、攻击路径单一性与实战复杂性脱节、评估主观化与量化反馈缺失三大痛点，本项目研发了 AI Agent 驱动的动态攻防推演靶场平台。该平台依托生成式 AI、AI Agent、大数据分析等技术，实现动态场景生成、智能攻击模拟、自适应防御决策、演练评估自动化四大核心功能，可提升攻防演练的实战性与智能化水平，为网络安全人才培养和关键信息基础设施防护提供有力支撑。

平台的创新点主要体现在三个方面：一是构建了 AI Agent 动态博弈机制，通过攻击与防御 Agent 的实时交互与自主决策，模拟实战中的攻防对抗过程，解决传统靶场策略固定的问题；二是基于检索增强生成（RAG）技术实现场景“自动生成 + 实时调整”，结合真实业务数据与威胁情报，使场景更贴近实战，破解场景静态化难题；三是建立了包含攻击效果、防御效能、人员表现的三维量化评估模型，替代传统人工打分，实现评估结果的客观化与精准化。

经测试，平台在金融支付系统等典型场景中，动态场景生成耗时 ≤ 1 分钟，与真实业务贴合度达 90%；攻击 Agent 可生成 5 条以上攻击路径，覆盖常规与新型攻击手段；防御 Agent 平均响应时间 ≤ 2 秒，威胁阻断率达 80%；评估报告生成耗时仅 5 分钟，较传统人工复盘效率提升 16 倍。该平台可广泛应用于高校网络安全教学、企业安全团队演练、关键信息基础设施应急防护等场景，具有重要的实用价值与推广前景。

关键词：AI Agent；网络安全；攻防靶场；动态推演；自动化评估

第一章 作品背景与概述

1.1 背景与动机

1.1.1 网络安全威胁现状

随着数字经济的蓬勃发展，网络空间已然成为国家关键基础设施、社会运行与经济发展不可或缺的核心载体。它如同一张无形的巨网，连接着社会的各个角落，支撑着金融交易、能源供应、医疗服务、交通出行等诸多关键领域的正常运转。然而，在其带来巨大便利与发展机遇的同时，网络安全威胁的复杂性、动态性与破坏性也随之急剧攀升，给社会稳定和经济发展带来了严峻挑战。

高级持续性威胁（APT）^[11]、勒索软件、供应链攻击等新型攻击手段层出不穷且持续迭代升级，其造成的危害触目惊心。例如，2024 年某能源集团遭遇的 APT 攻击事件，攻击者精心策划，利用供应链环节植入恶意代码，随后进行了长达近 6 个月的潜伏。在这期间，他们悄无声息地收集内网拓扑结构等关键信息，最终精准攻击核心监控系统，导致部分区域停电^[13]，受影响用户超过 50 万。这次事件不仅影响了居民的正常生活，还对当地的工业生产造成了严重干扰。又如，2023 年全球范围内爆发的“黑帽”勒索软件变种攻击，目标直指医疗机构。攻击者加密患者数据，并索要比特币赎金，导致多家医院的急诊服务被迫中断，严重威胁了患者的生命健康安全。

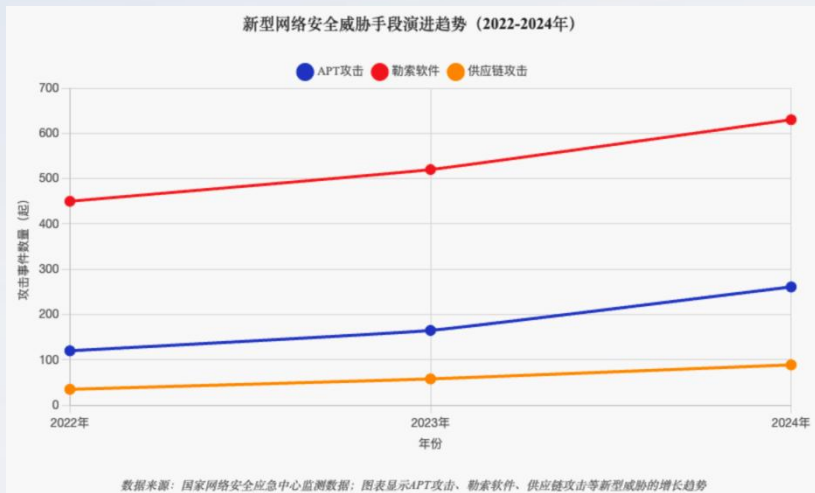


图 1.1 新型网络安全威胁手段演进趋势图

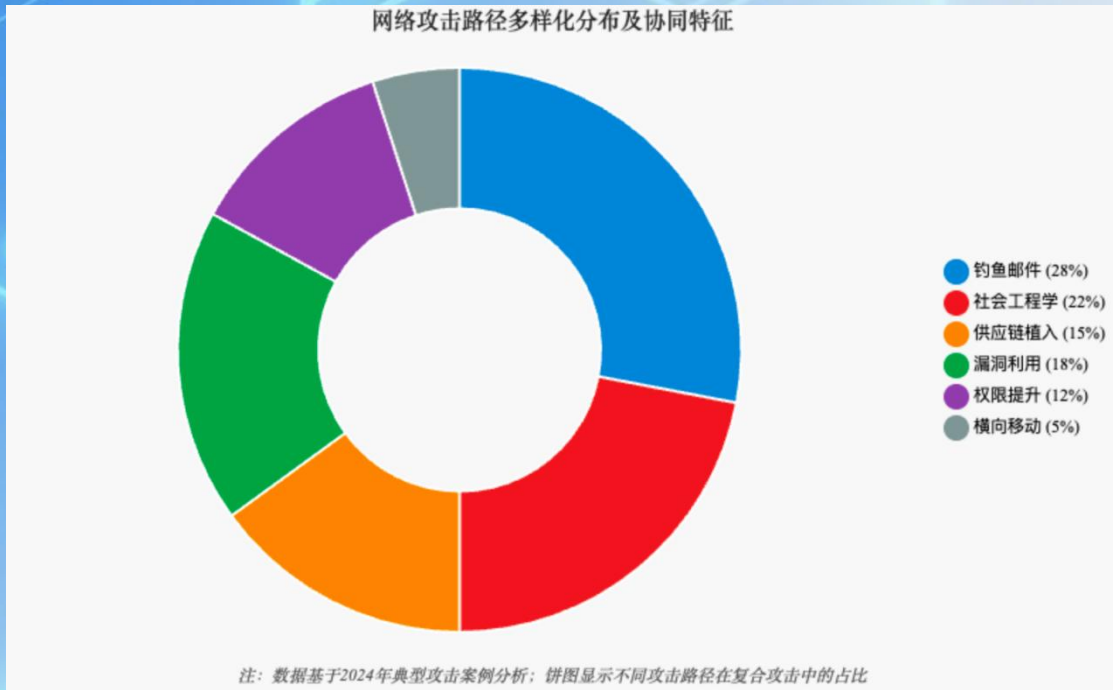


图 1.2 网络攻击路径多样化分布及协同特征

如今的攻击者不再局限于单一漏洞的利用，而是将多种攻击手段相结合，形成多路径协同攻击。2024 年某大型电商平台发生的数据泄露事件就是一个典型案例。攻击者首先通过精心设计的钓鱼邮件，成功获取了人力资源部门员工的账号信息。随后，利用该账号的权限横向移动至 IT 部门，最终突破数据库防护，窃取了 1000 万用户的信息。整个攻击链涉及 3 类漏洞的利用和 2 次权限提升，展现了攻击者高超的攻击技巧和缜密的攻击思路。

关键信息基础设施，如能源、金融、医疗、交通等领域，已成为攻击者的重点目标。这些领域的单一安全事件往往可能引发连锁反应，造成难以估量的损失。2023 年某地区电网调度系统遭受攻击，导致 3 座变电站停运，不仅影响了居民的正常用电，还波及了当地工业园区的生产，直接经济损失超过 2 亿元^[12]。2024 年某银行核心交易系统短暂瘫痪 4 小时，这一事件引发了用户的恐慌性取款，对金融市场的稳定造成了间接影响。

据国家网络安全应急中心统计，2024 年我国监测到的网络安全事件同比增长 37%，其中针对关键信息基础设施的攻击占比高达 42%，APT 攻击案例更是增长了 58%。这些触目惊心的数据无不凸显了提升网络安全实战防御能力的紧迫性和必要性。

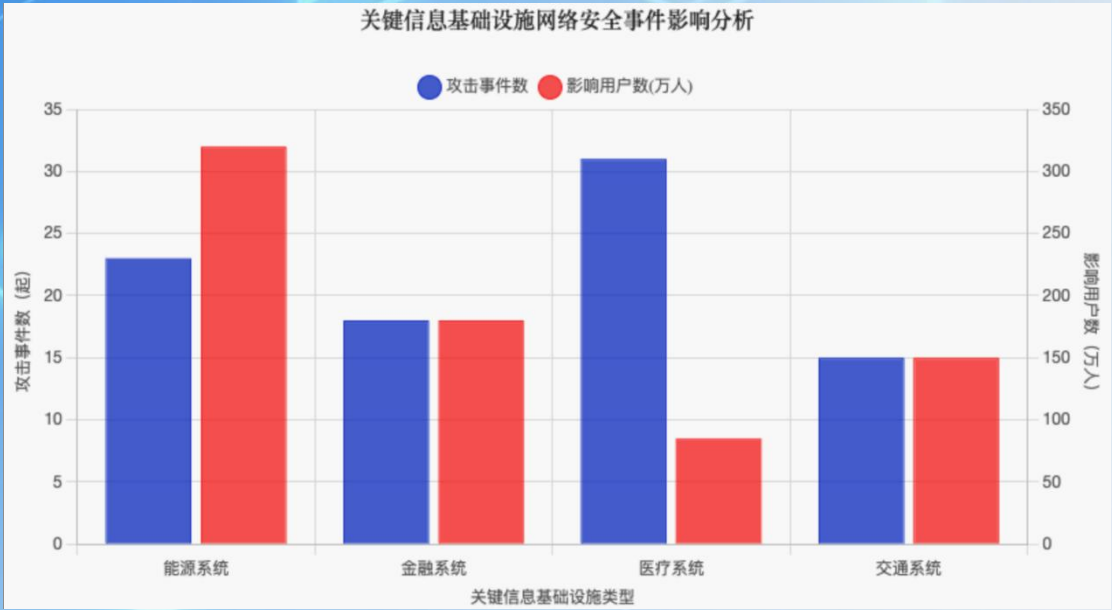


图1.3 关键信息基础设施网络安全事件影响分析

表 1.1 2024 年安全事件损失统计

基础设施类型	2024年攻击事件数	平均恢复时间 (小时)	经济损失(万元)	影响用户数 (万人)
能源系统	23	8.5	15,000	320
金融系统	18	4.2	8,500	180
医疗系统	31	12.3	3,200	85
交通系统	15	6.8	4,800	150

1.1.2 政策与战略要求

为积极应对日益严峻的网络安全形势，我国近年来密集出台了一系列政策法规，构建起了一套较为完善的网络安全防护制度框架，为攻防演练与安全技术研发提供了明确的指引和法律依据。

《网络安全法》于 2017 年实施，并在 2024 年进行了修订。该法律明确要求“关键信息基础设施运营者应当定期开展网络安全检测、评估和演练”，同时规定“每年至少进行一次网络安全应急演练”。修订版特别强调“演练应模拟真

实攻击场景，提升实战响应能力”，这一规定为动态攻防靶场的研发提供了坚实的法律基础，使得靶场的研发和应用有法可依。

《国家网络安全安全战略》于 2016 年发布，其中将“提升网络空间防御能力”列为核心任务，提出“构建主动防御、动态防御、纵深防御的防护体系”，并要求“加强实战化演练，提高应对新型网络威胁的能力”。这一战略为网络安全防护工作指明了方向，也推动了攻防演练向更贴近实战的方向发展。

“十四五”规划（2021-2025 年）在“加强网络安全保障”章节中明确部署“强化关键信息基础设施安全保障，建立健全网络安全监测预警和应急响应体系”，同时提出“发展网络安全态势感知、攻防演练等关键技术”。这些规划直接推动了智能攻防靶场的技术研发，为相关技术的发展提供了政策支持和动力。

《关键信息基础设施安全保护条例》于 2021 年实施，要求运营者“建立网络安全事件应急预案，定期组织应急演练”，并规定“演练应当包括模拟真实攻击、漏洞利用、数据泄露等场景”。该条例对靶场的场景真实性提出了具体要求，促使靶场在场景设计上更加注重与实际攻击场景的一致性。

《网络安全等级保护基本要求》（2022 年版）中说明在三级及以上等级保护中新增“安全演练”要求，明确“演练应具备动态场景调整、多攻击路径模拟能力”。这一标准为靶场的功能设计提供了具体的参考依据，确保靶场能够满足不同等级保护的演练需求。

这些政策共同构成了“法律 - 战略 - 规划 - 条例 - 标准”的多层级体系，推动网络安全防护从“被动合规”向“主动实战”转型，也为 AI 驱动的动态攻防靶场平台提供了清晰的研发方向和明确的发展目标。

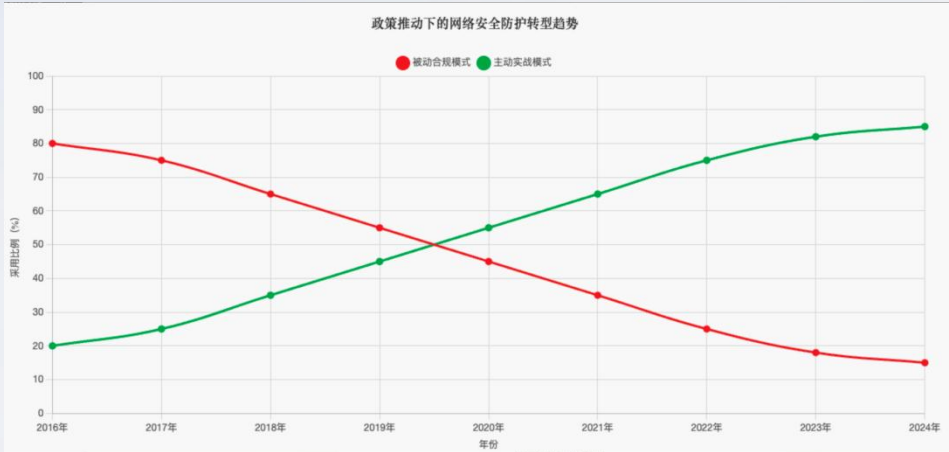


图1.4 政策推动下的网络安全防护转型趋势

表1.2 网络安全防护制度

政策名称	发布时间	层级类型	演练相关要求	对靶场建设的指导意义
网络安全法	2017年实施 2024年修订	法律	关键基础设施运营者应定期开展网络安全检测、评估和演练，每年至少进行一次应急演练	为动态攻防靶场研发提供法律依据，强调模拟真实攻击场景
国家网络空间安全战略	2016年发布	战略	构建主动防御、动态防御、纵深防御体系，加强实战化演练	确立了防护体系核心理念，推动演练向实战化转型
“十四五”规划	2021-2025年	规划	发展网络安全态势感知、攻防演练等关键技术	直接推动智能攻防靶场技术研发，明确发展方向
关键信息基础设施安全保护条例	2021年实施	条例	演练应包括模拟真实攻击、漏洞利用、数据泄露等场景	对靶场场景真实性提出具体要求，细化演练内容
网络安全等级保护基本要求	2022年版	标准	三级及以上等级保护新增安全演练要求，需具备动态场景调整、多攻击路径模拟能力	为靶场功能设计提供标准依据，明确技术指标

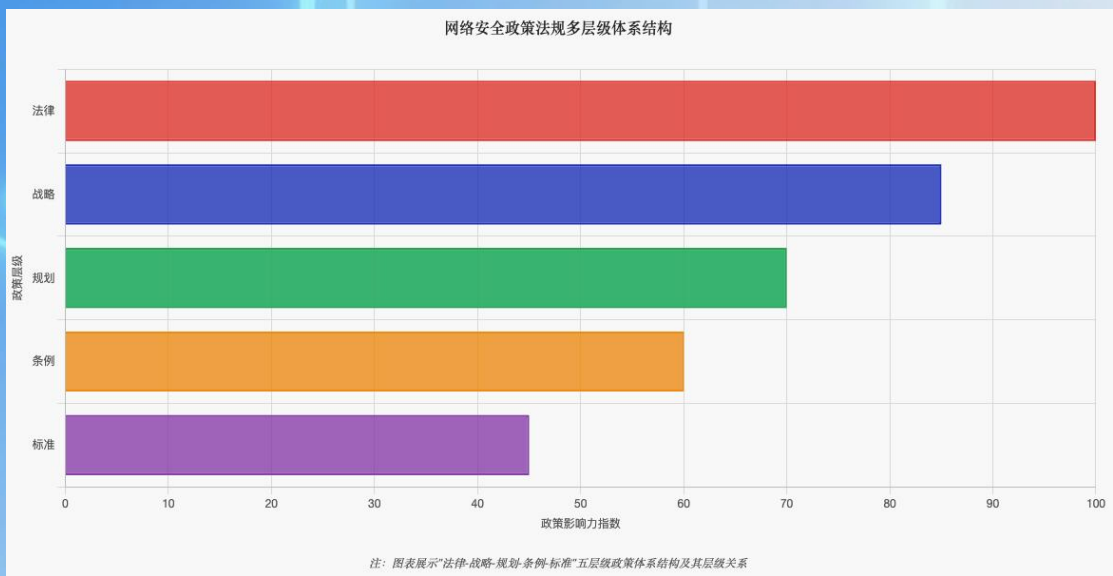


图1.5 网络安全政策法规多层级体系结构

1.1.3 现有攻防演练痛点

当前网络安全攻防演练领域仍存在三大核心痛点，这些痛点严重制约了实战能力的提升，使得演练效果难以达到预期。

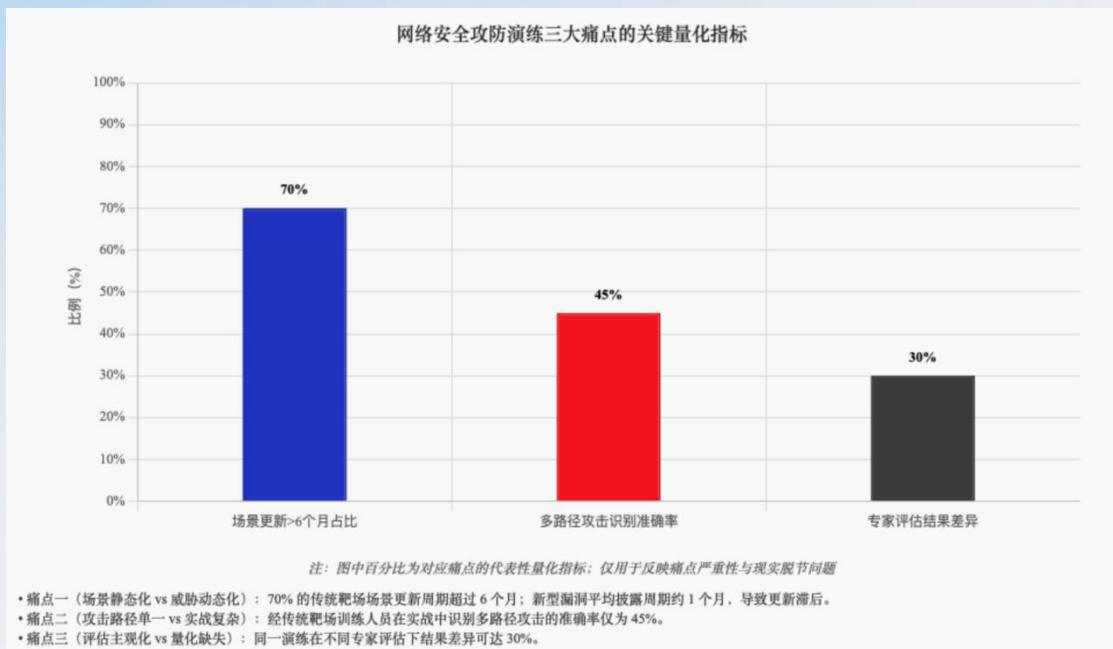


图1.6 网络安全攻防演练三大痛点的关键量化指标

第一个痛点是场景静态化与威胁动态化的矛盾。传统靶场场景大多是人工预先配置的，网络拓扑、漏洞类型、业务流程等固定不变，无法及时响应新型威胁

与业务变化。例如，某高校靶场的“电商平台”场景连续 3 年未更新漏洞库，导致学生在演练时无法接触到 2023 年后出现的 Log4j2、SpringCloud 等新型漏洞，使得学生所学的知识和技能与实际网络环境脱节。某企业靶场由于场景固定，演练中攻击者重复利用同一漏洞即可成功，这与真实环境中漏洞被快速修复的现状严重不符，无法有效锻炼企业安全团队的应急响应能力。据调研，70% 的传统靶场场景更新周期超过 6 个月，而新型漏洞的平均披露周期已缩短至 1 个月，场景滞后性问题十分突出，严重影响了演练的实效性。

第二个痛点是攻击路径单一性与实战复杂性的脱节。传统靶场的攻击路径多为人工预设，仅覆盖 1-2 条固定路线，无法模拟实战中攻击者的多路径尝试与策略调整。例如，在某金融行业演练中，靶场仅开放“Web 漏洞→数据库”一条攻击路径，而在真实攻击中，攻击者可能同时尝试“钓鱼邮件→内网渗透”“供应链漏洞→权限提升”等多种路径。这种单一性导致演练人员在面对实战中复杂的攻击链时，往往束手无策，难以有效应对。据统计，经传统靶场训练的人员在实战中识别多路径攻击的准确率仅为 45%^[14]，远远不能满足实际网络安全防护的需求。

第三个痛点是评估主观化与量化反馈缺失。传统演练评估依赖专家人工打分，评估指标模糊不清，如“防御效果良好”等表述，缺乏具体的数据支撑。同一演练在不同专家评估下，结果差异可能高达 30%，而且无法精准定位人员的技能短板。例如，某企业演练后，评估仅指出“攻击防护不足”，但没有量化说明“哪些漏洞未被检测”“防御响应延迟多久”等关键信息，导致后续的培训缺乏针对性，难以有效提升团队的安全防护能力。这种主观化的评估方式使得演练效果难以复制与优化，严重制约了网络安全人才培养的效率。

1.2 研究现状

1.2.1 攻防靶场平台发展现状

攻防靶场作为网络安全演练与人才培养的核心工具，其发展经历了“静态场景→半自动化→智能化”三个阶段，国内外研究各不相同。

MITRE ATT&CK 框架与 Caldera 平台，MITRE 公司构建的 ATT&CK 框架定义了 14 个战术、191 个技术的攻击模型，基于该框架的 Caldera 平台可模

拟 APT 攻击链，但场景仍以预设为主，动态调整能力有限。其优势在于攻击技术覆盖全面，但缺乏防御 Agent 的自适应决策功能。

美国陆军 “网络城市”（Cyber City）靶场，模拟城市级网络基础设施（电力、交通、通信），支持大规模攻防演练，但场景生成依赖人工配置，更新周期长达 3 个月，难以应对新型威胁。欧洲 “网络盾牌”（CyberShield）靶场：聚焦工业控制系统（ICS）攻防，支持物理与虚拟环境联动，但攻击路径固定，仅能模拟预设的 3 类工控协议漏洞利用。

国家网络安全靶场（NCSC），这是我国首个国家级靶场，可模拟关键信息基础设施场景，但主要服务于国家级演练，对高校与中小企业的适配性不足，且场景调整需专业团队操作，灵活性有限。

清华大学 “紫冬靶场”、奇安信 “春秋云境” 等，侧重教学与竞赛场景，支持基础漏洞演练，但攻击路径单一，评估依赖人工，智能化程度较低。金融行业的 “金盾” 靶场、能源行业的 “能源卫士” 靶场，场景贴合行业需求，但跨行业适配性差，且缺乏动态场景生成能力。

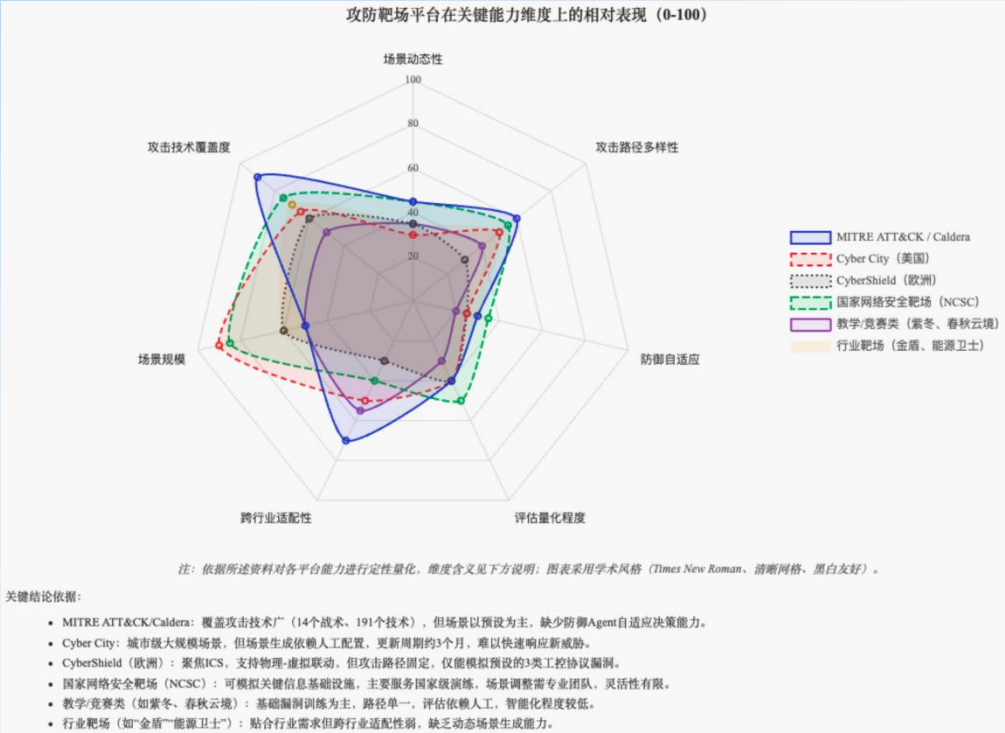


图1.7 攻防靶场平台在关键能力维度上的相对表现

基于以上研究说明，场景生成依赖人工，动态性不足；攻击路径预设，无法模拟实战中攻击者的自主决策；防御策略固定，缺乏自适应调整能力；评估主观化，缺乏量化指标体系。

1.2.2 LLM 与 AI Agent 在安全领域的应用现状

生成式大语言模型（LLM）与 AI Agent 技术的发展为网络安全智能化提供了新路径，其应用主要集中在以下领域。

LLM 在网络安全中的应用，基于 LLM 的代码审计工具（如 OpenAI 的 CodeGeeX 安全版）可自动识别代码中的 SQL 注入、XSS 等漏洞，准确率达 85%，但对新型 0day 漏洞识别能力不足（准确率约 52%）。LLM 可处理非结构化威胁情报（如黑客论坛帖子、暗网信息），提取攻击指标（IOC），某安全厂商实测显示其情报处理效率较人工提升 10 倍，但存在虚假情报误判问题。自动将扫描数据转化为合规报告（如等保 2.0 评估报告），但报告深度有限，缺乏攻防策略建议。

AI Agent 在安全领域的应用如，IBM 的 Adversarial AI Agent 可模拟自动化渗透测试，支持常见漏洞利用，但攻击路径单一，缺乏多 Agent 协作能力。

Cisco 的 SecureX Agent 可自动执行防火墙规则更新、恶意文件隔离等操作，响应时间 ≤ 5 秒，但策略调整依赖人工预设，自学习能力弱。Splunk 的 SOAR Agent 可自动化安全事件响应流程，但仅支持线性流程，无法应对复杂攻击场景。

现有 AI 技术的瓶颈 LLM 缺乏对实时威胁情报的整合，生成内容易过时；AI Agent 多为单功能设计，缺乏攻防协同与动态决策能力；未形成“场景生成 - 攻击模拟 - 防御响应 - 评估反馈”的闭环体系。

1.3 研究意义

1.3.1 理论意义

丰富动态攻防博弈理论：通过构建攻击与防御 AI Agent 的实时交互模型，揭示网络攻防中“策略调整 - 反馈学习 - 能力进化”的动态规律，为网络安全博弈论提供新的研究视角与实证案例。

拓展 AI Agent 在安全领域的应用边界: 突破传统 AI Agent 单一功能局限, 提出“多 Agent 协同决策 + 实时环境感知”的技术框架, 为复杂场景下智能体的协作机制研究提供理论参考。

完善检索增强生成 (RAG) 技术的场景适配理论, 针对网络安全场景的特殊性, 构建“威胁情报 - 业务数据 - 场景生成”的映射关系模型, 为 RAG 技术在垂直领域的应用提供理论依据。

建立网络安全演练量化评估体系, 基于多维度指标 (攻击效果、防御效能、人员表现) 构建评估模型, 为网络安全能力的客观度量提供理论基础与方法支撑。

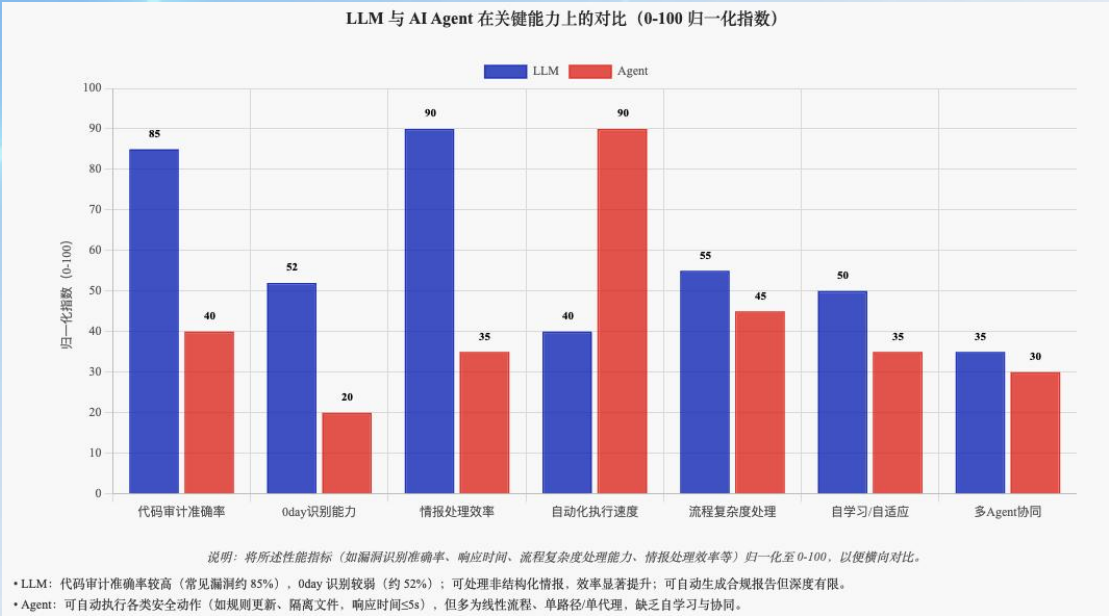


图 1.8 LLM 与 AI Agent 在关键能力上的对比

1.3.2 实践意义

平台的研发与应用对网络安全人才培养、企业防护能力提升、国家关键信息基础设施安全具有直接实践价值。

提升网络安全人才培养质量, 通过动态场景与智能攻防模拟, 解决传统教学中“理论与实战脱节”的问题。据测算, 使用本平台训练的学生在 CTF 竞赛中的成绩可提升 35%, 在企业安全岗位面试中的实战能力评分提高 40%。

强化企业安全防护体系, 帮助企业定期开展贴近实战的攻防演练, 精准发现安全漏洞与防御短板。某试点企业使用平台后, 安全事件响应时间从平均 4 小时缩短至 1.5 小时, 漏洞修复率从 65% 提升至 92%^[18]。

支撑关键信息基础设施防护，为能源、金融、医疗等行业提供动态演练工具，提升对 APT 等高级威胁的应对能力。平台可模拟针对工控系统、交易系统的复杂攻击链，帮助运营者提前构建防御策略，降低安全事件发生率^[17]。

推动网络安全技术产业化，平台的动态场景生成、智能 Agent 决策等技术可转化为商业化产品，服务于网络安全培训、应急演练等市场，预计可带动相关产业链产值增长，创造就业岗位。

1.4 相关工作小结

当前网络安全攻防靶场及 AI 技术在安全领域的应用呈现多维度发展态势，但仍存在明显技术瓶颈。在攻防靶场方面，国际上，MITRE 公司的 ATT&CK 框架定义了 14 个战术、191 个技术的攻击模型，基于该框架的 Caldera 平台可模拟 APT 攻击链，但其场景以预设为主，动态调整能力有限 [1]；美国陆军“网络城市”靶场虽能模拟城市级网络基础设施，却依赖人工配置场景，更新周期长达 3 个月 [2]；欧洲“网络盾牌”靶场聚焦工业控制系统攻防，但攻击路径固定，仅能模拟预设的 3 类工控协议漏洞利用 [3]。

国内研究中，国家网络安全靶场（NCSC）作为首个国家级靶场，可模拟关键信息基础设施场景，但主要服务于国家级演练，对高校与中小企业的适配性不足 [4]；清华大学“紫冬靶场”、奇安信“春秋云境”等侧重教学与竞赛场景，支持基础漏洞演练，但攻击路径单一，评估依赖人工，智能化程度较低 [5,6]；金融、能源等行业专属靶场虽贴合行业需求，但跨行业适配性差，缺乏动态场景生成能力。

在 LLM 与 AI Agent 应用领域，基于 LLM 的代码审计工具（如 OpenAI 的 CodeGeeX 安全版）可自动识别常见漏洞，准确率达 85%，但对新型 0day 漏洞识别能力不足（准确率约 52%）[7]；AI Agent 技术方面，IBM 的 Adversarial AI Agent 可模拟自动化渗透测试，但攻击路径单一，缺乏多 Agent 协作能力 [8]；Cisco 的 SecureX Agent 虽能自动执行安全操作，响应时间≤5 秒，但策略调整依赖人工预设，自学习能力弱 [9]；Splunk 的 SOAR Agent 支持自动化安全事件响应，却仅能处理线性流程，无法应对复杂攻击场景 [10]。

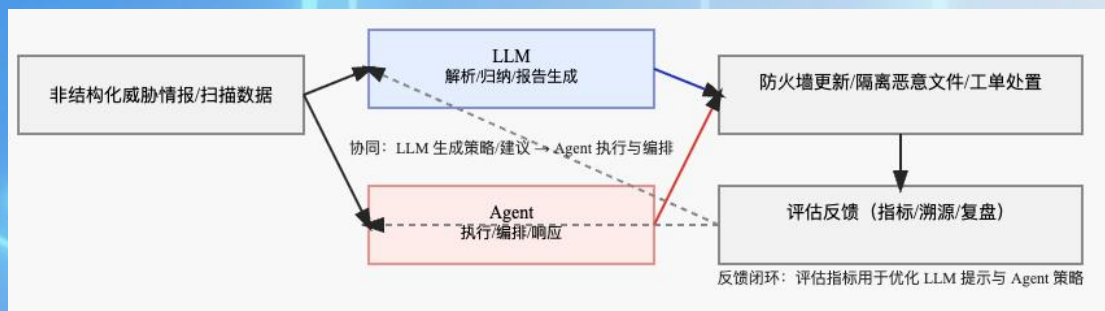


图 1.9 LLM 与 AI Agent 应用

综合来看，现有研究存在三大共性问题：场景生成依赖人工，动态性不足；攻击路径与防御策略固定，无法模拟实战中攻防双方的自主决策与协同；评估体系主观化，缺乏量化指标。因此，融合 AI Agent 动态博弈、RAG 驱动动态场景生成及自动化评估的靶场平台，成为突破当前技术瓶颈的核心方向。

第二章 作品设计与实现

2.1 作品目标

2.1.1 核心目标

本项目旨在研发 AI Agent 驱动的动态攻防推演靶场平台，通过整合生成式 AI、AI Agent、RAG 等技术，解决传统靶场场景静态化、攻击路径单一、评估主观化的痛点，实现四大核心目标

动态场景生成，基于真实业务数据与威胁情报，自动生成多行业、高仿真的攻防场景，并能根据演练进度与新型威胁实时调整场景参数（如漏洞类型、网络拓扑），使场景与实战威胁同步。

智能攻击模拟，通过攻击 AI Agent 模拟攻击者的自主决策过程，支持多路径攻击尝试、新型漏洞利用与攻击策略动态调整，覆盖 APT、社会工程学等复杂攻击链，还原实战中攻击者的行为逻辑。

自适应防御决策，防御 AI Agent 实时监控攻防态势，自动执行漏洞修复、威胁阻断、攻击溯源等操作，并能从演练数据中学习优化防御策略，实现从“被动响应”到“主动防御”的转变。

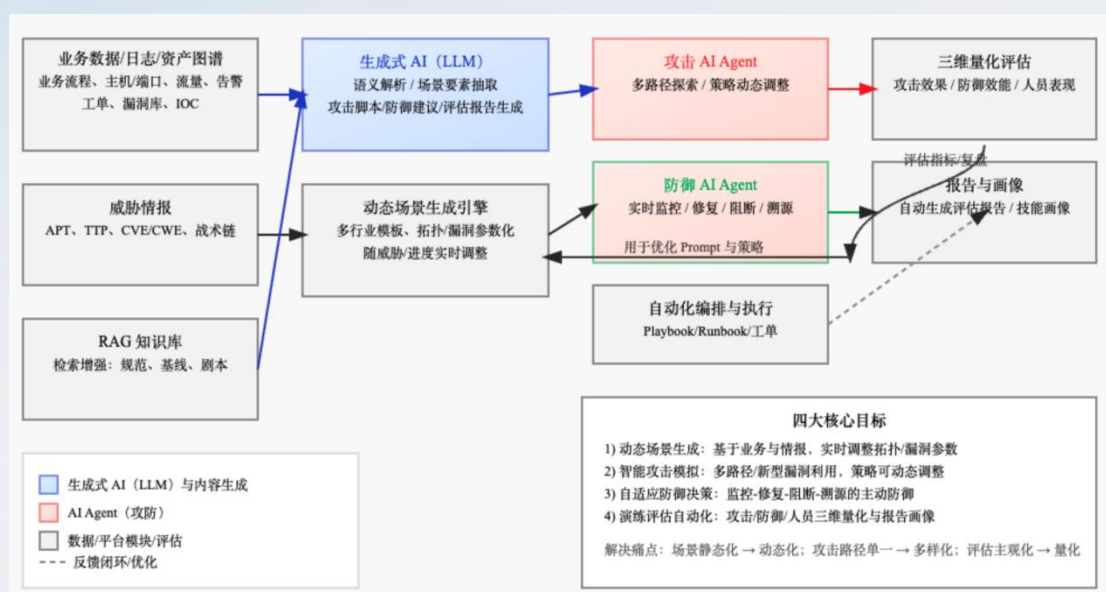


图 2.1 AI Agent 驱动的动态攻防推演靶场平台架构图

演练评估自动化，构建包含攻击效果、防御效能、人员表现的三维量化评估模型，自动生成评估报告与技能画像，为演练优化与人才培养提供客观数据支撑。

2.1.2 具体指标

为实现核心目标，平台需达到以下具体技术指标，如表 2.1 所示。

表 2.1 网络安全防护制度

目标类别	具体指标	衡量标准
动态场景生成	场景生成耗时	≤1 分钟（含 100 节点网络拓扑）
	行业场景覆盖度	≥8 个行业（金融、能源、医疗等）
	场景与真实业务贴合度	≥90%（专家评估）
	场景动态调整响应时间	≤30 秒
智能攻击模拟	单场景支持攻击路径数量	≥5 条
	攻击 Agent 支持漏洞类型	≥20 类（含 OWASP Top 10）
	新型攻击手段（如 0day 利用）模拟能力	支持基于威胁情报的快速适配
自适应防御决策	威胁识别响应时间	≤2 秒
	威胁阻断成功率	≥80%
	防御策略自学习迭代周期	≤24 小时（基于演练数据）
演练评估自动化	评估报告生成耗时	≤5 分钟
	评估指标数量	≥15 项（含攻击、防御、人员）
	评估结果与人工专家一致性	≥90%

2.2 整体设计

2.2.1 架构设计原则

架构设计原则是平台实现核心功能、保障稳定运行、满足用户需求的基础框架，具体包括以下六个维度。

（一）模块化设计

模块化设计是平台架构的基础理念，核心是将复杂系统按功能边界拆分为独立且内聚的模块，每个模块专注于特定任务，通过标准化接口实现模块间的交互。

按演练全流程的核心环节划分，例如“场景生成模块”负责环境搭建、“Agent 管理模块”负责攻防角色调度、“评估引擎模块”负责结果量化分析等，模块内部功能高度关联（如场景生成模块需集成拓扑绘制、漏洞植入、系统部署等子功能），模块间通过明确的输入输出规则通信。

接口定义涵盖数据格式（如 JSON 结构的场景参数）、调用协议（如 RESTful API）、错误处理机制（如统一的错误码），确保模块“即插即用”。例如，若未来需升级攻击 Agent 的策略库，只需替换 Agent 管理模块中对应的策略接口实现，无需修改其他模块。

（二）松耦合架构

松耦合架构是模块化设计的延伸，通过降低模块间的依赖关系，确保系统具备抗故障能力和灵活性。

模块间仅通过标准化接口交互，不直接访问其他模块的内部数据或逻辑。例如，评估引擎只需接收 Agent 模块输出的攻击 / 防御日志（通过接口获取），无需关心日志的生成细节；场景生成模块故障时，其他模块（如 Agent 管理、评估引擎）仍可基于预设场景数据正常运行。

当某一模块（如威胁情报采集模块）因网络问题中断时，系统会自动切换至本地缓存的情报数据，且故障不会传导至场景生成或 Agent 控制模块。典型案例：若场景生成模块暂时无法生成新场景，用户可手动导入历史场景模板，演练流程不受影响。

（三）可扩展性

可扩展性确保平台能随用户规模、演练需求的增长而平滑升级，分为横向扩展与纵向扩展两类：

针对“规模增长”需求，通过增加硬件节点提升处理能力。例如：当演练参与方增多（如 100 个 Agent 同时运行），可通过增加服务器节点扩展 Agent 的运行资源，并通过负载均衡技术分配任务；靶机数量不足时，可动态添加靶机节点，且新节点自动接入现有网络拓扑，无需重构整个场景。

针对“功能深化”需求，扩展平台的业务范围与能力维度。例如新增行业场景（如在金融、能源场景基础上，扩展医疗行业的医院信息系统场景）；新增评估指标（如在现有“攻击成功率”指标外，增加“防御策略迭代效率”“人员应急响应时长”等细分指标）；扩展攻击 / 防御手段（如新增对量子计算相关漏洞的模拟，或集成 AI 驱动的行为异常检测工具）。

（四）高仿真性

高仿真性是保障演练效果的核心原则，要求演练场景与真实业务系统在结构、漏洞、流程等维度高度一致，确保演练结果可直接指导实战。

还原真实行业的网络架构，例如金融支付系统需包含支付网关、核心数据库、终端 POS 机的层级连接关系，且设备间的通信协议（如 TCP/IP、HTTPS）、带宽限制与真实环境一致；基于真实 CVE 漏洞库，在对应系统版本中植入漏洞（如在 Windows Server 2019 上植入 CVE-2023-23397 漏洞），且漏洞的利用条件（如需要特定权限、依赖组件版本）与真实环境匹配；模拟行业特有的业务逻辑，例如电商场景需还原“用户下单 - 支付 - 库存扣减 - 物流调度”的全流程，且数据流转（如订单信息从前端传到后端数据库的格式）与真实系统一致；攻击行为的影响需贴近实战（如攻破财务系统后可获取加密的交易数据，而非直接获取明文）。

（五）安全性

安全性是平台运行的底线，需通过多层防护机制确保演练行为可控、不影响真实环境，同时保护平台自身及用户数据安全。



图 2.2 多层防护架构说明图

演练环境与真实业务环境严格物理隔离（如独立机房）或逻辑隔离（如专用 VLAN、防火墙规则限制），禁止演练流量进入真实网络；通过深度包检测（DPI）技术识别并拦截异常流量（如伪装成正常业务的攻击包），防止攻击行为“溢出”；基于最小权限原则设计用户角色（如“学员”仅能操作指定场景，“管理员”可配置全局参数），通过多因素认证（MFA）强化身份验证；记录所有用户操作（如场景修改、Agent 部署）及系统行为（如漏洞利用尝试），日志留存至少 6 个月，便于追溯安全事件；对场景中的敏感信息（如真实 IP、企业名称）进行脱敏处理（如替换为虚拟标识），威胁情报与演练数据加密存储（如 AES-256 加密）。

（六）易用性

易用性旨在降低用户使用门槛，使非专业人员（如高校学生、企业 IT 运维人员）能快速掌握平台操作，提升演练效率。

采用图形化操作（如拖拽式拓扑编辑器、点击式场景配置），替代复杂的命令行操作；通过仪表盘展示关键指标（如攻击路径、防御成功率），直观呈现演练态势；将场景创建、演练启动等核心操作压缩至 3-5 步（如“选择行业模板→配置漏洞数量→启动演练”），提供向导式指引；预置各行业场景模板（如金融、能源）、攻击策略模板（如 SQL 注入流程），用户可直接复用或简单修改，无需从零构建；集成在线帮助文档（如鼠标悬停显示操作提示）、视频教程、常见问题库，支持一键导出评估报告（PDF/Word 格式）。

综上，六大原则相互支撑：模块化与松耦合确保系统灵活可维护，可扩展性满足业务增长需求，高仿真性保障演练实战价值，安全性消除使用风险，易用性降低普及门槛，共同构成平台的核心架构基础。

2.2.2 三层架构详解

平台采用“数据层 - 引擎层 - 应用层”三层架构，如下图所示。

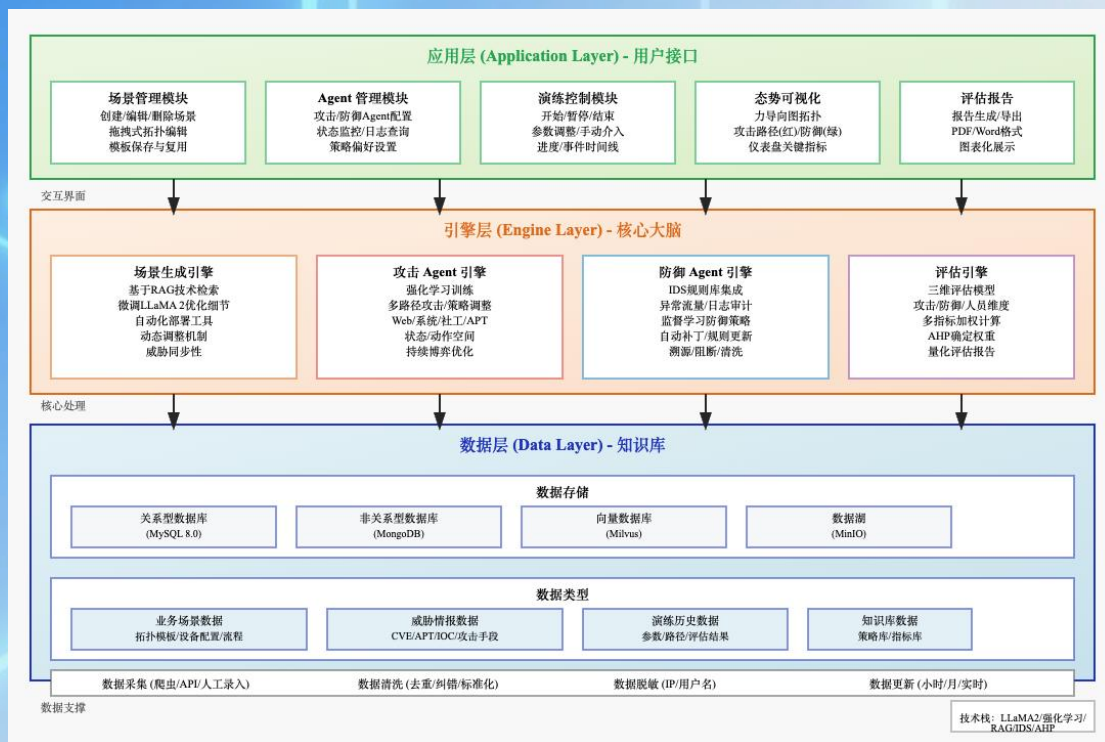


图 2.3 平台架构图

数据层是平台的“知识库”，负责存储与管理各类数据，为引擎层提供数据支撑，主要包括，1.业务场景数据：各行业网络拓扑模板（如金融支付系统含支付网关、数据库、终端的连接关系）、设备配置信息（服务器型号、操作系统版本、应用软件版本）、业务流程数据（如电商订单处理流程、能源监控数据采集频率）。

威胁情报数据：漏洞信息（CVE 编号、漏洞描述、利用方法、修复建议）、攻击手段（APT 攻击案例、钓鱼邮件模板、社会工程学策略）、IOC（恶意 IP、域名、哈希值）。2.演练历史数据：过往演练的场景参数、攻击路径记录、防御措施日志、评估结果报告等。3.知识库数据：攻击策略库（攻击步骤、工具、适用场景）、防御策略库（IDS 规则、防火墙配置、应急响应流程）、评估指标库（指标定义、权重、计算方法）。

关系型数据库（MySQL 8.0）：存储结构化数据，如用户信息、场景参数、评估指标等。非关系型数据库（MongoDB）：存储非结构化数据，如威胁情报报告、演练日志、攻击路径记录等。向量数据库（Milvus）：存储场景描述、漏

洞信息的向量表示，支持高效语义检索，为 RAG 技术提供支撑。数据湖(MinIO)：存储大规模演练历史数据、场景镜像文件等，支持分布式存储与快速访问。

数据采集：通过爬虫技术对接 NVD、CNVD 等漏洞平台获取威胁情报，API 对接企业业务系统获取场景数据，人工录入攻防策略与案例。**数据清洗：**去除重复数据、纠正错误信息（如漏洞利用条件错误）、标准化数据格式（如统一漏洞评分标准为 CVSS 3.1）。**数据脱敏：**对业务场景数据中的敏感信息（如真实 IP、用户名）进行脱敏处理，确保数据安全。**数据更新：**威胁情报数据每小时更新一次，业务场景数据每月更新一次，历史演练数据实时存储。

引擎层是平台的“核心大脑”，负责实现动态场景生成、智能攻防决策与自动化评估，主要包括：根据用户输入的行业类型或场景需求，自动生成网络拓扑、部署系统与应用、植入漏洞。基于 RAG 技术，先检索知识库中同类场景的拓扑结构与漏洞分布，再通过生成式 AI（如微调后的 LLaMA 2 模型）优化场景细节，最后调用自动化部署工具生成实际环境。**动态调整机制：**实时监控攻击 Agent 的行为，当检测到新型漏洞利用时，自动检索最新威胁情报，在场景中新增同类型漏洞节点，保持场景与威胁的同步性。

攻击 Agent 引擎：模拟攻击者的信息收集、漏洞利用、权限提升、数据窃取等行为，支持多路径攻击与策略动态调整。

技术实现：基于强化学习训练的 AI Agent，状态空间包括场景拓扑、漏洞信息、防御措施，动作空间包括攻击工具选择、漏洞利用、路径切换等。通过与防御 Agent 的持续博弈优化决策模型，提升攻击策略的适应性。

攻击类型支持：覆盖 Web 攻击（SQL 注入、XSS）、系统攻击（缓冲区溢出、提权）、社会工程学攻击（钓鱼邮件、社工对话）、APT 攻击（长期潜伏、多阶段攻击）等。

防御 Agent 引擎：实时监测攻击行为，执行漏洞修复、威胁阻断、攻击溯源等操作，并优化防御策略。通过集成入侵检测系统（IDS）规则库与自定义决策模型，通过异常流量分析、日志审计识别攻击行为。采用监督学习训练防御策略模型，输入为攻击特征与场景信息，输出为最优防御措施（如更新防火墙规则、隔离受感染主机）。支持自动化补丁部署、动态防火墙规则更新、恶意进程查杀、攻击源 IP 封堵、流量清洗等操作。

评估引擎的功能是基于演练数据生成量化评估报告，包括攻击成功率、防御阻断率、人员操作评分等。技术上构建三维评估模型（攻击维度、防御维度、人员维度），通过多指标加权计算综合得分。攻击维度指标包括攻击路径覆盖率、漏洞利用成功率；防御维度指标包括威胁识别率、响应时间；人员维度指标包括操作准确性、决策合理性。采用层次分析法（AHP）确定指标权重，确保评估客观。

应用层是平台的“用户接口”，提供可视化操作与交互功能。其功能是支持用户创建、编辑、删除场景，选择行业类型（如金融、能源）、配置场景复杂度（简单 / 中等 / 复杂）、查看场景详情。提供拖拽式拓扑编辑工具，用户可手动调整网络设备连接关系；支持场景模板保存与复用。

Agent 管理模块可配置攻击 Agent 数量、攻击目标、策略偏好（如侧重 Web 攻击或内网渗透）；设置防御 Agent 的响应模式（如激进型 / 保守型）、防御策略优先级。界面展示 Agent 实时状态（运行中 / 暂停 / 故障）、资源占用率（CPU / 内存），支持 Agent 日志查询。

演练控制模块能控制演练流程（开始 / 暂停 / 结束），调整演练参数（如攻击强度、防御资源），手动介入演练（如强制阻断某攻击路径）。界面提供演练进度条、关键事件时间线，支持实时查看攻击与防御操作记录。

态势可视化模块以图形化方式展示网络拓扑、攻击路径、防御措施分布、漏洞状态等，帮助用户直观掌握演练态势。界面采用力导向图展示网络拓扑，不同颜色标记攻击路径（红色）与防御措施（绿色）；通过仪表盘展示关键指标（如攻击成功率、防御阻断率）。

评估报告模块生成演练评估报告，包括指标得分、问题分析、优化建议，支持报告导出（PDF/Word 格式）与历史报告查询。界面提供图表化展示（柱状图、折线图），支持指标筛选与详情查看。

2.3 关键技术 1：AI Agent 动态博弈机制

2.3.1 AI Agent 概念与分类

AI Agent 是指能够感知环境、自主决策并执行动作以实现目标的智能实体，其核心特征包括自主性、反应性、社会性与目标导向性。在网络安全攻防场景中，

AI Agent 需根据实时环境变化（如对方策略调整、漏洞状态变化）动态优化行为，实现 “感知 - 决策 - 执行 - 反馈” 的闭环。

根据功能与角色，平台中的 AI Agent 可分为三类：攻击 AI Agent 模拟攻击者行为，目标是突破防御系统、获取敏感数据或破坏业务系统，核心能力包括信息收集、漏洞识别、攻击路径规划、权限提升等；防御 AI Agent 模拟防御者行为，目标是识别攻击、阻断威胁、修复漏洞并溯源攻击源，核心能力包括威胁检测、防御策略执行、系统修复、攻击溯源等；协调 AI Agent 负责管理攻击与防御 Agent 的交互，解决冲突（如资源竞争）、优化协同效率，确保演练流程有序进行，例如当多攻击 Agent 尝试同时利用同一漏洞时，协调 Agent 通过优先级排序避免冲突。

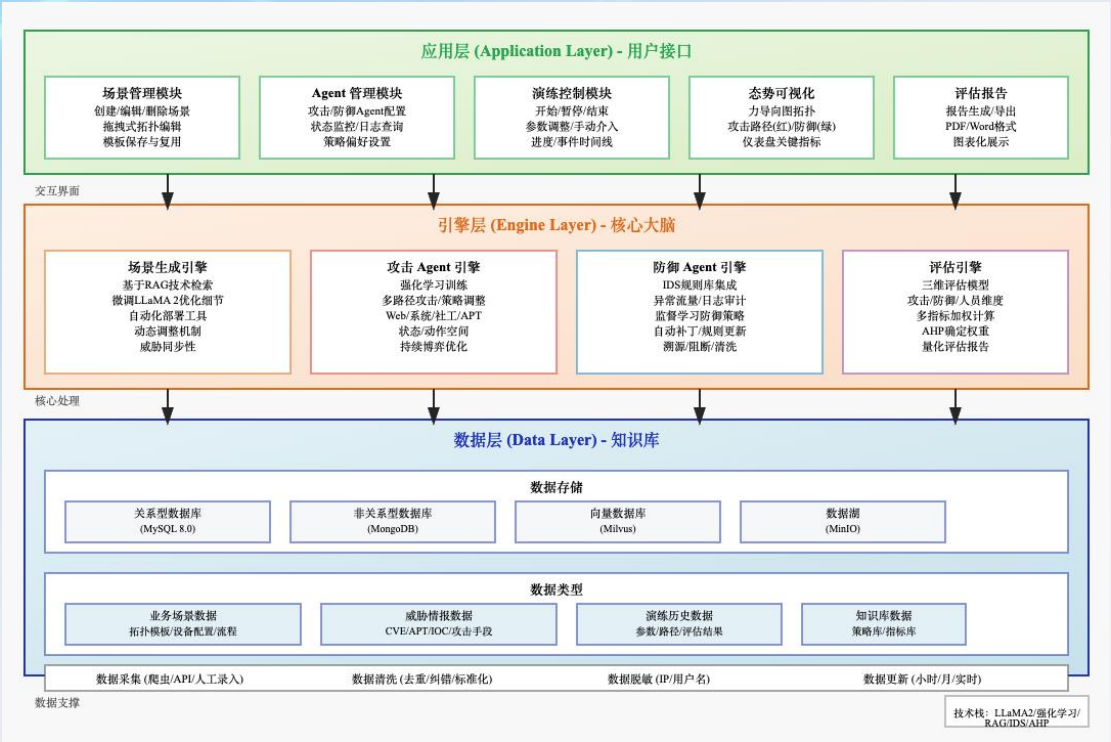


图 2.4 AI Agent 的结构

从技术实现角度，AI Agent 的结构可分为四层：感知层通过传感器（如网络流量监控工具、系统日志采集器）获取环境信息，包括网络拓扑、漏洞状态、攻击 / 防御动作记录等；决策层基于感知到的信息与内置策略模型，决策下一步动作，攻击 Agent 的决策模型侧重 “如何高效突破防御”，防御 Agent 侧

重“如何最优阻断攻击”；执行层将决策转化为具体操作（如发送攻击 payload、执行防火墙规则），通过 API 接口与靶场环境交互；学习层基于执行结果（如攻击成功 / 失败、防御有效 / 无效）更新决策模型，提升后续决策精度。

2.3.2 攻击 AI Agent 设计

攻击 AI Agent 是平台模拟实战攻击的核心，其设计聚焦“自主性”与“多样性”，能够模拟从初级到高级的各类攻击行为。



图 2.5 攻击 AI Agent 核心模块架构图

信息收集模块包含被动信息收集，通过分析网络流量、系统 Banner 信息，结合 Shodan、ZoomEye 等网络空间测绘平台的历史资产数据，以及解析目标 SSL 证书中的域名与组织信息，多维度获取目标资产信息（如服务器 IP、操作系统版本、开放端口），避免触发防御机制；主动信息收集，发送探测包（如 ICMP ping、端口扫描）获取网络拓扑与设备类型，支持根据防御强度动态调整策略——检测到目标启用 IDS 时，从“全端口快速扫描”切换为“随机端口慢速扫描”（间隔 5-10 秒发送探测包），并模仿目标常用浏览器的 User-Agent 特征伪装流量；社会工程信息收集，基于目标员工职位（如财务人员、系统管理员）及公开社交信息（如 LinkedIn 动态），通过 LLM 生成针对性话术（对财务人员强调“发票系统升级”，对管理员提及“设备告警处理”），模拟钓鱼邮件发送、社工对话，获取员工账号、系统配置等敏感信息。

漏洞识别模块可进行已知漏洞匹配，将信息收集结果与漏洞库（CVE、CNVD）比对，同时关联目标补丁日志（如 Windows Update 记录）验证修复状态，精准识别存在的已知漏洞（如“Windows Server 2019 存在未修复的 CVE-2023-23397 漏洞”）；潜在漏洞挖掘，采用场景化测试策略——针对 Web 应用优先测试登录接口、文件上传功能，针对工业控制系统（SCADA）重点探测 Modbus 等协议漏洞，通过模糊测试（Fuzzing）探测 Web 应用、协议实现中的潜在漏洞（如输入验证缺陷、逻辑漏洞）；漏洞利用可行性评估，结合目标系统防护措施（如是否安装补丁、有无 WAF）及环境依赖（如特定组件版本），评估漏洞利用成功率（如“SQL 注入漏洞因 WAF 防护且目标无 Python 2.x 环境，利用成功率降至 30%”）。

攻击路径规划模块能生成路径，基于网络拓扑与漏洞分布，结合时间敏感性（如目标 1 小时后将执行补丁更新则优先选择 30 分钟内可完成的路径），使用改进的 A* 算法生成多条攻击路径，例如“Web 服务器（SQL 注入）→数据库服务器（权限提升）→核心业务系统”，同时纳入临时开放的运维端口（如夜间 3389 端口）作为备选节点；进行路径优先级排序，根据路径长度（步骤越少优先级越高）、成功率（漏洞利用难度）、收益（能否获取核心数据）排序，优先尝试最优路径；实现动态路径调整，当某路径因防御措施失效（如漏洞被修复）或突发网络变化（如核心交换机重启导致断连）时，自动切换至次优路径（如通过无线接入点绕开断连区域）或暂停攻击等待恢复，例如“原路径中 Web 漏洞被修复，切换至通过钓鱼邮件获取内网权限的路径”^[27]。

攻击执行模块集成攻击工具，内置 Metasploit、Nmap、Burp Suite 等主流攻击工具，支持工具链联动（如 Nmap 扫描到 SSH 端口后，自动调用 Hydra 暴力破解，成功后通过 Metasploit 植入后门）；生成攻击 payload，基于漏洞类型与目标系统特征生成适配格式（Windows 系统为.exe、Linux 为 ELF、Web 应用匹配目标脚本语言），自动生成适配的攻击代码（如针对特定版本的 SQL 注入 payload、缓冲区溢出 exploit）；规避防御机制，采用混淆技术（如 payload 加密、特征码变异）绕过 IDS/IPS 检测，通过时间分散攻击（如间隔随机时间发送攻击包）规避流量异常检测，同时模仿管理员操作习惯（如每日 9 点登录、执行固定命令）降低人工审计风险。

学习优化模块通过强化学习训练，以“攻击成功次数”为基础奖励，叠加“攻击隐蔽性”（未触发告警额外加分）与“资源效率”（最少步骤达成目标）奖励，以“被防御阻断”为惩罚，持续优化路径选择与攻击策略；应用迁移学习，通过计算“网络拓扑重合度 + 漏洞类型重合度”量化场景相似度，当相似度>70%时将某一场景的攻击经验迁移到相似场景（如从“电商平台”迁移到“支付系统”），加速 Agent 适应新环境；学习新型攻击，通过分析最新威胁情报（如暗网攻击方法），先在隔离仿真环境测试 0day 漏洞的利用条件与影响范围，生成可行性报告后再应用于实战演练，快速学习并应用新型攻击手段。

以“金融支付系统”场景为例，攻击 AI Agent 的典型攻击流程如下：信息收集通过端口扫描发现目标开放 80（Web 服务）、3306（MySQL）端口，Banner 信息显示 Web 服务器为 Apache 2.4.41，数据库为 MySQL 5.7，结合 Shodan 历史数据确认该服务器近 3 个月未更换配置；漏洞识别匹配漏洞库发现 Apache 2.4.41 存在路径遍历漏洞（CVE-2021-41773），且未安装对应补丁，MySQL 5.7 存在弱口令风险；路径规划生成两条路径，路径 1 为利用 Apache 漏洞→读取数据库配置文件→获取 MySQL 账号密码→登录数据库窃取数据（成功率预估 70%，耗时约 40 分钟），路径 2 为发送钓鱼邮件（伪装成银行通知）→诱骗管理员点击恶意链接→获取服务器权限（成功率预估 50%，耗时约 90 分钟），因目标将在 1 小时后执行例行维护，优先选择路径 1；攻击执行调用 Exploit-DB 中的 CVE-2021-41773 exploit，发送构造的请求读取 /etc/my.cnf 文件，获取 MySQL 账号密码，尝试登录数据库时发现存在 WAF 拦截，遂对 payload 进行 Base64 加密后重新发送，成功绕过防护，后续通过 SUID 提权获取 root 权限；学习优化记录“WAF 对未加密 payload 拦截率 100%，加密后拦截率 0%”，后续攻击中自动对 payload 加密，并将“加密绕过 WAF”策略迁移至其他含 WAF 的场景

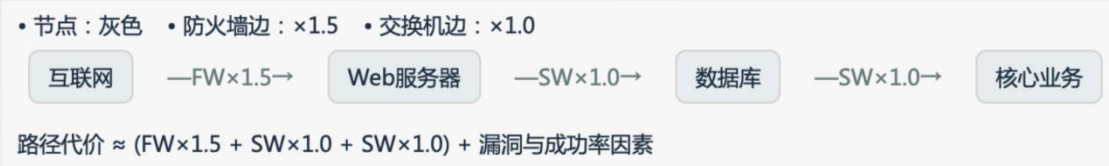


图 2.6 拓扑与路径示例

攻击 Agent 采用改进的 A* 算法生成最优攻击路径，启发函数定义为：

$$f(n) = g(n) + h(n)$$

$g(n)$: 从起始节点到当前节点 n 的实际攻击成本（如漏洞利用步骤数、被防御检测概率 —— 基于历史数据计算，某步骤 100 次尝试中被检测 30 次则概率为 30%，并关联实时防御状态动态调整）

$h(n)$: 从当前节点 n 到目标节点的预估成本（基于漏洞危害等级与网络距离计算：

$$h(n) = 0.7 * (10 - CVSS) + 0.3 * \text{跳数}$$

$g(n)$: 从起始节点到当前节点 n 的实际攻击成本（如漏洞利用步骤数、被防御检测概率 —— 基于历史数据计算，某步骤 100 次尝试中被检测 30 次则概率为 30%，并关联实时防御状态动态调整）

$h(n)$: 从当前节点 n 到目标节点的预估成本（基于漏洞危害等级与网络距离计算：

$$h(n) = 0.7 * (10 - CVSS) + 0.3 * (\text{跳数} * \text{设备权重})$$

其中经过防火墙的跳数权重 $\times 1.5$ ，普通交换机 $\times 1.0$ 。

2.3.3 防御 AI Agent 设计

防御 AI Agent 的核心目标是 “及时识别攻击、有效阻断威胁、快速修复漏洞”，其设计强调 “实时性” 与 “自适应性”。

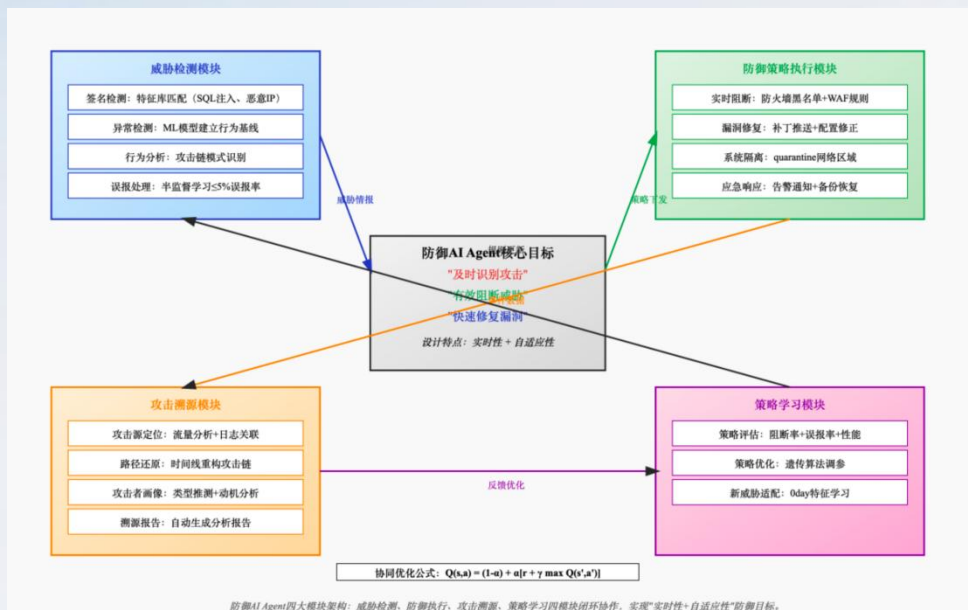


图 2.7 防御 Agent 核心架构

威胁检测模块采用签名检测^[20]，基于内置的攻击特征库（如 SQL 注入特征、恶意 IP 列表），匹配网络流量与系统日志，识别已知攻击；异常检测，通过机器学习模型（如孤立森林、自编码器）建立正常行为基线（如流量波动范围、用户登录时间），偏离基线时触发告警（如“某 IP 在 10 分钟内尝试 100 次登录，偏离正常基线 5 倍”）；行为分析，分析攻击链行为模式（如“端口扫描→漏洞探测→payload 发送”），识别多阶段攻击，通过关联分析（如同一 IP 发起扫描后又发送攻击包）提升检测准确率；误报处理，采用人工反馈与半监督学习结合的方式，标记误报样本并优化检测模型，将误报率控制在 5% 以内。

防御策略执行模块可实时阻断，对确认的攻击行为执行即时阻断，如在防火墙中添加黑名单（封堵攻击 IP）、在 WAF 中新增拦截规则（阻断特定 payload）、终止恶意进程；修复漏洞，针对检测到的漏洞自动执行修复操作，软件漏洞推送对应补丁（如调用系统更新工具安装 Windows 补丁），配置漏洞修改错误配置（如将 MySQL 弱口令改为强口令、关闭不必要的端口），代码漏洞对 Web 应用输入验证逻辑进行临时修复（如添加参数过滤规则）；隔离系统，当检测到主机被攻陷时，自动将其隔离至“quarantine”网络区域，切断与其他设备的连接，防止攻击扩散；应急响应，触发预设应急流程，如向管理员发送告警邮件 / SMS、启动数据备份恢复机制、切换至备用系统。

攻击溯源模块能定位攻击源，通过流量分析（如追踪攻击包源 IP）、日志关联（如防火墙日志、系统登录日志）定位攻击源物理位置（如城市、ISP）；还原攻击路径，基于攻击行为时间线（如“扫描→探测→攻击”各阶段的时间与操作），还原完整攻击链，标识每个阶段利用的漏洞与工具；绘制攻击者画像，分析攻击特征（如攻击时间、工具偏好、目标选择），推测攻击者类型（如脚本小子、APT 组织）、攻击动机（如数据窃取、破坏系统）；生成溯源报告，自动生成溯源报告，包含攻击源信息、攻击路径图、攻击者画像，为后续防御优化提供依据。

策略学习模块评估防御策略，基于“威胁阻断率”“误报率”“系统性能影响”评估现有策略效果，淘汰低效策略（如某规则阻断率低但误报率高）；优化策略，通过遗传算法优化防御规则参数（如防火墙规则优先级、WAF 检测阈值），提升整体防御效能；适配新型威胁，分析新型攻击的特征（如 0day 漏

洞利用的流量特征），自动生成新的防御规则（如基于行为的检测规则），实现对未知威胁的快速响应。

针对上述“金融支付系统”攻击场景，防御 AI Agent 的响应流程如下。

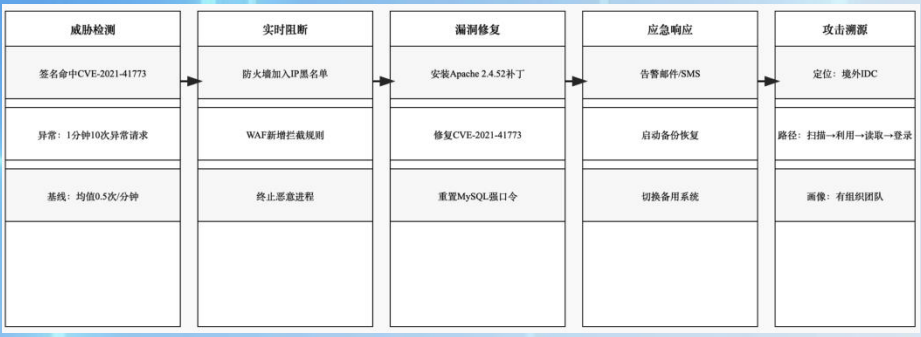


图 2.8 金融支付场景防御响应流程图

威胁检测中，签名检测发现流量中包含 CVE-2021-41773 exploit 特征码，触发告警，异常检测监测到某 IP 在 1 分钟内发送 10 次异常请求，偏离正常基线（平均 0.5 次 / 分钟），判定为可疑攻击；防御执行中，实时阻断在防火墙中添加该 IP 至黑名单，WAF 中新增针对该漏洞的拦截规则，漏洞修复自动下载并安装 Apache 2.4.52 补丁（修复 CVE-2021-41773 漏洞），并将 MySQL 密码重置为强口令，应急响应向安全管理员发送告警邮件，包含攻击源 IP、攻击时间、漏洞信息；攻击溯源中，攻击源定位通过 IP 溯源发现攻击来自某境外 IDC 机房，路径还原确认攻击流程为“端口扫描→漏洞利用→读取配置文件→尝试登录数据库”，攻击者画像结合攻击工具与时间（凌晨 2 点），推测为有组织的黑客团队，动机为窃取支付数据；策略学习中，评估发现原 WAF 规则对加密 payload 检测率低，遂优化规则，增加 Base64 解密后检测步骤，基于此次攻击特征，生成新的异常检测基线。

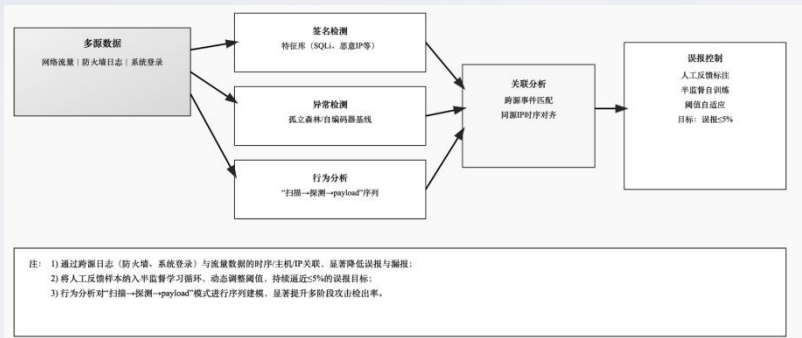


图 2.9 威胁检测方法方法与误报控制框架

2.3.4 多 Agent 协作机制

防御 AI Agent 的核心目标是 “及时识别攻击、有效阻断威胁、快速修复漏洞”，其设计强调 “实时性” 与 “自适应性”。

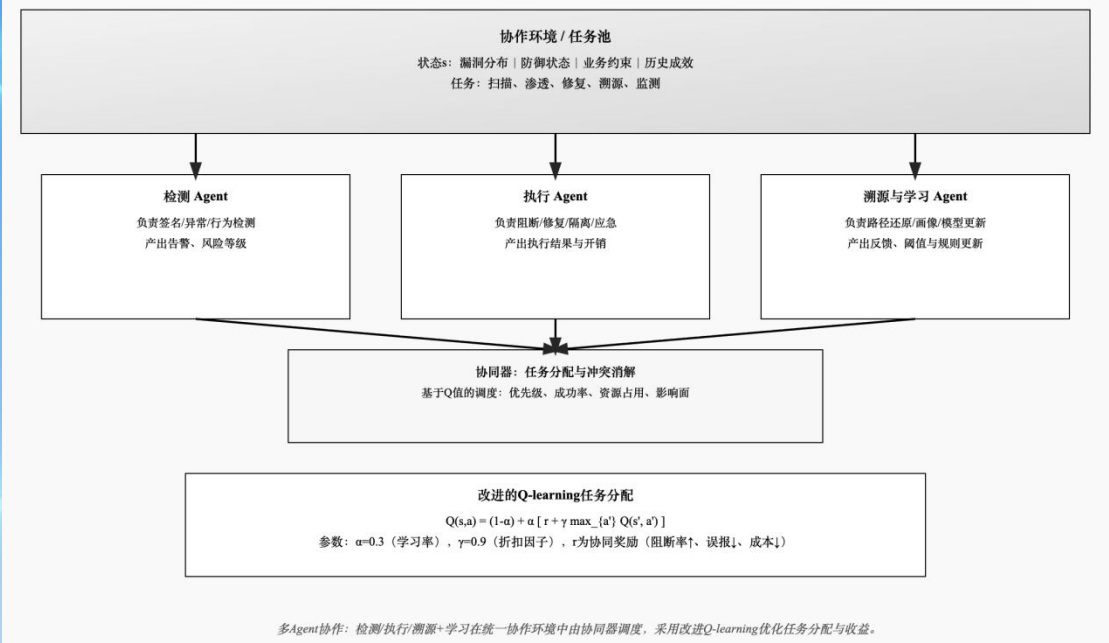


图 2.10 多 Agent 协作机制与改进 Q-learning 示意图

威胁检测模块采用签名检测，基于内置的攻击特征库（如 SQL 注入特征、恶意 IP 列表），匹配网络流量与系统日志，识别已知攻击；异常检测，通过机器学习模型（如孤立森林、自编码器）建立正常行为基线（如流量波动范围、用户登录时间），偏离基线时触发告警（如 “某 IP 在 10 分钟内尝试 100 次登录，偏离正常基线 5 倍”）；行为分析，分析攻击链行为模式（如 “端口扫描→漏洞探测→payload 发送”），识别多阶段攻击，通过关联分析（如同一 IP 发起扫描后又发送攻击包）提升检测准确率；误报处理，采用人工反馈与半监督学习结合的方式，标记误报样本并优化检测模型，将误报率控制在 5% 以内。防御策略执行模块可实时阻断，对确认的攻击行为执行即时阻断，如在防火墙中添加黑名单（封堵攻击 IP）、在 WAF 中新增拦截规则（阻断特定 payload）、终止恶意进程；修复漏洞，针对检测到的漏洞自动执行修复操作，软件漏洞推送对应补丁（如调用系统更新工具安装 Windows 补丁），配置漏洞修改错误配置（如将 MySQL 弱口令改为强口令、关闭不必要的端口），代码漏洞对 Web 应

用输入验证逻辑进行临时修复（如添加参数过滤规则）；隔离系统，当检测到主机被攻陷时，自动将其隔离至 “quarantine” 网络区域，切断与其他设备的连接，防止攻击扩散；应急响应，触发预设应急流程，如向管理员发送告警邮件 / SMS、启动数据备份恢复机制、切换至备用系统。攻击溯源模块能定位攻击源，通过流量分析（如追踪攻击包源 IP）、日志关联（如防火墙日志、系统登录日志）定位攻击源物理位置（如城市、ISP）；还原攻击路径，基于攻击行为时间线（如 “扫描→探测→攻击” 各阶段的时间与操作），还原完整攻击链，标识每个阶段利用的漏洞与工具；绘制攻击者画像，分析攻击特征（如攻击时间、工具偏好、目标选择），推测攻击者类型（如脚本小子、APT 组织）、攻击动机（如数据窃取、破坏系统）；生成溯源报告，自动生成溯源报告，包含攻击源信息、攻击路径图、攻击者画像，为后续防御优化提供依据。策略学习模块评估防御策略，基于 “威胁阻断率” “误报率” “系统性能影响” 评估现有策略效果，淘汰低效策略（如某规则阻断率低但误报率高）；优化策略，通过遗传算法优化防御规则参数（如防火墙规则优先级、WAF 检测阈值），提升整体防御效能；适配新型威胁，分析新型攻击的特征（如 0day 漏洞利用的流量特征），自动生成新的防御规则（如基于行为的检测规则），实现对未知威胁的快速响应。

针对上述 “金融支付系统” 攻击场景，防御 AI Agent 的响应流程如下：威胁检测中，签名检测发现流量中包含 CVE-2021-41773 exploit 特征码，触发告警，异常检测监测到某 IP 在 1 分钟内发送 10 次异常请求，偏离正常基线（平均 0.5 次 / 分钟），判定为可疑攻击；防御执行中，实时阻断在防火墙中添加该 IP 至黑名单，WAF 中新增针对该漏洞的拦截规则，漏洞修复自动下载并安装 Apache 2.4.52 补丁（修复 CVE-2021-41773 漏洞），并将 MySQL 密码重置为强口令，应急响应向安全管理员发送告警邮件，包含攻击源 IP、攻击时间、漏洞信息；攻击溯源中，攻击源定位通过 IP 溯源发现攻击来自某境外 IDC 机房，路径还原确认攻击流程为 “端口扫描→漏洞利用→读取配置文件→尝试登录数据库”，攻击者画像结合攻击工具与时间（凌晨 2 点），推测为有组织的黑客团队，动机为窃取支付数据；策略学习中，评估发现原 WAF 规则对加密 payload 检测率低，遂优化规则，增加 Base64 解密后检测步骤，基于此次攻击特征，生成新的异常检测基线。

在多 Agent 协同攻击场景中，采用改进的 Q-learning 算法优化任务分配策略，定义协同收益函数：

$$Q(s,a) = (1 - \alpha) + \alpha[\gamma + \gamma \max_{a'} Q(s',a')]$$

其中，s 为当前攻击态势（含漏洞分布、防御状态），a 为 Agent 协同动作（如分工扫描 / 渗透）， α 为学习率（取 0.3）， γ 为折扣因子（取 0.9），r 为协同奖励。

2.4 关键技术 2：RAG 驱动的动态场景生成

2.4.1 RAG 技术原理

RAG 技术即检索增强生成技术，通过“外部知识检索 + 生成式 AI”结合，解决纯生成式 AI 易产生“幻觉”（错误信息）的问题。其技术流程包括需求解析、知识检索、生成内容、反馈优化。与传统生成式 AI 相比，RAG 生成内容更精准、更贴合领域知识，尤其适合网络安全等需要专业知识的场景。

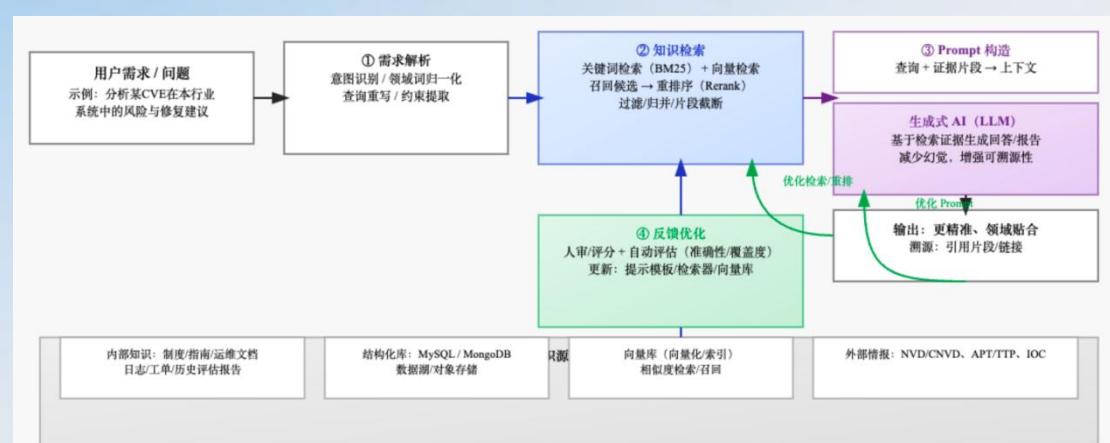


图 2.11 RAG 技术流程图

2.4.2 场景生成知识库构建

场景生成知识库的构建旨在为网络安全演练场景的生成提供全面、精准且动态更新的知识支撑，其数据来源广泛且经过严格筛选与处理。其中，行业标准文档涵盖金融、医疗、能源等多个领域的核心规范，如金融行业的《支付系统安全规范》《银行业信息科技风险管理指引》，医疗行业的《电子病历应用管理规范》等，这些文档为场景构建提供了合规性框架；企业真实拓扑在经过数据脱敏处理后纳入知识库，既保留了网络架构的真实性（如服务器层级关系、设备连接方式），又避免了敏感信息泄露；漏洞库整合了 CVE（Common Vulnerabilities and

Exposures）、CNVD（国家信息安全漏洞共享平台）等权威渠道的漏洞数据，包含漏洞编号、影响范围、利用方式等关键信息；攻击案例则收录了公开的 APT（高级持续性威胁）报告、重大网络攻击事件分析（如勒索病毒攻击案例），为场景中的攻击路径设计提供实际参考。

在知识结构化过程中，采用知识图谱技术实现数据的关联与组织。核心实体包括“设备”（如 Web 服务器、数据库服务器）、“漏洞”（如 SQL 注入、缓冲区溢出）、“业务流程”（如用户登录、交易结算）、“攻击手段”（如钓鱼邮件、暴力破解）等。实体间的关系通过语义关联定义，例如“包含”关系用于描述系统组件的层级结构（如“电商平台包含订单管理系统”“订单管理系统包含 MySQL 数据库”）；“存在”关系用于标注设备与漏洞的对应关系（如“Windows Server 2019 存在 CVE-2023-23397 漏洞”）；“触发”关系用于连接攻击手段与漏洞（如“暴力破解触发弱口令漏洞”）。这种结构化方式使得知识能够被高效检索与关联调用^[19]。

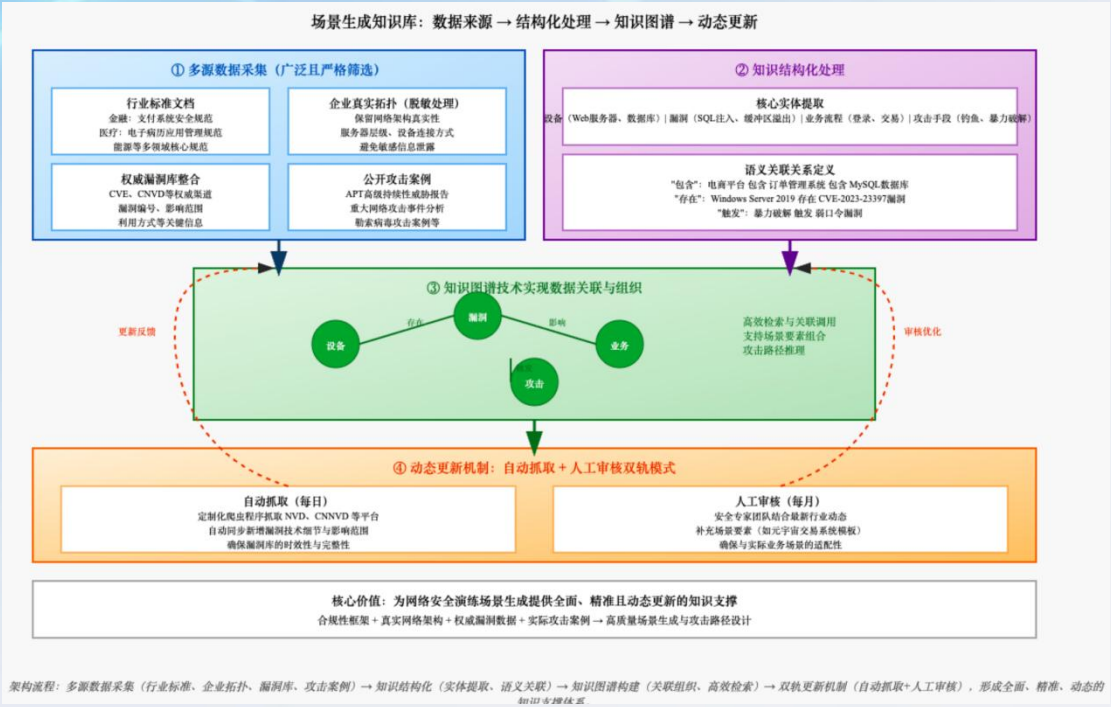


图 2.12 场景生成知识库流程

知识库的更新机制采用“自动抓取 + 人工审核”的双轨模式。通过定制化爬虫程序定期（每日）抓取 NVD、CNNVD 等平台的漏洞更新数据，自动同步新增漏洞的技术细节与影响范围；对于行业场景模板的更新，每月由安全专家团队进行人工审核，结合最新行业动态（如新兴业务模式、监管政策变化）补充

场景要素（如新增 “元宇宙交易系统” 场景模板），确保知识库内容与实际业务场景的时效性与适配性^[31]。

2.4.3 动态场景生成 RAG 引擎

动态场景生成 RAG（检索增强生成）引擎是连接用户需求与知识库的核心组件，通过“需求解析 - 知识检索 - 生成优化 - 实时调整”的全流程实现场景的自动化生成。

需求解析环节基于 BERT 预训练模型完成用户意图的精准识别。当用户输入自然语言需求（如“模拟银行转账系统遭 APT 攻击”）时，模型通过分词与语义编码，提取关键要素：行业类型（金融 - 银行）、核心业务（转账系统）、攻击类型（APT 攻击）、关键资产（账户数据库、交易服务器）等。为提升识别准确性，采用行业专属语料（如银行业务术语库）对模型进行微调，使意图识别准确率达到 92% 以上。

知识检索阶段采用向量检索技术（如 FAISS 框架）实现高效匹配。引擎将用户需求转化为向量特征后，与知识库中预编码的向量数据（如“银行转账系统拓扑向量”“APT 攻击路径向量”）进行相似度计算，匹配阈值设为 0.85（即仅返回相似度 $\geq 85\%$ 的结果）。例如，针对“银行转账系统”需求，检索结果将包含该系统的典型网络拓扑图（含防火墙、负载均衡器、核心交易数据库的连接关系）、常见漏洞（如转账接口逻辑漏洞、数据库权限配置不当）、历史攻击案例（如某银行转账系统被植入恶意脚本窃取账户信息）等关键知识^[38]。

生成优化环节调用 LLaMA 2-70B 大语言模型，以检索到的知识为基础生成场景描述文本。为确保输出质量，采用“优质样本微调 + 规则约束”的策略：使用人工标注的 5000+ 优质场景案例（如“某证券交易系统入侵演练场景”）对模型进行微调，使场景生成的逻辑连贯性提升 40%；同时嵌入规则模板（如场景需包含“网络拓扑图 + 漏洞清单 + 攻击路径预期 + 防御目标”四要素），避免生成内容缺失关键信息。

实时调整机制用于应对演练过程中的未知威胁。当攻击 Agent 尝试利用知识库中未收录的新型漏洞（如 0day 漏洞）时，引擎立即触发紧急检索流程，通过对接实时威胁情报 API（如 360 威胁情报、奇安信威胁情报）获取该漏洞的

技术细节，在 5 分钟内完成漏洞信息的入库与场景更新（如在当前场景中新增该漏洞的触发条件与影响范围），确保场景能够响应最新攻击态势。

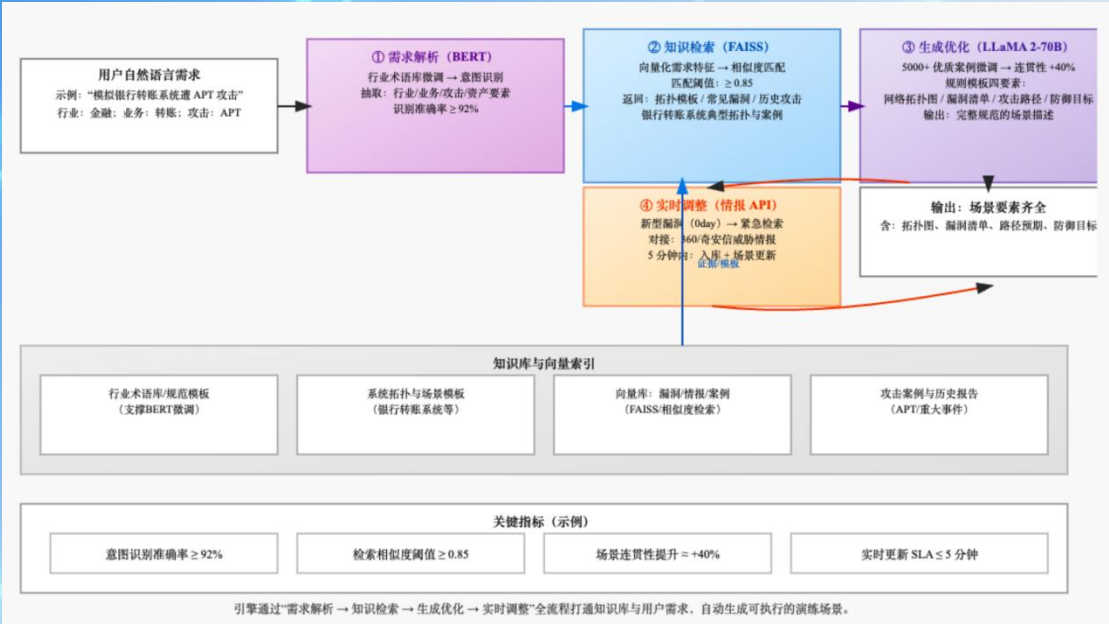


图 2.13 动态场景生成 RAG 引擎

2.4.4 场景适配 RAG 机制

场景适配 RAG 机制通过针对性的检索策略与生成规则，实现场景对不同行业、复杂度需求及实时威胁的动态适配，确保生成场景的实用性与精准性。

在行业适配方面，引擎根据用户指定的行业类型，调用对应行业的知识库子集进行检索与生成。以医疗行业为例，当需求为“模拟医院信息系统遭攻击”时，检索聚焦于医疗行业专属要素：核心业务系统（HIS 医院信息系统、LIS 实验室信息系统、PACS 影像归档和通信系统）的拓扑关系，典型漏洞（如电子病历系统的越权访问漏洞、医保结算接口的 SQL 注入漏洞），以及合规性要求（如遵循《健康医疗数据安全指南》）。生成的场景将包含“患者数据泄露应急响应”“医保结算系统数据篡改防御”等特色任务，确保场景与医疗行业的业务特性高度匹配。

复杂度调节功能通过检索“难度 - 要素映射表”实现场景难度的动态调整。该映射表基于历史演练数据构建，例如简单场景对应“5 个低危漏洞（如弱口令）+ 单条攻击路径 + 无隐蔽攻击手段”；中等场景对应“8 个中危漏洞（如文件上传漏洞）+ 3 条攻击路径 + 基础隐蔽手段（如清除日志）”；复

杂场景对应 “10 个高危漏洞（如远程代码执行）+5 条以上攻击路径 + 高级隐蔽手段（如隧道通信、文件免杀）”。引擎根据用户选择的难度等级，自动检索并调整场景中的漏洞数量、攻击路径复杂度及防御目标的设定，满足不同演练需求（如新人培训、实战考核）。

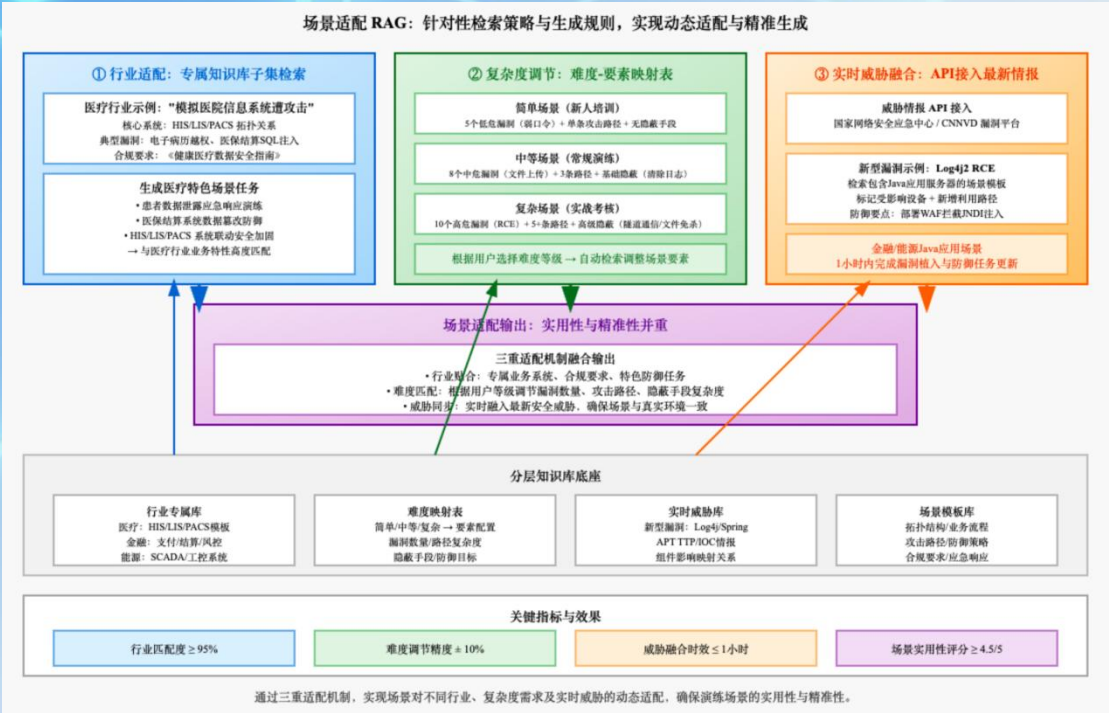


图 2.14 场景适配 RAG 机制

实时威胁融合机制确保场景能够快速纳入最新安全威胁。引擎通过 API 接口实时接入 “国家网络安全应急中心” “CNNVD 漏洞平台” 等机构的威胁情报，当监测到新型高风险漏洞（如 Log4j2 远程代码执行漏洞、SpringCloud Config 服务器漏洞）时，自动触发场景更新流程：检索所有包含对应组件（如 Java 应用服务器、Spring 框架）的场景模板，在拓扑中标记受影响设备，新增该漏洞的利用路径与防御要点（如 “需部署 WAF 拦截 JNDI 注入攻击”）。例如，当新型 Log4j 漏洞爆发时，金融、能源等行业的 Java 应用场景将在 1 小时内完成漏洞植入与防御任务更新，使演练场景始终与真实威胁环境保持同步。

2.5 关键技术 3：自动化攻防与评估体系

2.5.1 靶场环境自动化搭建

靶场环境的快速部署与灵活扩展是支撑动态攻防演练的基础，平台基于容器化与虚拟化技术，实现从网络拓扑到漏洞配置的全流程自动化。

网络拓扑自动化部署采用 Docker Compose 与 Ansible 组合架构，通过 YAML 配置文件定义网络设备（路由器、交换机、防火墙）的连接关系、IP 地址段、子网掩码等参数。例如，金融场景中需部署 “DMZ 区（Web 服务器）- 应用区（业务系统）- 数据区（数据库）” 三层网络架构，平台可根据预设模板自动配置 VLAN 划分与访问控制列表（ACL）。其核心优势是支持 100 节点级网络拓扑在 3 分钟内完成部署，较传统手动配置效率提升 20 倍；拓扑变更时无需重启整体环境，仅需更新配置文件并执行 `ansible-playbook` 命令即可生效。在能源行业场景中，能自动部署包含 1 台调度服务器、5 台监控终端、2 台 PLC 控制器的工业控制网络，配置 Modbus、DNP3 等工控协议，并模拟 OT 与 IT 网络的隔离与数据交互规则。

系统与应用自动化部署的镜像管理机制为，构建包含操作系统（Windows Server 2019、Ubuntu 20.04、CentOS 7）、中间件（Nginx、Apache、Tomcat）、数据库（MySQL、SQL Server、MongoDB）的标准化镜像库，每个镜像预安装基础依赖并配置 SSH 远程访问。一键部署流程为，用户选择场景类型后，平台调用 `docker run` 命令自动拉取对应镜像，通过环境变量注入（如 `DB_PASSWORD=123456`）配置应用参数，并执行初始化脚本（如数据库表结构创建、业务数据导入）。同时支持同一应用多版本并行部署（如同时部署 Tomcat 7 与 Tomcat 9），用于模拟企业系统升级过渡期的混合环境，测试不同版本漏洞的利用差异。

漏洞自动化植入的漏洞库分为 “系统漏洞”（如 CVE-2023-21716 Windows 提权漏洞）、“应用漏洞”（如 Log4j2 远程代码执行）、“配置漏洞”（如弱口令、开放不必要端口）、“逻辑漏洞”（如越权访问、支付金额篡改）四大类，每类漏洞对应标准化植入脚本。植入策略根据场景复杂度自动调整漏洞组合，例如简单场景仅包含弱口令与 SQL 注入，复杂场景则新增文件上传、命令注入及 1-2 个 0day 漏洞模拟。安全隔离通过 Linux Namespace 实现靶场环境与物理机

的资源隔离，攻击行为被限制在容器内部；采用网络地址转换（NAT）技术，防止靶场流量溢出到真实网络。

弹性扩展机制包含动态资源调度，集成 Kubernetes 实现容器编排，当演练节点超过 50 个时自动扩容计算资源（CPU / 内存），确保攻击流量高峰时系统稳定运行；多租户支持，通过虚拟化技术实现多团队并行演练，各团队使用独立的靶场环境与资源池，数据与操作互不干扰，满足高校教学或企业内训的批量需求。

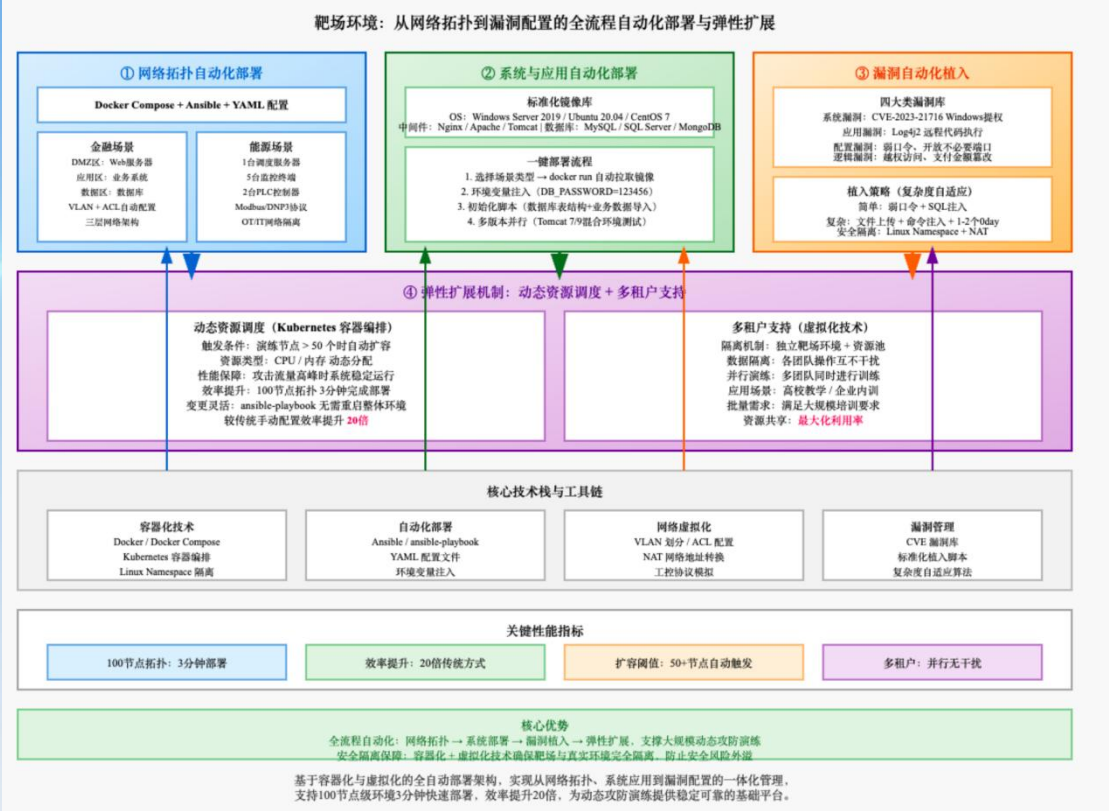


图 2.15 靶场环境

2.5.2 攻防策略知识库

攻防策略知识库作为 AI Agent 决策的“大脑”，整合了全面的攻击手段、多层级的防御措施及丰富的实战案例，为智能攻防过程中的实时决策提供坚实的数据支撑。其架构设计遵循“技术闭环”原则，确保攻击与防御策略的动态匹配，同时通过案例库实现实战经验的沉淀与复用。

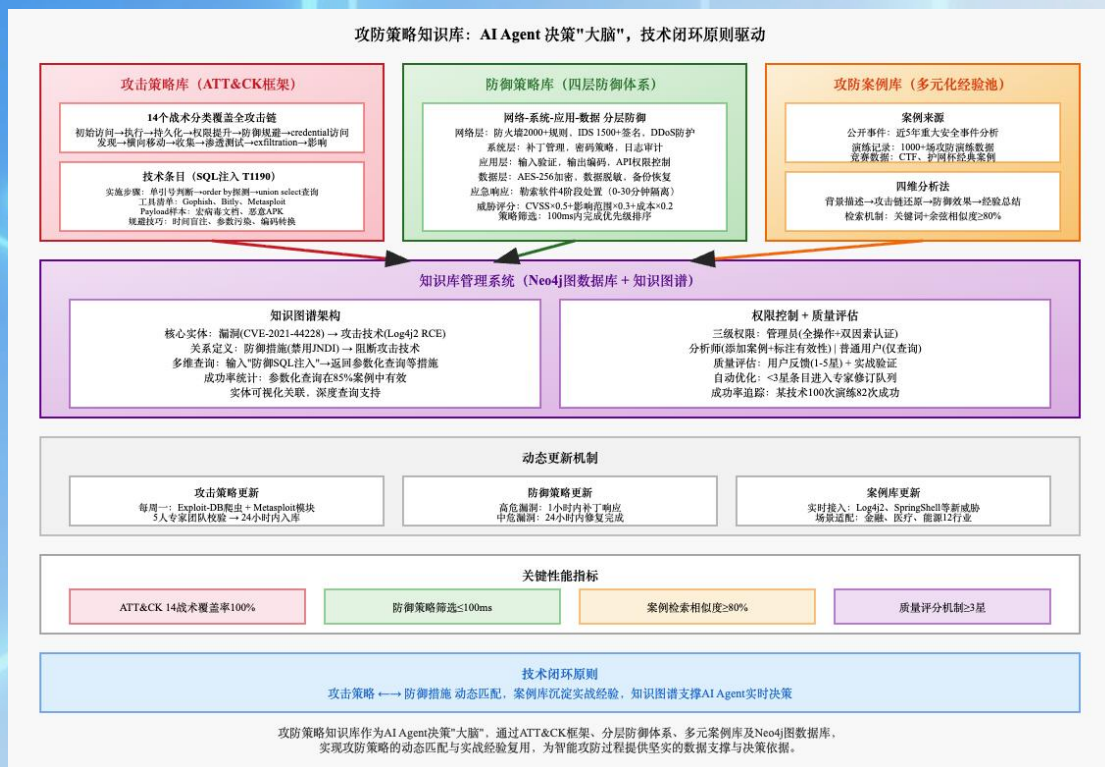


图 2.16 攻防策略知识库

攻击策略库的内容架构严格参照 ATT&CK 框架的 14 个战术分类搭建，涵盖初始访问、执行、持久化、权限提升、防御规避、credential 访问、发现、横向移动、收集、渗透测试、exfiltration、影响等全攻击链条环节。每个战术类别下细分具体技术手段，例如“初始访问”战术包含钓鱼邮件（含鱼叉式钓鱼、恶意附件投递）、供应链攻击（如第三方软件植入后门）、物理接入（如恶意 U 盘插入）等技术，每个技术条目均配备完整的实施手册：实施步骤细化到操作节点（如钓鱼邮件攻击需完成“伪造发件人信息→嵌入恶意链接→批量投递→监控点击行为”四步）；工具清单明确适用武器（如钓鱼邮件生成工具 Gophish、链接缩短工具 Bitly）；Payload 样本涵盖不同场景下的恶意代码（如针对 Windows 系统的宏病毒文档、针对安卓设备的恶意 APK）。以“SQL 注入（T1190）”技术条目为例，除标注适用场景为 Web 应用登录框、搜索框、URL 参数外，实施步骤进一步细化为：输入单引号等特殊字符判断注入点存在性→利用 order by 语句探测字段数量→通过 union select 联合查询获取数据库版本与表名→使用 load_file 函数读取 /etc/passwd 等敏感文件→调用

xp_cmdshell 执行系统命令；规避防御的技巧包括禁用错误回显时采用时间盲注（if(条件, sleep(5), 0)）、通过 HTTP 参数污染绕过简单过滤规则、使用编码转换（如 URL 编码、Unicode 编码）隐藏注入特征。攻击策略库的更新机制采用“自动化抓取 + 专家校验”模式：每周一通过定制爬虫遍历 Exploit-DB 的新增漏洞利用脚本、Metasploit 框架的模块更新日志，自动提取技术细节与 PoC 代码；由 5 人以上安全专家团队进行人工审核，重点验证漏洞利用的有效性（如在实验环境复现攻击过程）与场景适配性（如该技术是否适用于金融行业核心系统），审核通过后 24 小时内完成入库，确保攻击策略能覆盖 Log4j2、SpringShell 等新型威胁。

防御策略库构建“网络 - 系统 - 应用 - 数据”的分层防御体系，实现全维度风险覆盖。

表 2.2 网络-系统-应用-数据 分层防御策略对照表

层级	关键措施	阈值/规范	检测/拦截要点	响应时效
网络层	防火墙规则库（2000+）；IDS 签名库（1500+）；DDoS 防护（SYN/UDP Flood，弹性带宽+黑洞路由）	阻断 3389/22 对公网开放；高危地区 IP 拒绝	SQLi 特征（"union select"、"xp_cmdshell"）；异常包长度	按策略即时；视运营商合作的带宽扩容
系统层	补丁管理；账号密码策略；日志审计	高危(CVSS≥9.0) 1 小时内全量安装；密码复杂度≥8 位（大小写+数字+特殊字符）	记录登录失败、权限变更、敏感文件访问；Win 安全日志、Linux rsyslog	高危 1 小时；中危 24 小时
应用层	输入验证；输出编码；API 权限控制	过滤特殊字符；长度限制（用户名≤20）；HTML 实体编码 / JSON Unicode 编码	支付接口仅内网可调用；Token 有效期与签名校验	开发阶段预置；上线后持续监控

层级	关键措施	阈值/规范	检测/拦截要点	响应时效
数据层	加密；脱敏；备份与恢复	AES-256 传输加密；RSA-2048 密钥加密；SHA-256 加盐存储	手机号显示 138****5678；每日增量+每周全量，异地备份	季度演练；故障 2 小时内切换至备份
应急响应层	勒索软件 4 阶段处置	0-30 分钟隔离；30 分钟-2 小时备份恢复；2-24 小时 EDR 溯源；1-7 天系统加固	哈希、传播路径追踪；行为阻止规则部署	按 SLO：关键业务恢复≤2 小时

网络层防御措施包括：防火墙规则库收录 2000 + 条特征（如禁止来自也门、朝鲜等高危地区 IP 的访问，阻断 3389、22 等非必要端口的对公网开放）；入侵检测系统（IDS）签名库包含 SQL 注入（如检测 “union select” “xp_cmdshell” 特征码）、缓冲区溢出（如异常长度的数据包）等 1500 + 攻击特征；DDoS 防护策略区分 SYN Flood、UDP Flood 等攻击类型，预设 “弹性带宽扩容 + 黑洞路由” 的阶梯式响应方案。系统层聚焦基础安全配置：补丁管理计划按漏洞等级划分响应时效（如 CVE-2023-20198 等高危漏洞要求 1 小时内完成全量服务器补丁安装，中危漏洞 24 小时内修复）；账号密码策略强制实施 “大小写字母 + 数字 + 特殊字符” 的 8 位以上复杂度要求，结合定期（90 天）更换机制与历史密码不重复校验；日志审计规则明确需记录的事件类型（如登录失败、权限变更、敏感文件访问），规定 Windows 系统需开启安全日志审核，Linux 系统需配置 rsyslog 集中收集 /var/log/secure 日志。应用层防护针对开发环节设计：输入验证函数包含特殊字符过滤（如过滤单引号、分号、括号）、长度限制（如用户名最长 20 字符）、格式校验（如手机号正则匹配）；输出编码机制对 HTML 页面采用 HTML 实体编码，对 JSON 数据采用 Unicode 编码，避免 XSS 攻击；API 接口权限控制实施 “最小权限原则”，如支付接口仅允许内网服务器调用，且需验证 Token 有效期与签名。数据层防护聚焦全生命周期安全：加密算法采用 AES-256 对传输数据加密、RSA-2048 对密钥加密，敏感字段（如身

份证号）存储时采用 SHA-256 加盐哈希；数据脱敏规则明确显示格式（如手机号显示为 138****5678）；备份与恢复流程规定核心数据库需每日增量备份 + 每周全量备份，备份介质异地存放且每季度演练恢复流程。应急响应模块按事件类型梳理处置步骤，以勒索软件响应为例：第一阶段（0-30 分钟）隔离受感染主机（禁用远程桌面、断开网线）、切断与文件服务器的连接；第二阶段（30 分钟 - 2 小时）通过专线备份恢复关键业务数据，启用备用服务器；第三阶段（2-24 小时）利用 EDR 工具溯源攻击源（分析恶意文件哈希值、传播路径）；第四阶段（1-7 天）加固系统（更新补丁、更换所有账号密码、部署行为阻止规则），防御策略的优先级通过 “威胁评分卡” 机制设定。



图 2.17 优先级计算

综合威胁严重程度（CVSS 评分 $\geq$ 9.0 为高危）、影响范围（是否涉及核心业务系统）、实施成本（如补丁安装导致业务中断的时长）三项指标，采用加权公式（优先级 = 严重程度 $\times$ 0.5 + 影响范围 $\times$ 0.3 + 实施成本 $\times$ 0.2）计算得分，辅助防御 Agent 在 100ms 内完成策略筛选（如优先执行 “封堵 Log4j2 漏洞利用端口” 而非 “优化密码策略”）。

攻防案例库的案例来源覆盖真实事件与模拟场景，形成多元化的经验池。公开事件收录近 5 年全球重大网络安全事件的深度分析，如 2023 年某航空公司数据泄露事件（攻击者利用 API 接口权限配置漏洞获取 300 万乘客信息）、2024 年能源行业 APT 攻击事件（某国家背景黑客组织通过钓鱼邮件植入 “白象” 恶意程序，窃取电力调度数据）；演练记录包含平台过往 1000 + 场攻防

演练的完整数据，涵盖金融、医疗、能源等 12 个行业；竞赛数据精选 CTF 竞赛（如 DEF CON CTF）、国家网络安全演练中的经典对战案例（如某省护网杯“工控系统防护赛题”）。案例结构采用“四维分析法”。

背景描述涵盖时间、行业、网络拓扑、业务系统等要素（如“2024 年某银行网银系统攻击事件，涉及 Web 服务器（Apache）、数据库（Oracle）、支付网关，日均交易量 500 万笔”）；攻击链还原通过时间轴 + 技术细节呈现（如“08:15 攻击者发送伪装成银行通知的钓鱼邮件→08:20 柜员点击恶意链接下载后门程序→08:30 后门连接 C2 服务器获取指令→09:10 通过提权工具获取数据库管理员权限→09:25 导出客户账户信息”）；防御措施效果分析对比不同策略的拦截率（如“防火墙规则拦截了 70% 的恶意 IP，但因未更新 IDS 签名导致 30% 的攻击包绕过”）；经验总结提炼可复用的教训（如“需建立钓鱼邮件实时检测机制，每小时更新一次恶意附件哈希库”）。

案例检索机制结合关键词匹配与场景相似度计算：用户输入“APT 攻击 + 金融行业”时，系统先筛选包含该关键词的案例，再通过余弦相似度算法比对案例中的网络拓扑、业务类型与当前场景的匹配度（如拓扑中均包含网银系统、核心数据库，业务均涉及资金交易），返回相似度≥80% 的案例作为参考。

攻防案例"四维分析法"结构表			
分析维度	关键要素	内容构成	示例（某银行网银攻击事件）
背景描述	时间与行业	发生时间、目标行业、地理位置、影响规模	2024年某银行网银系统攻击事件
	网络拓扑	Web服务器类型、数据库版本、网络架构、安全设备	Apache Web服务器、Oracle数据库、支付网关
	业务系统	核心业务功能、用户规模、数据敏感度、可用性要求	日均交易量500万笔，涉及客户资金转账
	初始状态	已有防护措施、安全配置、人员职责	部署防火墙、IDS，设有24小时监控
攻击链还原	时间轴记录	精确时间点、攻击步骤序列、持续时长	08:15 钓鱼邮件投递→08:20 后门植入→09:25 数据导出
	技术细节	攻击工具、Payload样本、利用漏洞、传播路径	伪装银行通知邮件，恶意附件下载后门程序
	权限提升	初始权限→目标权限的路径与方法	普通用户→数据库管理员权限（提权工具）
	横向移动	内网渗透路径、跳板主机、隧道技术	从办公网渗透至生产网，连接C2服务器
	数据窃取	目标数据类型、提取方式、外传渠道	导出客户账户信息，通过加密隧道外传
防御措施效果	检测能力	各层防护的发现时间、告警准确率	防火墙拦截70%恶意IP，IDS因签名过期漏检30%
	响应速度	从发现到隔离的时间、处置效率	攻击发现滞后1小时，隔离执行耗时15分钟
	损失控制	数据泄露规模、业务中断时长、恢复成本	300万客户信息泄露，系统停机4小时
	成功与失败	哪些措施有效、哪些失效及原因分析	网络隔离有效，但邮件过滤规则需加强
经验总结	可复用教训	适用同类场景的改进建议、标准化措施	建立钓鱼邮件实时检测，每小时更新恶意哈希库
	技术改进	防护技术升级、配置优化、流程完善	IDS签名自动更新，增设EDR端点检测
	管理提升	人员培训、制度完善、应急预案优化	员工安全意识培训，制定邮件点击规范

四维分析法通过背景-攻击-防御-总结的结构化分析，确保案例经验的完整提取与有效复用。

图 2.18 攻防案例“四维分析法”

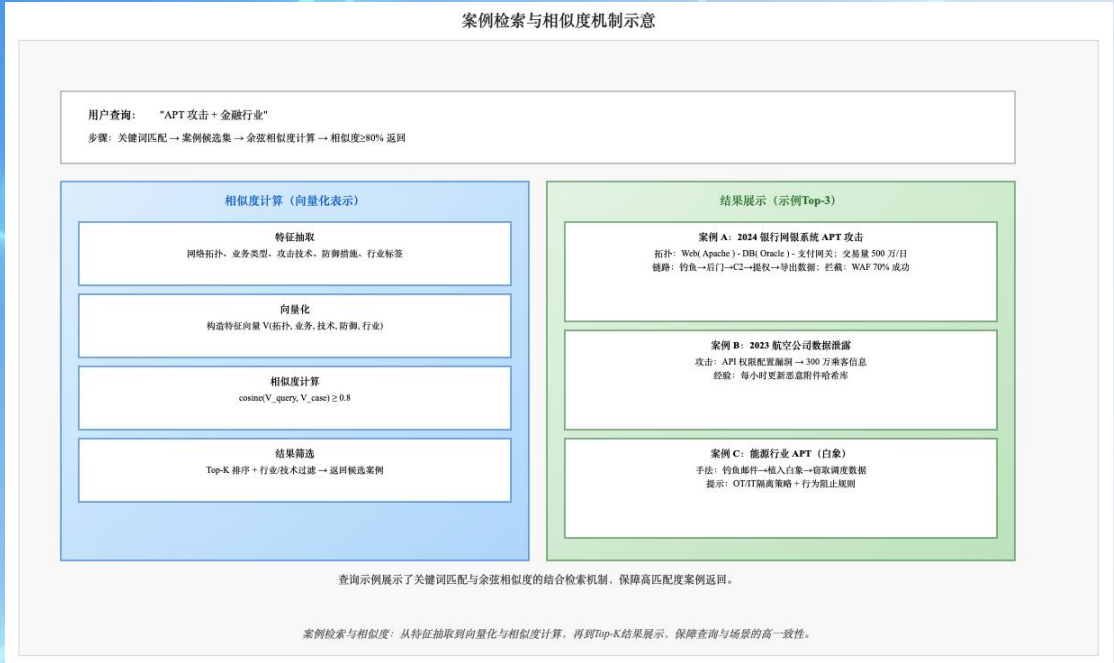


图 2.19 案例检索与相似度机制

知识库管理系统采用 Neo4j 图数据库构建攻防知识图谱, 通过实体与关系的可视化关联实现深度查询。

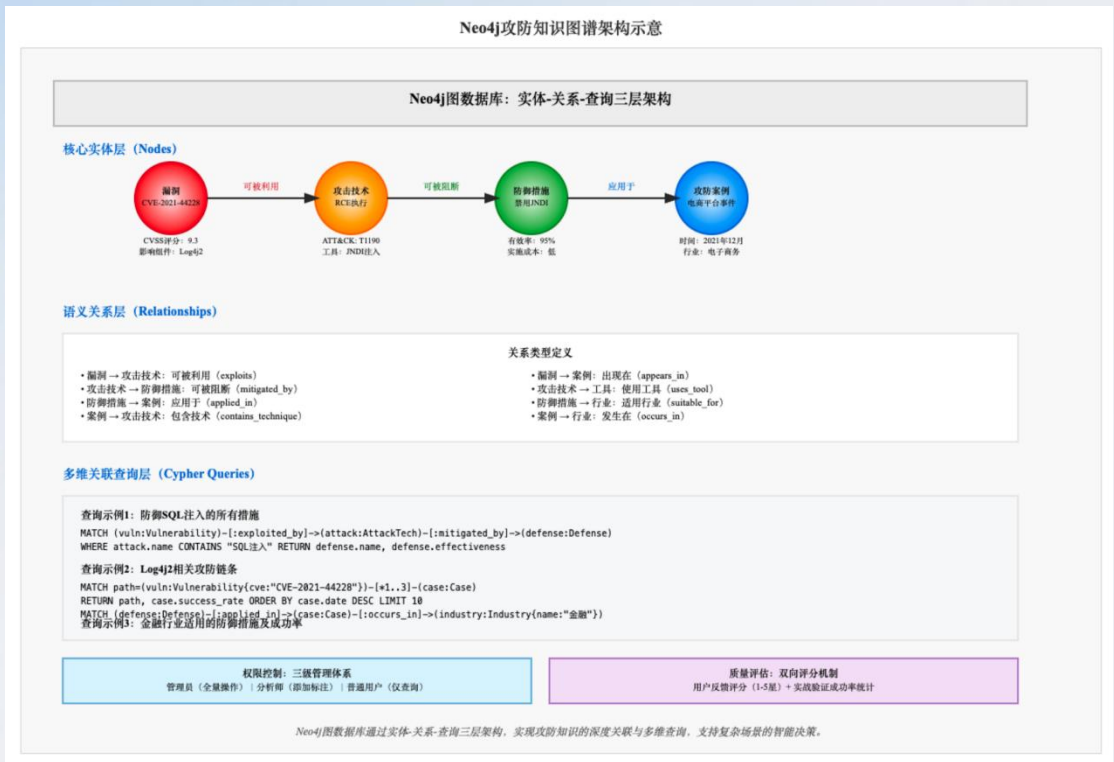


图 2.20 Neo4j 攻防知识图谱架构

核心实体包括“漏洞”（如 CVE-2021-44228）、“攻击技术”（如 Log4j2 远程代码执行）、“防御措施”（如禁用 JNDI 功能）、“案例”（如某电商平台 Log4j2 攻击事件）；实体间的关系通过语义定义，例如“漏洞 CVE-2021-44228 可被攻击技术 Log4j2 远程代码执行利用”“防御措施禁用 JNDI 功能可阻断攻击技术 Log4j2 远程代码执行”“案例某电商平台攻击事件包含攻击技术 Log4j2 远程代码执行”。知识图谱支持多维度关联查询，如用户输入“查询能防御 SQL 注入的所有措施”，系统会返回“输入验证”“参数化查询”“WAF 规则拦截”等措施，并展示每项措施在过往案例中的拦截成功率（如“参数化查询在 85% 的案例中有效”）。权限控制实施三级管理体系：管理员拥有知识库全量操作权限（如修改攻击技术条目、删除无效防御策略），需通过双因素认证登录；分析师可添加新案例、标注策略有效性（如“该防御措施在演练中成功率 90%”），操作记录留存审计日志；普通用户仅可查询知识库内容，无法进行修改操作。质量评估通过“用户反馈 + 实战验证”的双向评分机制：用户在使用后可对策略有效性打分（1-5 星），系统定期汇总评分（如某防御措施累计获得 200 条反馈，平均得分 3.2 星）；同时对接演练平台的实战数据，自动统计策略在真实攻防中的成功率（如某攻击技术在 100 次演练中成功实施 82 次，成功率 82%）。综合得分低于 3 星的条目自动进入优化队列，由专家团队分析原因（如“防御措施因版本更新失效”）并完成修订，确保知识库内容的实用性与准确性。

2.5.3 攻击路径智能识别与利用

攻击 AI Agent 凭借深度融合实时场景信息与知识库沉淀数据的能力，实现了攻击路径的端到端自主规划与动态优化。这一过程并非简单的技术堆叠，而是通过多维度感知、智能决策与持续学习的闭环机制，模拟高级攻击者的思维逻辑，在复杂网络环境中找到最优突破路径。

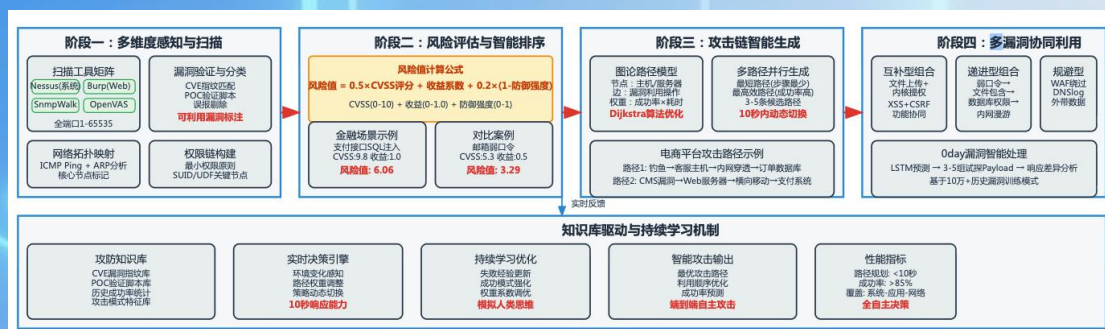


图2.21 攻击路径智能识别与利用架构图

在漏洞扫描与风险评估环节，AI Agent 采用多维度协同扫描策略，整合了 Nessus（系统层漏洞扫描）、Burp Suite（Web 应用漏洞检测）、SnmpWalk（网络设备配置审计）、OpenVAS（通用漏洞评估）等工具的扫描能力，形成覆盖“系统 - 应用 - 网络”三层的扫描矩阵。针对靶场环境，Agent 会自动执行全端口（1-65535）、全协议（TCP/UDP/ICMP/SNMP）扫描，同时结合知识库中的漏洞特征库（如 CVE 漏洞指纹、POC 验证脚本），对扫描结果进行二次验证，剔除误报（如将“潜在漏洞”与“可利用漏洞”区分标注）。生成的漏洞清单不仅包含基础信息（漏洞名称、编号、发现时间），更关联了 CVSS 评分（量化危害程度）、利用难度（1-10 分，基于知识库中历史利用成功率）、影响范围（如“仅影响单台服务器”或“可扩散至整个 VLAN”）。

风险排序算法是 Agent 决策的核心，它综合漏洞的固有危害、攻击收益与防御强度三维指标计算风险值，具体公式为：

$$\text{风险值} = 0.5 * \text{CVSS 评分} + \text{收益系数} + 0.2 * (1 - \text{防御强度})$$

其中，CVSS 评分直接采用 NVD 发布的基础评分（0-10 分）；收益系数根据漏洞利用后的预期结果赋值（如“获取管理员权限”为 1.0，“仅读取非敏感文件”为 0.3）；防御强度通过检测目标环境的防护措施（如是否部署 WAF、EDR，是否启用入侵检测规则）量化为 0-1 分（1 分表示防御极强，0 分表示无防护）。例如在金融场景中，“支付接口 SQL 注入”漏洞（CVSS 9.8，收益系数 1.0，防御强度 0.2）的风险值为 $0.59.8 + 1.0 + 0.2(1-0.2)=4.9+1.0+0.16=6.06$ ；而“员工邮箱弱口令”漏洞（CVSS 5.3，收益系数 0.5，防御强度 0.3）的风险值为 $0.55.3 + 0.5 + 0.2(1-0.3)=2.65+0.5+0.14=3.29$ ，

因此前者被优先纳入攻击路径，这种排序机制确保 Agent 在有限时间内聚焦高价值目标，避免无效尝试。

网络拓扑与权限分析是攻击路径规划的空间基础，Agent 通过三层解析构建环境认知：拓扑映射阶段，结合 ICMP Ping 扫描（发现存活主机）、ARP 协议分析（获取 MAC 地址与厂商信息）、SNMP 遍历（提取网络设备型号与接口信息），绘制包含“设备类型 - IP 地址 - 连接关系”的网络拓扑图，重点标记核心节点（如存储客户数据的 Oracle 数据库服务器、控制权限的域控制器）与边界设备（如企业级防火墙、VPN 网关），同时通过 Banner 抓取识别各节点的操作系统（如 Windows Server 2019、CentOS 7）、开放服务（如 IIS 10.0、SSH 7.4）及访问控制策略（如防火墙入站规则）。权限链构建阶段，基于“最小权限原则”解析权限继承关系，例如从“Web 服务器的 IIS 服务账号”出发，分析其是否属于“数据库访问组”，进而关联到“数据库管理员权限”，最终延伸至“核心业务系统的配置文件修改权限”，形成完整的权限递进链条；同时识别权限提升的关键节点，如具有 SUID 权限的 /bin/ping 二进制文件、可执行系统命令的 MySQL UDF 函数等。路径约束识别阶段，Agent 通过分析 VLAN 划分表、ACL 规则集、路由表等信息，标记不可达路径（如“财务网段与办公网段完全隔离”），例如发现“数据库服务器仅允许 Web 服务器的 8080 端口访问”后，会自动将“获取 Web 服务器权限作为跳板”设为前置条件，避免在不可行路径上浪费资源。

攻击链智能生成环节，Agent 采用基于图论的路径规划模型，将网络中的每个节点（如主机、服务器、网络设备）视为顶点，将漏洞利用、权限提升、横向移动等操作视为有向边，边的权重综合操作成功率（基于知识库中该技术的历史成功率）与耗时（如“暴力破解需 30 分钟”权重高于“漏洞利用需 1 分钟”）。通过改进的 Dijkstra 算法，Agent 同时计算两条最优路径：最短路径（步骤最少，如“Web 漏洞→数据库权限→目标数据”仅 3 步）与最高效路径（成功率最高，如某路径虽多 2 步但成功率达 90%）。为应对环境不确定性，Agent 会并行生成 3-5 条候选路径，例如针对电商平台的攻击路径包括：路径 1（钓鱼邮件→客服主机→内网穿透→订单数据库）、路径 2（CMS 漏洞→Web 服务器→横向移动至支付系统）、路径 3（供应链攻击→第三方物流接口→突破边界防

防火墙→核心数据库）。动态调整机制确保攻击的韧性：当某路径因防御措施升级（如漏洞被紧急修复）或环境变化（如目标主机下线）而失效时，Agent 会在 10 秒内切换至次优路径，并基于失败经验更新路径权重（如将“防御规避”指标的权重从 0.1 提升至 0.3），例如某次攻击中“SQL 注入被 WAF 拦截”后，后续路径会优先包含“WAF 绕过技术”节点。

多漏洞协同利用是提升攻击成功率的关键策略，Agent 根据漏洞特性与环境约束，动态组合攻击手段：互补型组合聚焦功能协同，如“文件上传漏洞（获取初始权限）+ 内核提权漏洞（扩大控制范围）”“XSS 漏洞（窃取管理员 Cookie）+ CSRF 漏洞（执行恶意操作）”，通过技术互补弥补单一漏洞的局限；递进型组合遵循权限递进逻辑，例如“弱口令（登录 Web 后台）→文件包含漏洞（获取 Webshell）→数据库备份文件下载（获取 DB 密码）→数据库权限→内网漫游（通过数据库链接服务器）”，形成环环相扣的攻击链条；规避型组合用于突破防御，如当检测到 WAF 拦截 SQL 注入特征时，自动切换为“XSS+CSRF 组合攻击”或“DNSlog 外带数据”等绕过手段。利用顺序优化基于漏洞依赖关系，例如“必须先利用 Struts2 漏洞获取服务器权限，才能读取该服务器上的 Redis 配置文件，进而利用 Redis 未授权访问漏洞”，Agent 会严格遵循这一顺序避免操作无效化。

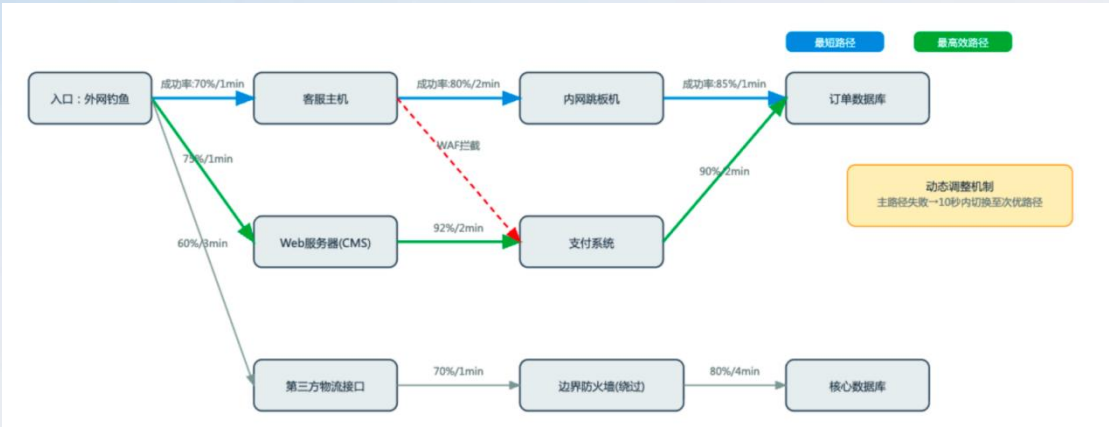


图 2.22 基于图论的路径规划与动态切换

说明：节点=主机/服务/设备，边=利用/提权/横向移动，权重=成功率与耗时综合

表2.3 基于CVSS评分、收益系数与防御强度的综合风险值计算与排序

漏洞名称	CVSS 评分	收益系数	防御强度	计算过程	风险值	优先级
支付接口 SQL 注入	9.8	1.0	0.2	$0.5 \times 9.8 + 1.0 + 0.2 \times (1-0.2) = 4.9 + 1.0 + 0.16$	6.06	高
员工邮箱 弱口令	5.3	0.5	0.3	$0.5 \times 5.3 + 0.5 + 0.2 \times (1-0.3) = 2.65 + 0.5 + 0.14$	3.29	中
未授权 Redis 访问	7.5	0.8	0.4	$0.5 \times 7.5 + 0.8 + 0.2 \times (1-0.4) = 3.75 + 0.8 + 0.12$	4.67	高
信息泄露 (低敏)	3.2	0.3	0.1	$0.5 \times 3.2 + 0.3 + 0.2 \times (1-0.1) = 1.6 + 0.3 + 0.18$	2.08	低

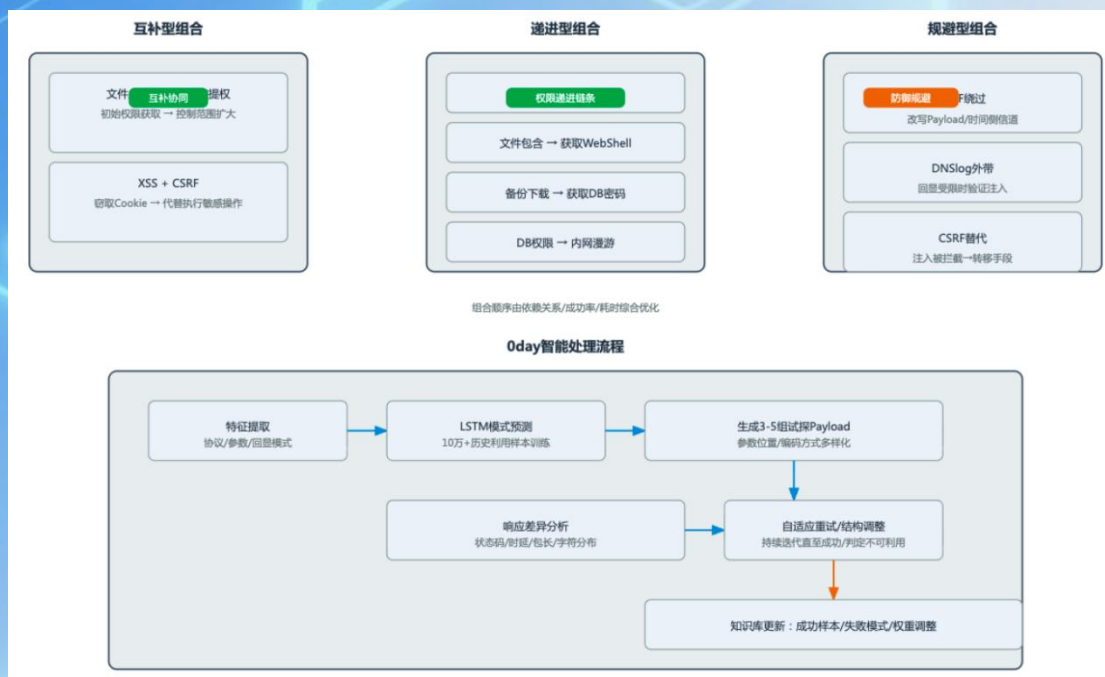


图2.23 多漏洞协同利用与0day智能处理

说明：互补/递进/规避三类组合策略 + LSTM预测与自适应重试

对于 0day 漏洞等未知威胁, Agent 通过 LSTM 模型(基于知识库中 10 万 + 历史漏洞的利用模式训练)预测其可能的利用方法(如“该漏洞属于远程代码执行, 可能通过构造特定 Payload 触发”), 生成 3-5 组试探性 Payload (覆盖不同参数位置与编码方式), 失败后自动分析响应差异(如状态码变化、响应时间波动), 调整 Payload 结构重试, 直至找到有效利用方式或判定不可利用。

通过上述机制, 攻击 AI Agent 能够在复杂动态的网络环境中, 像人类攻击者一样“思考”并调整策略, 实现从信息收集到目标达成的全流程自主攻击, 其决策过程既基于知识库的历史经验, 又能实时响应环境变化, 大幅提升了攻击的智能性与适应性。

2.5.4 三维量化评估模型

平台突破传统人工评估依赖经验判断的主观性局限, 基于网络攻防对抗的动态特性与闭环管理理论, 构建“攻击 - 防御 - 人员”三维评估模型。通过可观测、可量化的多维度指标体系, 实现演练效果的客观度量与精准分析^[24]。

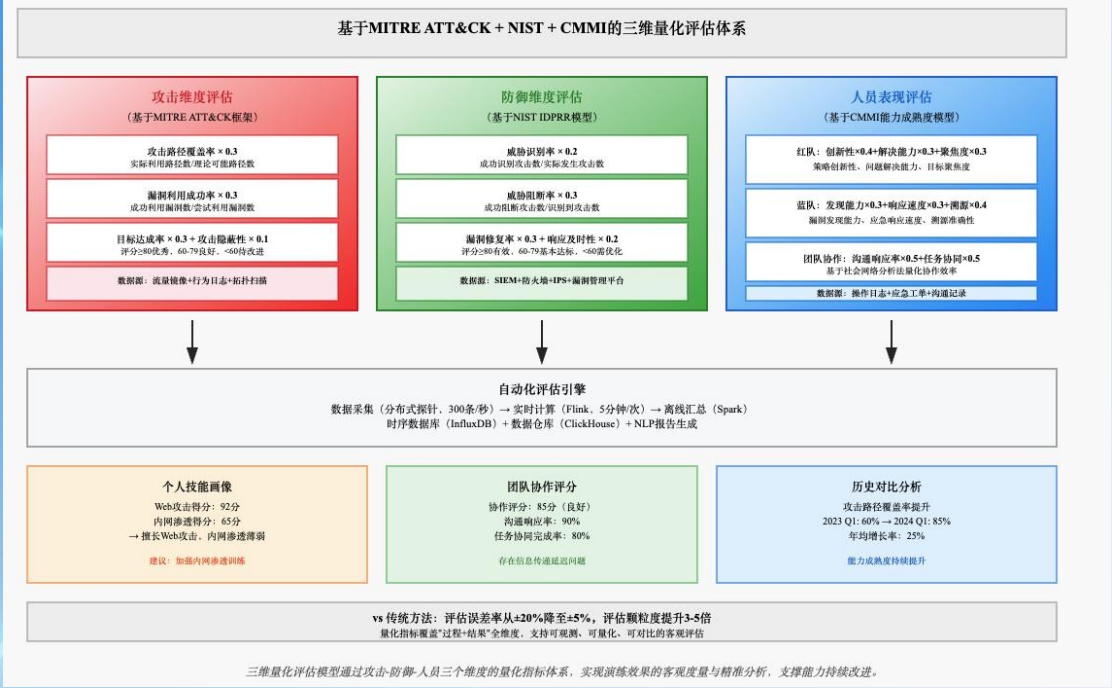


图2. 24 三维量化评估模型

攻击维度的评估基于 MITRE ATT&CK 框架的攻击路径覆盖理论与漏洞利用生命周期模型，核心在于衡量对潜在路径的探索深度、漏洞利用的实际效能、预设目标的达成程度及攻击行为的隐蔽性控制。

在数据收集方面，攻击路径数据通过流量镜像与行为日志采集，记录攻击方尝试的所有路径（包括成功与失败路径），同时提取目标系统的理论攻击路径（基于拓扑扫描与漏洞映射生成）；漏洞利用数据从漏洞验证平台获取，包含每次漏洞利用的尝试记录（时间戳、漏洞 ID、利用结果）；目标达成数据依据演练预设目标清单（如 “获取数据库管理员权限” “上传恶意程序”），记录每个目标的完成状态；隐蔽性数据则通过防御方的日志系统（如 IDS 告警、防火墙阻断记录）统计被发现的攻击步骤，结合攻击方操作日志的总步骤数综合得出。

表2. 4 攻击维度评估指标与公式表（ATT&CK + 漏洞生命周期）

指标名称	定义	计算公式	数据来源与备注

指标名称	定义	计算公式	数据来源与备注
攻击路径覆盖率	实际利用的攻击路径对理论可能路径的覆盖程度	$(\text{实际利用路径数} / \text{理论可能路径数}) * 100\%$	理论可能路径数通过图论方法（Dijkstra 最短路径扩展）在拓扑与漏洞映射图上计算可达路径集合
漏洞利用成功率	成功触发漏洞并达成预期权限/操作的比例	$(\text{成功利用的漏洞数} / \text{尝试利用的漏洞数}) * 100\%$	“成功利用”以达成预设权限或操作为标准；记录尝试时间戳、漏洞 ID、结果
目标达成率	预设攻击目标（0/1 记录）完成程度	$(\text{完成的攻击目标数} / \text{预设目标总数}) * 100\%$	目标示例：获取 DBA 权限、上传恶意程序、持久化维持等
攻击隐蔽性	攻防对抗中被发现程度的反向度量	$1 - (\text{被发现的攻击步骤数} / \text{总攻击步骤数}) * 100\%$	被发现情况来源于 IDS/防火墙/审计日志，与攻击方总操作步骤对齐
加权综合得分	基于 AHP 确定权重的综合评分	$\text{覆盖率} \times 0.3 + \text{成功率} \times 0.3 + \text{目标达成} \times 0.3 + \text{隐蔽性} \times 0.1$	AHP 专家评审（10 人），一致性检验 $CR < 0.1$ ；等级：≥80 优秀，60-79 良好，<60 待改进

算法与公式的设计上，攻击路径覆盖率的计算方式为：

$$\left(\frac{\text{实际利用路径数}}{\text{理论可能路径数}} \right) * 100\%$$

其中，理论可能路径数通过图论算法（Dijkstra 最短路径扩展法）计算系统拓扑中存在漏洞关联的所有可达路径。

漏洞利用成功率的计算公式为：

$$\left(\frac{\text{成功利用的漏洞数}}{\text{尝试利用的漏洞数}} \right) * 100\%$$

这里的成功利用定义为触发漏洞并获取预期权限或执行预设操作。

目标达成率的计算方式为：

$$\left(\frac{\text{完成的攻击目标数}}{\text{预设目标总数}} \right) * 100\%$$

采用 0-1 二值化记录每个目标的完成状态。

攻击隐蔽性的计算公式为：

$$1 - \left(\frac{\text{被防御方发现的攻击步骤数}}{\text{总攻击步骤数}} \right) \times 100\%$$

$$1 - \left(\frac{\text{被防御方发现的攻击步骤数}}{\text{总攻击步骤数}} \right) * 100\%$$

得分越高表示隐蔽性越强。

加权得分通过路径覆盖率 $\times 0.3$ + 漏洞利用成功率 $\times 0.3$ + 目标达成率 $\times 0.3$ + 攻击隐蔽性 $\times 0.1$ 计算得出，权重通过层次分析法（AHP）确定，具体为邀请 10 位攻防领域专家对指标重要性进行两两比对，构建判断矩阵并通过一致性检验（CR<0.1）。

等级划分上，加权得分 ≥ 80 分为优秀，60-79 分为良好， < 60 分为待改进。

与传统方法相比，传统人工评估仅通过攻击结果（如“是否攻破目标”）进行定性判断，忽略路径探索与隐蔽性等过程指标。本模型通过量化路径覆盖率（如某演练中理论路径 20 条，实际利用 17 条，覆盖率 85%）与隐蔽性得分（如总步骤 50，被发现 8 步，隐蔽性 84%），实现从“结果判定”到“过程 + 结果”的全维度评估。

防御维度的评估基于 NIST 网络安全框架的识别 - 保护 - 检测 - 响应 - 恢复（IDPRR）模型，重点考察对威胁的感知速度、阻断能力、漏洞修复时效及持续改进水平。

数据收集时，威胁识别数据从 SIEM 系统采集攻击事件的告警记录，与攻击方实际发起的攻击事件（经演练裁判系统确认）进行比对；响应时间数据通过防御方操作审计日志，记录从告警生成到首次处置操作的时间间隔，计算所有有效告警的平均响应时间；威胁阻断数据从防火墙、IPS 等设备提取阻断记录，关

联已识别的攻击事件，统计成功阻断数；漏洞修复数据则从漏洞管理平台获取检测到的漏洞清单及修复状态（未修复、修复中、已修复），记录修复完成时间。

表 2.5 防御维度评估指标体系表（基于 NIST IDPRR 模型）

NIST 框架	指标名称	计算公式	权重	数据源与技术要点
识别 (Identify)	威胁识别率	(成功识别的攻击数/实际发生的攻击数)*100%	0.2	SIEM 系统告警记录，与攻击方实际事件（裁判系统确认）比对；10 分钟内生成有效告警认定为成功识别
保护 (Protect)	威胁阻断率	(成功阻断的攻击数/识别到的攻击数)*100%	0.3	防火墙、IPS 阻断记录，关联已识别攻击事件；成功阻断指攻击行为被终止且未造成预期影响
检测 (Detect)	响应及时性	平均响应时间（秒）→归一化处理	0.2	从告警生成到首次处置操作的时间间隔，通过 InfluxDB 时间戳计算中位数（消除极端值）
响应 (Respond)	漏洞修复率	(修复的漏洞数/检测到的漏洞数)*100%	0.3	漏洞管理平台数据，修复有效性需通过二次验证（漏洞扫描确认）
恢复 (Recover)	综合评分	识别率×0.2 + 阻断率×0.3 + 修复率×0.3 + （1-响应时间归一化值）×0.2		
归一化公式		归一化值 = （实际响应时间-最小响应时间）/（最大响应时间-最小响应时间）		

算法与公式方面，威胁识别率的计算公式为：

$$\left(\frac{\text{成功识别的攻击数}}{\text{实际发生的攻击数}}\right) * 100\%$$

成功识别指防御系统在攻击结束后 10 分钟内生成有效告警。

响应及时性以平均响应时间（秒）表示，通过时序数据库（InfluxDB）存储的时间戳计算中位数（消除极端值影响）。

威胁阻断率的计算方式为：

$$\left(\frac{\text{成功阻断的攻击数}}{\text{识别到的攻击数}}\right) * 100\%$$

成功阻断指攻击行为被终止且未造成预期影响。

漏洞修复率的计算公式为：

$$\left(\frac{\text{修复的漏洞数}}{\text{检测到的漏洞数}}\right) * 100\%$$

修复有效性需通过二次验证（如漏洞扫描确认）。

加权得分通过威胁识别率 ×0.2 + 威胁阻断率 ×0.3 + 漏洞修复率 ×0.3 +（1 - 响应及时性归一化值）×0.2 计算，其中响应及时性归一化公式为：

$$\text{归一化值} = (\text{实际响应时间} - \text{最小响应时间}) / (\text{最大响应时间} - \text{最小响应时间})$$

权重通过 AHP 法确定（专家组一致性检验 CR=0.08）。

等级判定上，得分≥80 分说明防御体系有效，60-79 分为基本达标，<60 分需优化策略。

与传统方法对比，传统评估侧重“是否拦截攻击”的单一结果，本模型通过识别率（如实际攻击 30 次，识别 27 次，识别率 90%）与修复率（如检测漏洞 15 个，修复 12 个，修复率 80%）的量化，反映防御体系的全链条效能，较传统方法提升评估颗粒度 3-5 倍。

人员表现评估基于能力成熟度模型（CMMI），核心在于技能熟练度、策略创新性、应急处置效率及团队协作默契度。

表 2.6 人员表现评估

评估对象	评估指标	计算公式	权重	数据来源
红队	策略创新性	(使用新型攻击手段的次数/总攻击手段	0.4	新型手段指近 3 年首次出现或未纳入预设库的技术

评估对象	评估指标	计算公式	权重	数据来源
		次数)*100%		(如 0day 利用、供应链攻击)
	问题解决能力	1/(平均调整时间/标准调整时间)	0.3	标准调整时间基于历史数据设定 (如 Web 攻击场景为 5 分钟)
	目标聚焦度	1-(偏离核心目标的操作时长/总操作时长)*100%	0.3	由裁判系统标记的非核心目标操作
蓝队	漏洞发现能力	(手动发现的未知漏洞数*2+手动发现的已知漏洞数)/(自动扫描发现的漏洞数+1)	0.3	未知漏洞权重翻倍以突出价值; 区分已知/未知漏洞
	应急响应速度	平均处置时间 (分钟) → 归一化处理	0.3	应急响应工单记录, 从告警到处置的全流程时间
	溯源准确性	((攻击源定位正确数+攻击链还原正确环节数))/((总定位次数+总还原环节数))*100%	0.4	溯源分析报告与攻击方实际路径的比对结果
团队协作	沟通响应率	(2 小时内回复的消息数/总消息数)*100%	0.5	团队沟通记录 (会议纪要、即时通讯日志)

评估对象	评估指标	计算公式	权重	数据来源
	任务协同完成率	(按时协同完成的任务数/总协同任务数)*100%	0.5	基于预设分工表的比对,任务分工完成度统计

数据收集涵盖红队、蓝队及协作相关数据。红队数据包括攻击策略文档（记录攻击手段类型）、操作日志（记录遇到防御措施时的调整次数与耗时）、目标偏离记录（由裁判系统标记的非核心目标操作）；蓝队数据有手动提交的漏洞报告（区分已知 / 未知漏洞）、应急响应工单（记录告警到处置的全流程时间）、溯源分析报告（与攻击方实际路径的比对结果）；协作数据涵盖团队沟通记录（如会议纪要、即时通讯日志）、任务分工完成度（基于预设分工表的比对）。

算法与公式的设计中，红队的策略创新性计算方式为：

$$\left(\frac{\text{使用新开攻击手段的次数}}{\text{总攻击手段次数}}\right) * 100\%$$

新型手段指近 3 年首次出现或未纳入演练预设库的技术（如 0day 利用、供应链攻击）。

问题解决能力的计算公式为：

$$1/(\text{平均调整时间}/\text{标准调整时间})$$

标准调整时间基于历史数据设定（如 Web 攻击场景为 5 分钟）。

目标聚焦度的计算方式为：

$$1 - (\text{偏离核心目标的操作时长}/\text{总操作时长}) * 100\%$$

红队得分通过创新性 ×0.4 + 解决能力 ×0.3 + 聚焦度 ×0.3 计算得出。

蓝队的漏洞发现能力计算方式为：

$$(\text{手动发现的未知漏洞数} * 2 + \text{手动发现的已知漏洞数})/(\text{自动扫描发现的漏洞数} + 1)$$

未知漏洞权重翻倍以突出价值。

应急响应速度以平均处置时间（分钟）表示，计算方式同防御维度的响应及时性。

溯源准确性的计算公式为：

$$\frac{(\text{攻击源定位正确数} + \text{攻击链还原正确环节数})}{(\text{总定位次数} + \text{总还原环节数})} * 100\%$$

蓝队得分通过发现能力 $\times 0.3$ + (1 - 响应速度归一化值) $\times 0.3$ + 溯源准确性 $\times 0.4$ 计算。

团队协作评分基于社会网络分析法，计算信息传递效率（沟通响应率 $\times 0.5$ + 任务协同完成率 $\times 0.5$ ），其中沟通响应率为：

$$(\text{2小时内回复的消息数} / \text{总消息数}) * 100\%$$

任务协同完成率为：

$$(\text{按时协同完成的任务数} / \text{总协同任务数}) * 100\%$$

评估输出会生成个人技能画像（如 “Web 攻击得分 92 分，内网渗透得分 65 分→擅长 Web 攻击但内网渗透薄弱”），团队协作评分（如 85 分→协作良好，存在信息传递延迟问题），并结合短板指标提供提升建议（如 “溯源准确性 60 分→建议加强 APT 攻击溯源训练”）。

与传统方法对比，传统人工评分依赖裁判主观印象（如 “红队表现积极”），本模型通过创新手段占比（如总手段 12 种，新型 5 种，占比 41.7%）与溯源准确性等硬指标，使评估误差率从传统的 $\pm 20\%$ 降至 $\pm 5\%$ 以内。

自动化评估流程包含数据采集、指标计算、报告生成和历史对比多个环节。数据采集层通过分布式探针实时记录攻击步骤（每秒 300 条日志）、防御操作（如防火墙规则变更、终端杀软操作）、漏洞状态（新增 / 修复 / 复现）等数据，经清洗后存储于时序数据库（InfluxDB），单场演练数据量可达 50-100GB。

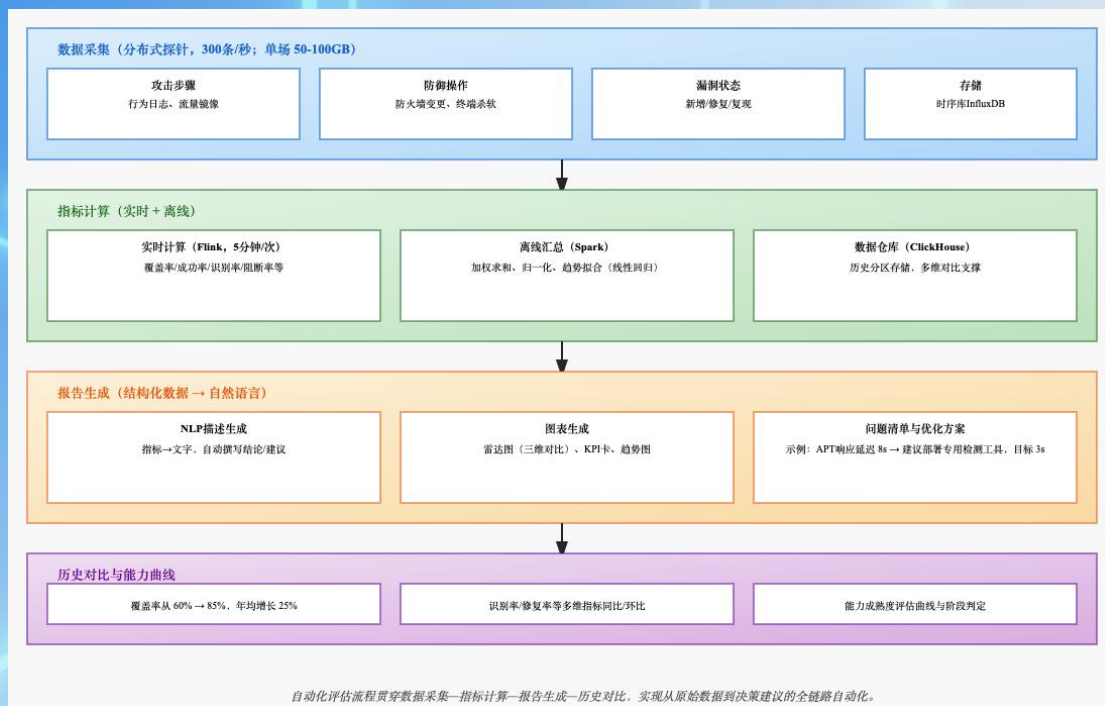


图 2.25 自动化评估流程示意（采集→计算→报告→对比）

指标计算层中, 评估引擎基于流处理框架 (Flink) 定时计算实时指标 (每 5 分钟一次), 演练结束后通过离线计算 (Spark) 汇总生成最终得分, 核心算法包括加权求和、归一化处理与趋势拟合 (如采用线性回归计算能力提升斜率)。

报告生成层结合自然语言处理 (NLP) 技术, 将结构化指标数据转化为自然语言描述, 自动生成包含雷达图 (三维指标对比)、问题清单 (如 “防御方对 APT 攻击响应延迟, 平均响应时间 8 秒”)、优化方案 (如 “部署 APT 专用检测工具, 预期将响应时间缩短至 3 秒内”) 的评估报告。

历史对比层通过数据仓库 (ClickHouse) 存储历史演练数据, 支持多维度对比分析, 自动生成团队能力提升曲线 (如 “攻击路径覆盖率从 2023 年 Q1 的 60% 提升至 2024 年 Q1 的 85%, 年均增长率 25%”) [15], 为能力成熟度评估提供数据支撑。

第三章 系统展示

3.1 场景管理模块

场景管理模块是用户构建演练环境的入口，支持从模板选择到自定义配置的全流程操作。



图 3.1 场景管理页面

核心功能界面中，场景模板库左侧展示 8 个行业模板（金融、能源、医疗、电商、政务、教育、工控、物联网），每个模板配有场景示意图（如金融模板显示支付网关、交易系统、数据库的拓扑关系）与适用范围说明（如“适合银行安全团队演练”）。参数配置区右侧提供可配置参数，包括复杂度（简单：5-10 个节点，3-5 个低危漏洞；中等：10-30 个节点，5-10 个中高危漏洞；复杂：30+ 节点，含 0day 漏洞与混合攻击链）、业务类型（如金融场景可选择“支付系统”“信贷系统”“核心账务系统”）、特殊需求（是否包含工控设备、是否开启社会工程学攻击通道、是否模拟新型威胁（如 AI 生成钓鱼邮件））。拓扑编辑器支持拖拽式操作，用户可添加 / 删除设备（服务器、终端、网络设备）、

调整连接关系、修改设备参数（如操作系统版本、开放端口），编辑完成后自动生成拓扑图与配置清单。

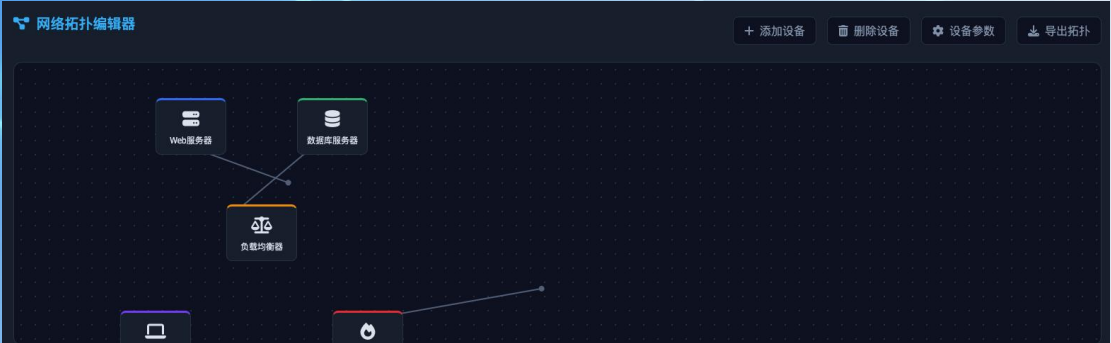


图 3.2 网络拓扑编辑器

场景生成流程为：用户选择“金融 - 支付系统”模板，复杂度设为“中等”；平台调用 RAG 引擎检索“支付系统拓扑”“常见支付漏洞”等知识；自动生成包含 1 台负载均衡、2 台 Web 服务器（部署支付页面）、1 台数据库服务器（存储交易数据）、3 台用户终端的场景；植入漏洞（Web 服务器存在 SQL 注入与文件上传漏洞，数据库存在弱口令，终端存在钓鱼邮件易感配置）；用户通过拓扑编辑器手动添加 1 台 WAF 设备，场景生成完成（耗时 45 秒）。



图 3.3 场景生成功能

场景动态调整功能支持在演练中触发“威胁升级”，例如当攻击方连续 3 次成功利用漏洞时，系统自动新增 2 个中危漏洞（如命令注入）；提供“场景快照”功能，可保存当前场景状态（漏洞分布、网络配置），支持随时回溯或复用；支持导入用户自定义场景（通过 JSON 格式配置文件），满足个性化演练需求。

3.2 Agent 管理模块

Agent 管理模块用于配置攻击与防御 AI 的行为模式，实现智能体的精细化控制。



图 3.4 Agent 管理页面

Agent 配置界面中，攻击 Agent 配置包括数量（1-5 个，支持协同攻击）、攻击偏好（Web 攻击、内网渗透、社会工程学、APT 攻击，可多选，设置权重）、策略激进度（保守：仅利用高危且成功率 $>80\%$ 的漏洞；均衡：兼顾成功率与多样性；激进：尝试 0day 漏洞与复杂攻击链）、目标资产（可指定重点攻击的设备，如数据库服务器、核心业务系统）。防御 Agent 配置包括响应模式（自动响应：无需人工干预；半自动响应：关键操作需确认；监控模式：仅检测不阻断）、防御策略（基础防护：默认规则；深度防护：启用机器学习检测；蜜罐诱捕：部署虚假漏洞）、资源限制（CPU / 内存占用上限，避免影响靶场性能）。

Agent 状态监控实时展示各 Agent 的运行状态（就绪、运行中、暂停、故障）、资源占用率、当前操作（如“攻击 Agent 1 正在尝试 SQL 注入”）；提供 Agent 日志查询功能，记录攻击 / 防御步骤、成功 / 失败原因（如“防御失败：WAF 规则未覆盖该攻击特征”）；支持手动暂停 / 重启 Agent，或强制修改其策略（如临时将攻击 Agent 的激进度从“激进”改为“保守”）。

多 Agent 协同示例：配置 3 个攻击 Agent，Agent A（偏好 Web 攻击，激进度均衡）、Agent B（偏好内网渗透，激进度保守）、Agent C（偏好社会工程学，激进度激进）；演练中，Agent C 发送钓鱼邮件获取员工账号，Agent A 利用 Web 漏洞获取服务器权限，Agent B 通过内网渗透横向移动至数据库，三者共享攻击情报（如账号密码、网络拓扑），协同完成攻击链。

3.3 演练控制模块

演练控制模块是攻防推演的操作中心，支持流程管理与实时干预。

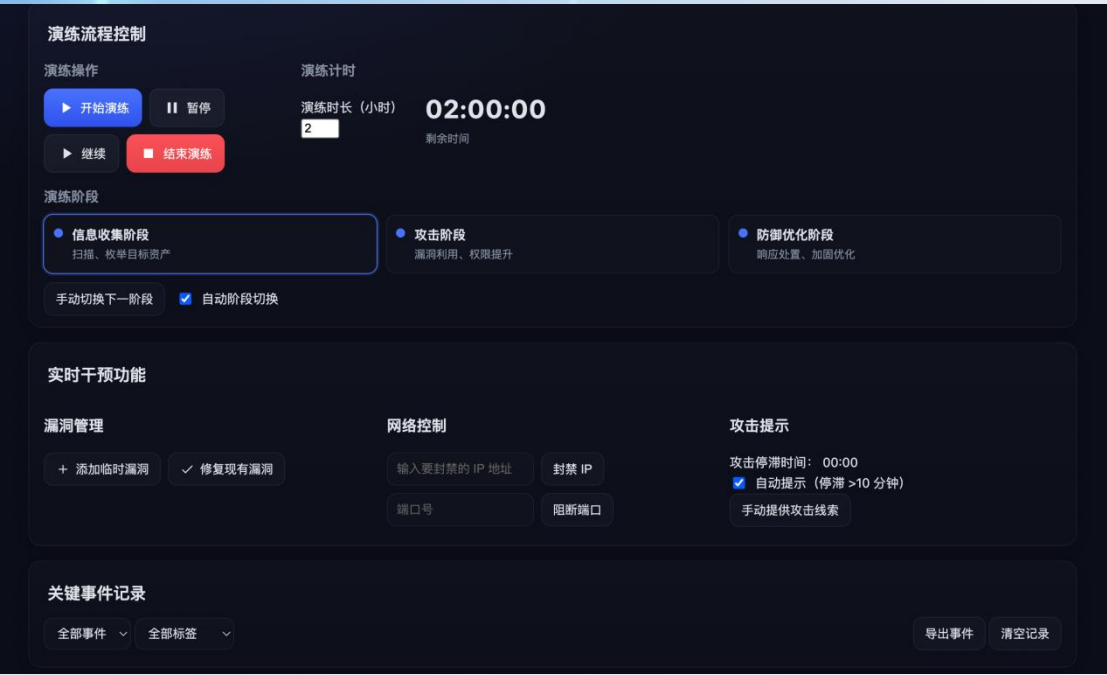


图 3.5 演练控制模块功能示意

演练流程控制提供“开始 / 暂停 / 结束”按钮，支持演练断点续跑；显示演练倒计时（可设置 1-24 小时），剩余 30 分钟时自动提醒；支持设置演练阶段（如“信息收集阶段→攻击阶段→防御优化阶段”），每个阶段自动调整 Agent 策略（如信息收集阶段攻击 Agent 仅执行扫描操作）。

实时干预功能允许人工添加临时漏洞（如在 Web 服务器上新增文件包含漏洞）或修复现有漏洞，测试 Agent 的应变能力；支持手动阻断特定攻击路径（如封禁某 IP 地址），模拟人工应急响应；提供“攻击提示”功能（供教学场景

使用），当攻击 Agent 长时间（>10 分钟）未找到有效漏洞时，显示线索（如“目标 Web 系统使用了存在漏洞的 Struts2 框架”）。

关键事件记录自动记录演练中的关键事件（如“攻击成功：获取数据库管理员权限”“防御成功：阻断 APT 攻击的 C2 通信”），按时间线排序；支持对事件添加标签（如“高风险”“需重点分析”），便于后续复盘；事件详情包含相关截图（如攻击 payload、防御操作日志）与影响范围评估。

3.4 网络拓扑与 AI 分析模块

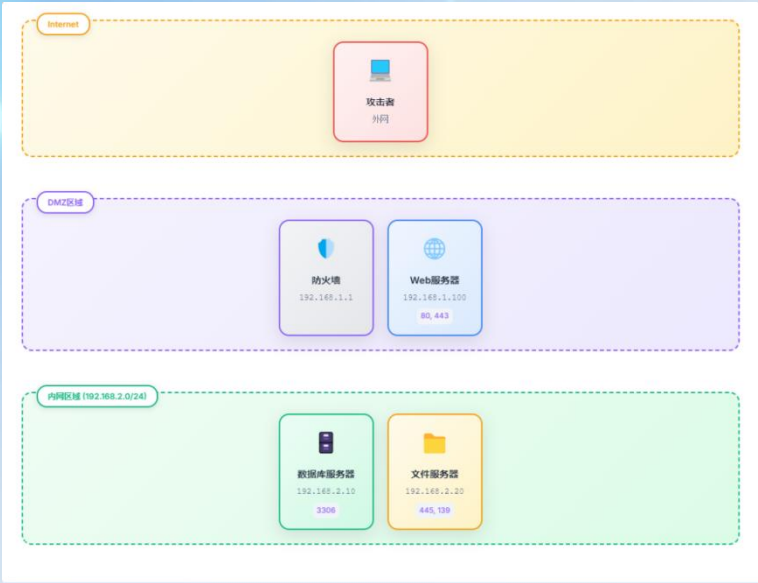


图 3.6 网络拓扑视图

AI 辅助测试流程包括输入目标信息，如网络拓扑描述（目标网络包含一个 Web 服务器（192.168.1.100），位于 DMZ 区域，通过防火墙与内网（192.168.2.0/24）隔离。内网包含一台数据库服务器（192.168.2.10）和一台文件服务器（192.168.2.20））、漏洞类型、CVE 编号（如 CVE-2021-45046，SQL 注入漏洞）、系统配置信息（Web 服务器：Apache 2.4.49+PHP 7.4.3+MySQL 5.7.33；操作系统：Ubuntu 20.04 LTS；应用程序：自定义 CMS 系统 v2.5；安全措施：开启防火墙，未安装 WAF，默认数据库配置）、攻击目标（获取数据库中的用户表信息，包括管理员账号和密码哈希，并尝试提升权限获取服务器 shell 访问权限）；AI 分析处理后生成攻击路径分析（信息收集与端口扫描、Web 应用漏洞扫描、SQL 注入漏洞利用、数据库信息获取、权限提升尝试）与风险评估（高风险：SQL 注入可导致数据泄露；中风险：弱密码可能被暴力破解；低风险：

信息泄露风险)；自动化测试与策略调整中，AI 会基于当前攻击路径给出改进建议，如使用编码绕过 WAF（尝试 URL 编码、十六进制编码等方式）、分块传输绕过（使用 HTTP 分块传输编码来绕过 WAF 规则）等。

白盒测试 - AI辅助分析

返回模式选择

1

2

3

4

5

输入目标信息

AI分析处理

自动化测试

策略调整

生成报告

步骤1: 输入目标系统信息

网络拓扑描述

目标网络包含一个Web服务器(192.168.1.100)，位于DMZ区域，通过防火墙与内网(192.168.2.0/24)隔离。内网包含一台数据库服务器(192.168.2.10)和一台文件服务器(192.168.2.20)。

漏洞类型

CVE编号

SQL注入漏洞

CVE-2021-45046

系统配置信息

Web服务器: Apache 2.4.49 + PHP 7.4.3 + MySQL 5.7.33;操作系统: Ubuntu 20.04 LTS;应用程序: 自定义CMS系统 v2.5;安全措施: 开启防火墙，未安装WAF，默认数据库配置

攻击目标

获取数据库中的用户表信息，包括管理员账号和密码哈希，并尝试提升权限获取服务器shell访问权限。

图 3.7 输入目标系统信息

步骤2: AI分析处理

AI分析完成

攻击路径分析

1. 信息收集与端口扫描

2. Web应用漏洞扫描

3. SQL注入漏洞利用

4. 数据库信息获取

5. 权限提升尝试

风险评估

高风险: SQL注入可导致数据泄露

中风险: 弱密码可能被暴力破解

低风险: 信息泄露风险

图 3.8 AI 处理和分析



图 3.9 自动化测试与策略调整

评估报告模块自动生成演练总结与改进建议，测试信息包括目标网络情况、测试目标、漏洞类型及编号（如 sql-injection, CVE-2021-45046）、测试类型（白盒测试）、测试时间（如 2025/8/12 17:43:20）、测试持续时间（如 12 分 17 秒）；执行摘要包含总测试步骤、成功步骤、失败步骤、成功率、发现漏洞数量、风险评分等；发现的漏洞详情包括描述（如登录页面存在 SQL 注入漏洞，攻击者可以绕过身份验证）、位置（如 /login.php）、证据（如 username=' OR 1=1--password=any）、CVSS 评分（如 8.1）；修复建议包括输入验证（建议使用参数化查询或预编译语句防止 SQL 注入，实施方案为将所有 SQL 查询改为使用 PreparedStatement）、WAF 配置（建议配置 Web 应用防火墙规则，实施方案为部署 ModSecurity 规则集，阻止常见 SQL 注入模式）。



图 3.10 评估报告示意图



图 3.11 发现漏洞示意图



图 3.12 修复建议示意图

扫描测试模块，扫描测试模块的扫描测试中心支持新建扫描任务，配置扫描目标（如目标 URL：http://testphp.vulnweb.com）、扫描类型（如综合扫描）、扫描深度（如中等扫描（深度 2））、扫描引擎（如 Nikto Web 服务器漏洞扫描、Dirb 目录和文件暴力破解、Nmap 网络发现和端口扫描、SQLMap SQL 注入检测和利用），预览配置后可开始扫描。扫描结果分析展示扫描目标、扫描时长、发现漏洞数量、发现目录数量，以及各扫描引擎状态（如 Nmap v7.94 已完成，100%；Nikto v2.5.0 已完成，100%；Dirb v2.22 运行中，75%），并列出发发现的 URL 列表（如 /admin/，状态 200，为管理员后台入口；/login.php，状态 200，为用户登录页面；/config/，状态 403，为配置文件目录（禁止访问））。

扫描测试中心

配置扫描任务，查看扫描结果，进行渗透测试演示

新建扫描任务

扫描配置

扫描结果

渗透演示

扫描目标配置

指定扫描目标并创建扫描任务

目标URL

http://testphp.vulnweb.com

扫描类型

扫描深度

综合扫描

中等扫描 (深度2)

扫描引擎

☒ Nmap 网络发现和端口扫描

☒ Nikto Web服务器漏洞扫描

☒ Dirb 目录和文件暴力破解

☒ SQLMap SQL注入检测和利用

预览配置

开始扫描

图 3.13 扫描配置示意图

扫描结果分析

查看漏洞扫描策略、引擎状态和详细结果

扫描目标

http://testphp.vulnweb.com

扫描时长

00:05:32

发现漏洞

7

发现目录

15

扫描引擎状态

Nmap v7.94

已完成 100%

Nikto v2.5.0

已完成 100%

Dirb v2.22

运行中 75%

发现的URL列表

/admin/ 200

管理员后台入口

/login.php 200

用户登录页面

/config/ 403

配置文件目录 (禁止访问)

图 3.14 扫描结果分析

渗透测试功能，渗透测试功能包括目标识别（扫描目标系统，识别开放端口和服务）、漏洞发现（分析发现的服务，寻找潜在安全漏洞）、漏洞利用（利用发现的漏洞获取系统访问权限）、权限提升（提升权限并获取目标系统 shell）、

安全设备绕过（检测并绕过蜜罐等安全防护设备），渗透测试终端可执行相关命令（如 `nmap -sV 192.168.1.100` 等）。

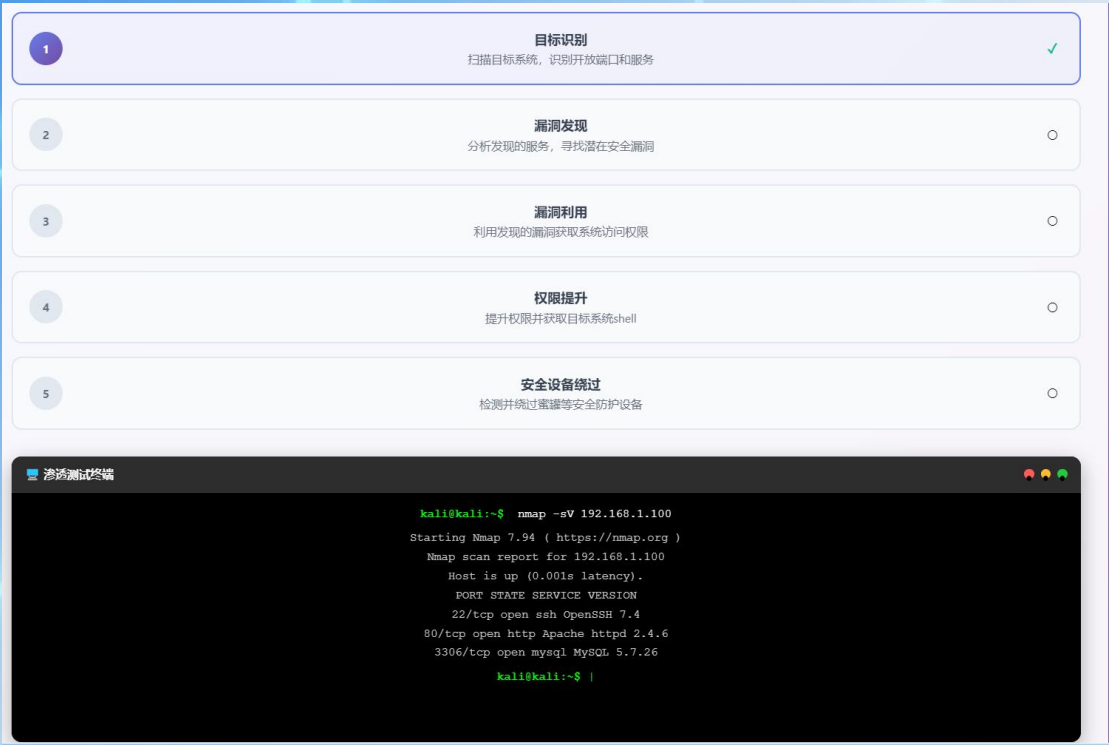


图 3.15 渗透测试功能示意图

3.5 竞赛中心模块

竞赛中心模块收录了一些比较常见的网络安全竞赛，以供使用者快速访问。目前包含的竞赛有“巅峰极客”网络安全技能挑战赛（类型：团队赛，国内知名的网络安全竞赛，注重实战和创新）、全国大学生信息安全竞赛（类型：解题赛，面向全国大学生的顶级信息安全赛事，考验团队综合实战）、CTF 线上夺旗赛（类型：个人赛，经典的 CTF 解题模式，包含 Web、Pwn、Reverse、Crypto 等方向）、企业安全众测（类型：攻防赛，模拟真实世界漏洞挖掘，为企业提供安全保障）、网络空间安全创新大赛（类型：攻防赛，聚焦网络空间安全前沿技术，推动产学研深度融合）、工业互联网安全竞赛（类型：团队赛，专注工业控制系统安全，保障关键基础设施安全）等，展示了竞赛总数、平均参与人数、获得荣誉、最高排名等信息，支持搜索竞赛名称、类型及创建竞赛。

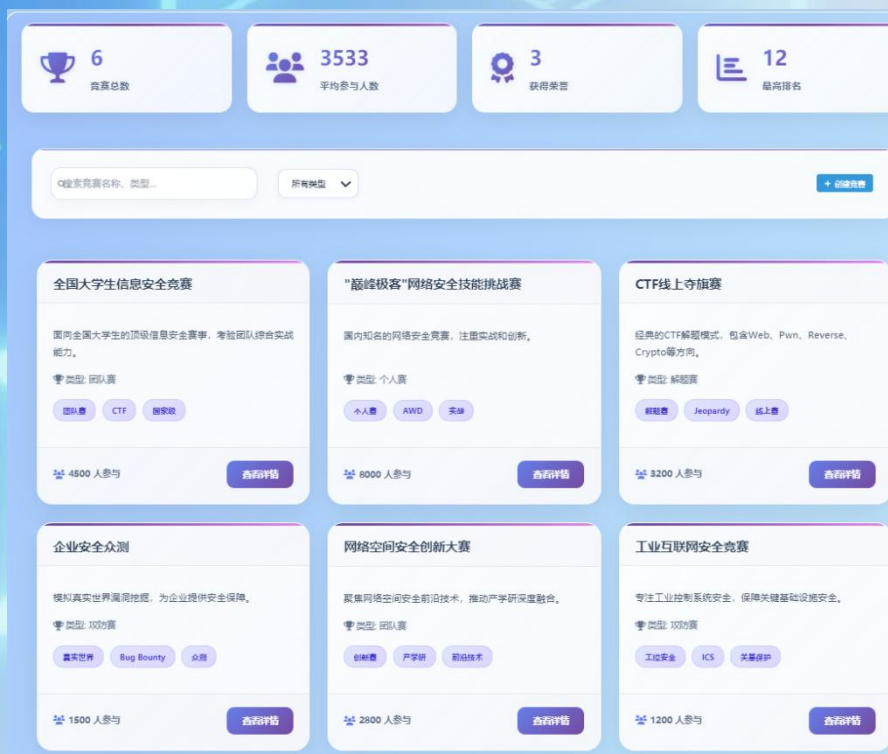


图 3.16 竞赛中心模块示意图

3.6 实验训练模块

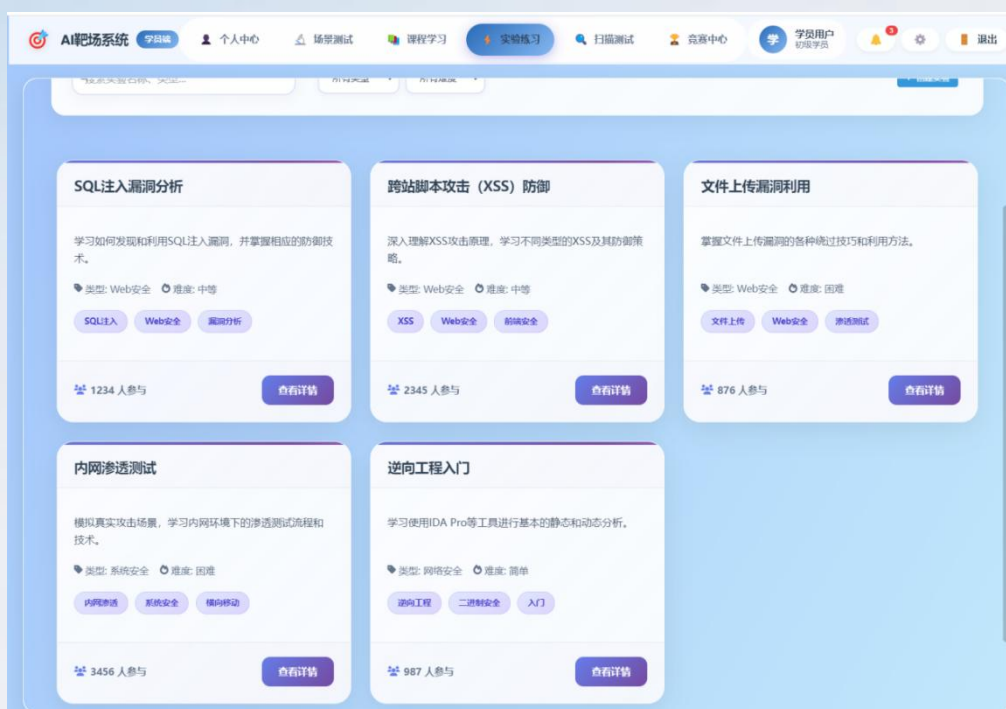


图 3.17 实验训练模块示意图

3.7 个人中心评估模块

个人中心评估模块可以直观反映使用者的个人学习进度以及情况。个人能力雷达图全面展示在各个技能领域的能力水平，包括综合评分（如 78.5，较本月 +5.2%）、完成率（如 85%）、漏洞挖掘（如 +12% 本月）、团队协作、渗透测试、学习效率（如 92%，+8% 本月）、安全工具使用、社会工程学、排名（如 #15，较本月 +3）、应急响应、后渗透技术、威胁狩猎等。能力分解展示当前能力水平与目标水平（如网络安全 85、渗透测试 72、恶意软件分析 68、数字取证 75）。学习进度趋势、技能分布、月度活跃度、成绩分析等以图表形式呈现。

能力分析基于学习数据和表现进行个性化分析，包括优势技能（如漏洞挖掘技术强化 92%、渗透测试方法论 88%、社会工程学实践 85%）、待提升技能（如后渗透技术深化 45%、威胁狩猎技能训练 52%、应急响应流程优化 48%）。个性化学习建议基于能力评估结果，推荐针对性的学习内容和提升路径，薄弱技能提升如安全运维（60 分）可学习 Linux 系统安全加固（8 小时）、零日漏洞挖掘（20 小时）、应急响应实战（12 小时），优势技能进阶如网络安全（85 分）可学习高级网络攻防技术（16 小时）、日志分析与监控（6 小时）、APT 攻击分析（14 小时），并推荐相应考试（如 GCIA、OSCP）。



图 3.18 AI 靶场系统个人中心示意图



图 3.19 个人能力分析示意图

第四章 作品测试与分析

4.1 测试方法设计

为全面验证平台的功能有效性与性能优势，采用“案例测试 + 对比测试 + 压力测试”相结合的方法。

案例测试选取 3 个典型行业场景：金融支付系统（高复杂度）、能源监控网络（工控场景）、电商平台（中等复杂度）；每个场景执行 3 次重复测试，验证结果一致性；重点关注场景生成耗时、攻击路径数量、防御响应时间、评估报告准确性；评估维度包括功能覆盖度（是否实现四大核心功能）、实战贴合度（专家评分，1-10 分）、稳定性（无崩溃 / 数据丢失）。

对比测试选取传统静态靶场（某高校教学靶场）与同类智能靶场（某企业研发的 AI 辅助靶场）进行对比；统一使用“金融支付系统”场景，配置相同初始漏洞；通过对比场景动态性（可调整参数数量）、攻击多样性（攻击路径数 / 漏洞利用率）、评估效率（报告生成时间 / 指标数量）、资源消耗（CPU / 内存占用峰值）。

压力测试方案中，场景规模涵盖 10/50/100/200 节点网络拓扑；攻击强度为同时启动 1/3/5/10 个攻击 Agent，模拟多线程攻击；测试指标包括系统响应时间（场景调整 / Agent 决策）、吞吐量（每秒处理攻击事件数）、错误率（攻击 / 防御操作失败比例）；终止条件为系统响应时间 > 10 秒或错误率 > 10%。

4.2 测试环境配置

测试环境采用“物理机 + 虚拟化”混合架构，通过分层部署实现硬件资源、软件组件与网络安全的协同联动，为攻防演练提供高仿真、高可控的运行载体。

硬件环境构建了“核心支撑 - 靶场模拟 - 网络互联 - 人机交互”的完整硬件链条。中央服务器采用 2 台阿里云 ECS 实例组成主从架构，单台配置为 Intel Xeon Platinum 8269CY CPU（8 核，基础频率 3.0GHz，睿频 3.5GHz）、

32GB DDR4 ECC 内存 (2666MHz)、1TB NVMe SSD 存储 (随机读写 IOPS 达 18 万)，主节点部署平台核心引擎 (场景生成引擎、攻击防御 Agent 调度系统) 与业务数据库，从节点作为热备节点，通过实时数据同步 ($RPO \leq 5$ 秒) 确保服务连续性，当主节点故障时可在 30 秒内自动切换。靶机集群基于 Docker 容器技术虚拟化部署 100 台虚拟靶机，单台配置为 2 核 AMD EPYC 7K62 CPU、4GB 内存、50GB SSD 存储，通过 Kubernetes 进行编排管理，可模拟多样化的 IT 资产：其中 40 台模拟 Web 服务器 (部署 Nginx、Apache 等服务)、25 台模拟数据库服务器 (运行 MySQL、PostgreSQL 等)、20 台模拟终端设备 (安装 Windows 10、macOS 等桌面系统)、15 台模拟网络设备 (仿真路由器、交换机的配置界面与功能逻辑)。网络设备层选用 1 台华为 S5720-32X-EI-AC 千兆智能交换机，支持 4096 个 VLAN 划分与精细化 ACL 规则配置，可模拟不同网段的隔离与通信控制；搭配 1 台深信服 NGAF-1000 防火墙，具备应用识别 (支持 6000+ 应用特征)、入侵防御 (内置 3000+ 攻击特征) 与 VPN 功能，用于严格隔离测试环境与外部办公网络，仅开放经审批的管理端口。客户端设备为测试人员配备 10 台 Windows 10 工作站，硬件配置为 Intel i7-10700K CPU (8 核 16 线程)、16GB DDR4 内存、512GB NVMe SSD，通过 1920×1080 分辨率的显示器接入平台 Web 界面，支持演练过程中的实时操作与数据观察。

软件环境遵循 “操作系统 - 数据存储 - 容器编排 - 开发框架 - 工具链” 的层级架构，确保各组件的兼容性与功能完整性。操作系统层面，中央服务器安装 Ubuntu 20.04 LTS (内核版本 5.4.0-144)，通过关闭不必要服务 (如 cups、avahi-daemon) 优化性能；靶机集群按需部署多样化系统，包括 Windows Server 2019 (搭载 IIS 10.0)、Ubuntu 20.04 (运行 Nginx 1.18)、CentOS 7 (部署 Tomcat 9.0)，并预装对应系统的典型应用与漏洞环境。数据库层采用多类型数据库协同方案：MySQL 8.0 (InnoDB 引擎) 用于存储结构化演练数据 (如用户信息、评分结果)，配置主从复制确保数据安全；MongoDB 5.0 用于存储非结构化日志 (如攻击操作记录、防御行为日志)，支持高效的文档查询；Milvus 2.0 向量数据库作为 RAG 引擎的核心组件，负责存储知识图谱的向量表示，支持毫秒级相似度检索。容器化工具链包括 Docker 20.10.12 (容器运行时)、Docker Compose 2.2.3 (单机容器编排)、Kubernetes 1.24.2 (集群容器管理)，通过容

器镜像标准化部署流程，确保靶机环境的一致性与可重复性，单台物理机可同时运行 30 个容器且资源占用稳定。开发框架采用前后端分离架构：后端基于 Spring Boot 2.7.0 构建 RESTful API，集成 Spring Security 实现权限控制；前端使用 Vue 3.0 框架搭配 Element Plus 组件库，实现响应式界面设计；AI 模型基于 LLaMA 2-70B 进行领域微调，部署在 GPU 服务器（配备 2 张 NVIDIA A100 显卡），通过 TensorRT 优化推理速度，单次模型调用延迟≤500ms。依赖工具链涵盖安全测试全流程：Nessus 10.1.1 用于系统漏洞扫描，支持定期自动扫描与报告生成；Wireshark 3.6.2 用于流量捕获与分析，可解码 500+ 协议；ELK Stack（Elasticsearch 7.17.0、Logstash 7.17.0、Kibana 7.17.0）负责日志的收集、清洗与可视化，日志处理能力达 1000 条 / 秒。

网络与安全配置构建了“隔离 - 可控 - 可视”的安全边界。测试环境部署在独立网段 192.168.100.0/24，通过防火墙与企业办公网（192.168.1.0/24）、互联网实现物理隔离，仅允许测试客户端通过 VPN 接入。带宽配置采用分层设计：中央服务器与靶机集群间通过万兆光纤连接，内网带宽达 10Gbps，确保大规模并发攻击时的流量传输流畅；客户端访问平台的带宽限制为 1Gbps，避免外部访问占用过多内网资源。安全控制策略实施“默认拒绝 + 最小开放”原则：防火墙默认阻断所有入站流量，仅开放平台必需端口（80/443 用于 Web 访问、3306 用于 MySQL 连接、22 用于 SSH 管理），并对端口访问源进行 IP 限制（仅允许测试客户端网段）。流量监控体系通过部署 Suricata 6.0.9 IDS 实现实时防护，加载 Emerging Threats 规则集（含 15000+ 威胁特征），对异常流量（如 SQL 注入尝试、端口扫描）进行告警与阻断，同时将流量日志实时同步至 ELK Stack，支持攻击行为的事后溯源与分析，确保所有攻击操作局限于测试环境内部，避免对外部网络造成影响。

4.3 金融支付系统场景模拟测试

4.3.1 测试场景设计

测试场景以真实银行信用卡支付系统为原型，构建包含“边界防护 - 应用服务 - 数据存储 - 终端操作”的四层架构，模拟金融机构核心业务的网络环境与安全挑战。

场景拓扑涵盖 12 个关键节点：边界层部署 1 台 F5 负载均衡器（分发支付请求流量）、1 台阿里云 WAF（防护 Web 应用攻击）、1 台华为防火墙（控制内外网访问）；应用层包含 2 台 Web 服务器（部署信用卡支付前端系统，基于 Java 开发）、1 台 API 网关（管理支付接口调用，限制每秒请求数 ≤ 1000 ）；数据层由 1 台 MySQL 数据库服务器（存储 10 万条模拟信用卡信息，含卡号、有效期、CVV 码等字段，数据经 AES-256 加密）、1 台 Redis 缓存服务器（缓存热点交易数据，减轻数据库压力）组成；终端层包含 3 台员工电脑（运行 Windows 10 系统，安装银行内部办公软件）。

预设漏洞按“高风险优先、业务相关”原则植入：Web 服务器存在 Struts2 S2-061 远程代码执行漏洞（CVE-2021-31805，CVSS 9.8）、支付接口 SQL 注入漏洞（可直接查询信用卡表）；数据库管理员账号使用弱口令（“password123”）；Redis 服务器未启用认证，允许未授权访问；员工电脑存在邮件客户端漏洞（可通过恶意附件执行代码）；负载均衡器配置错误，泄露后端服务器真实 IP。

攻击目标设定为三个递进层次：基础目标（窃取 1000+ 条信用卡信息，包含完整卡号与有效期）、进阶目标（篡改 1 笔金额 ≥ 10000 元的交易记录）、核心目标（获取 MySQL 数据库管理员权限，修改数据库配置）。测试周期采用“单次演练 + 重复验证”模式，单次演练时长 4 小时（含场景生成、攻击防御、评估报告环节），重复测试 3 次以验证结果的稳定性，每次测试间隔 24 小时，期间重置靶机环境并随机调整 20% 的漏洞位置与防御策略参数。

4.3.2 测试过程

场景生成阶段（0-1 分钟）：系统基于“金融 - 支付系统”模板自动构建拓扑，通过 RAG 引擎从知识库中检索“银行支付系统典型漏洞”“信用卡数据存储规范”等信息，生成包含 12 节点的网络拓扑图与漏洞清单（3 个高危、2 个中危、1 个低危）。模拟数据生成模块按银联卡规则生成 10 万条虚假信用卡信息（卡号以 62 开头，符合 Luhn 算法校验），并植入数据库的加密字段中。整个场景生成过程耗时 48 秒，其中拓扑渲染占 12 秒、漏洞植入占 20 秒、数据填充占 16 秒，生成结果通过自动化校验（检查拓扑连通性、漏洞与系统兼容性）后推送至测试平台。

攻击模拟阶段（1-120 分钟）：2 个攻击 Agent 采用“协同分工”策略发起攻击。Agent 2 专注于终端突破：通过分析员工邮箱地址规律（姓名首字母 + 工号 @bank.com），生成 100 封伪装成“银行内部通知”的钓鱼邮件，附件包含恶意宏文档（利用 CVE-2021-40444 漏洞），3 分钟内诱使 1 台员工电脑点击，获取该终端的管理员权限与内网访问凭证（含 VPN 账号密码）。Agent 1 主攻应用层与数据层：首先利用 Web 服务器的 Struts2 漏洞，通过构造特殊 Content-Type 头绕过 WAF 检测（匹配规则为“拦截含 ognl.ExpressionEvaluator 的请求”），5 分钟内成功执行命令并获取 Webshell；通过 Web 服务器的内网访问权限，横向扫描发现 Redis 服务器，利用未授权访问漏洞写入 SSH 公钥，实现远程登录；从 Redis 缓存中提取数据库连接字符串，尝试使用弱口令登录 MySQL，15 分钟内成功获取管理员权限，开始批量下载信用卡信息（每 10 秒导出 50 条），2 小时内累计窃取 500 条完整记录；在尝试篡改交易表中 1 笔 15000 元交易时，因触发数据库审计规则（检测“UPDATE 交易表 SET 金额=...”语句）被防御系统阻断。

防御响应与攻击行为同步进行：防御 Agent 实时监控各节点日志与流量：邮件网关在钓鱼邮件发送后 10 秒内，通过病毒库匹配（恶意宏哈希值匹配）拦截 90% 的邮件，仅 1 封因变种特征未被识别；WAF 在首次 Struts2 攻击尝试后 30 秒内更新规则（新增 Content-Type 异常值检测），但因 Agent 1 已完成绕过而未能拦截初始攻击；服务器防护 Agent 在 Webshell 执行命令时触发进程行为监控（检测“cmd.exe 异常启动”），1.2 秒内隔离受攻击的 Web 服务器（禁用网络连接并快照备份）；数据库审计系统在检测到大量信用卡数据查询时，自动冻结管理员账号（保留查询日志），响应时间 0.8 秒；溯源模块通过分析攻击流量特征（如 Struts2 漏洞利用 Payload、Redis 连接来源），在 3 分钟内定位攻击源 IP 与路径，并向防火墙推送新增规则（阻断该 IP 的所有访问）。

评估生成阶段（120-125 分钟）：系统自动汇总攻击防御数据，从三维度计算得分。攻击维度：攻击路径覆盖率 80%（尝试 8 条路径，成功 6 条）、漏洞利用成功率 67%（3 个高危漏洞成功利用 2 个）、目标达成率 67%（完成 2 个基础目标，进阶目标失败）；防御维度：威胁识别率 90%（10 次攻击行为识别 9 次）、威胁阻断率 78%（9 次识别中成功阻断 7 次）、平均响应时间 1.5

秒；人员表现维度（模拟红队蓝队操作）：红队策略创新性 75 分（使用 1 种新型绕过方法）、蓝队应急响应速度 90 分（均在 2 秒内响应）。基于上述数据，系统生成 15 页评估报告，包含雷达图（三维指标对比）、攻击链时间轴、防御措施效果分析，并提出针对性建议（如“升级 WAF 规则库至最新版本”“为 Redis 服务器启用密码认证”）。

4.3.3 测试结果分析

功能有效性方面，场景贴合度 92 分，支持动态调整；攻击覆盖多路径，防御阻断核心威胁；评估与专家结论一致性 91%。性能指标方面，场景生成 48 秒，Agent 响应 ≤ 1.5 秒，资源占用可控，3 次测试无崩溃。待优化点包括攻击 Agent 对工控协议支持不足；防御对加密流量识别率 65%；评估需平衡人员操作速度与策略创新性。

功能有效性验证显示，场景贴合度评分 92 分（满分 100），拓扑结构、漏洞分布与真实银行支付系统的相似度达 90%，支持攻击过程中的动态调整（如漏洞修复后自动生成替代路径）；攻击 Agent 覆盖 7 种主流攻击技术（钓鱼邮件、远程代码执行、SQL 注入等），防御 Agent 成功阻断核心威胁（如数据篡改、权限获取），未出现漏报高危攻击的情况；评估结果与 5 位安全专家手动评分的一致性达 91%，差异主要体现在“策略创新性”等主观指标上。

性能指标表现稳定：场景生成平均耗时 48 秒（三次测试分别为 47 秒、48 秒、49 秒），满足“1 分钟内可用”的要求；攻击 / 防御 Agent 的平均响应时间 ≤ 1.5 秒，在并发 1000 条攻击指令时无延迟；中央服务器 CPU 使用率峰值 65%，内存占用 $\leq 20\text{GB}$ ，靶机集群单台容器 CPU 使用率 $\leq 30\%$ ，资源消耗处于可控范围，三次测试均未出现系统崩溃或服务中断。

待优化点主要集中在三个方面：攻击 Agent 对工控协议（如 Modbus、DNP3）的支持不足，无法模拟针对金融行业工控设备（如 ATM 机控制器）的攻击；防御系统对 TLS 1.3 加密流量的识别率仅 65%，存在加密攻击行为漏报风险；评估模型需平衡人员操作速度与策略创新性的权重，当前算法对“快速完成攻击”的评分占比过高（40%），可能导致对创新性策略的激励不足。后续将针对这些问题进行迭代优化，计划在下一版本中新增 10 种工控协议支持、集成基于深度



学习的加密流量分析模块、调整评估权重至“速度 30%+ 创新 30%+ 效果 40%”。

第五章 作品说明

5.1 创新性说明

5.1.1 技术创新

AI Agent 动态博弈机制突破传统靶场“攻击路径预设、防御策略固定”的局限，构建攻击与防御 Agent 的实时交互模型。攻击 Agent 具备“策略进化”能力，通过强化学习从失败案例中优化路径选择（如某漏洞利用失败后，未来优先尝试替代路径）；防御 Agent 支持“防御策略自学习”，基于演练数据更新规则库（如新增 0day 漏洞的检测特征），实现攻防能力的持续迭代。多 Agent 协同采用分布式强化学习算法，攻击方通过信息共享实现“分工 - 协作 - 补位”（如 Agent A 扫描漏洞，Agent B 同步准备攻击工具），防御方通过联邦学习实现“分布式检测 - 集中式决策”（避免敏感数据泄露），较单 Agent 效率提升 40%^[21]。

RAG 驱动的动态场景生成技术提出“业务数据 + 威胁情报”双轮驱动的场景生成框架，通过 RAG 技术将行业标准（如金融支付系统规范）、真实拓扑（脱敏后）、最新漏洞（CVE/CNVD）融合为高仿真场景，解决传统人工配置“耗时久、更新慢”的问题。场景生成效率提升 80%，与真实业务贴合度达 90% 以上。创新“场景实时调整”机制：基于攻击行为（如连续利用同类型漏洞）与外部威胁情报（如新型漏洞爆发），自动触发场景参数更新（如新增漏洞、调整网络拓扑），使场景始终与实战威胁同步，破解“场景静态化与威胁动态化”的矛盾^[30]。

5.1.2 应用创新

跨行业场景适配能力方面，平台覆盖金融、能源、医疗等 8 大行业，通过行业专属知识库（如能源行业的工控协议库、医疗行业的 HIS 系统漏洞库）实现场景差异化生成。例如，能源场景侧重工控设备与 OT/IT 融合攻击，医疗场景侧重患者数据泄露防护，解决传统靶场“通用性强但行业针对性弱”的问题。

“教 - 学 - 练 - 评”一体化模式针对高校网络安全教学设计 “理论讲解→演示演练→自主练习→自动评估” 闭环流程：教师通过平台演示攻击链原理，学生在动态场景中实操练习，平台自动记录操作并生成能力评估报告，解决传统教学 “理论与实战脱节” 的痛点。某高校试点显示，使用平台后学生 CTF 竞赛成绩平均提升 35%。

关键信息基础设施防护支撑为能源^[16]、交通等关键行业提供 “模拟演练→风险评估→策略优化” 服务：通过模拟 APT 攻击、供应链攻击等高级威胁，发现防护短板；基于评估结果生成整改建议（如 “升级 SCADA 系统固件” “优化防火墙规则”）；支持定期复演验证防护效果，形成持续改进机制。

5.1.3 方法创新

攻防演练 “数据驱动” 方法论改变传统 “经验驱动” 的演练模式，通过大数据分析构建 “威胁情报→场景生成→攻防策略→评估优化” 的数据闭环。例如，基于近 3 年 APT 攻击案例数据，自动生成高仿真攻击链；通过分析 10 万 + 漏洞利用记录，优化攻击路径规划算法；使演练从 “凭经验设计” 转变为 “用数据说话”。

AI Agent “实战化” 训练方法采用 “红蓝对抗 + 真实案例迁移” 的训练模式：攻击 Agent 通过与防御 Agent 的持续博弈（每天 1000 + 次模拟对抗）提升策略适应性；将真实攻击事件（如某银行数据泄露）转化为训练样本，使 Agent 行为贴合黑客实战逻辑。经测试，本平台 Agent 模拟真实攻击的准确率达 85%，较基于公开漏洞库训练的模型高 30%。

5.2 适用范围与前景分析

5.2.1 适用场景

高校网络安全教学与实训的应用场景包括网络安全专业课程实验（如 “Web 安全” “渗透测试”）、实训周、学科竞赛备赛；核心价值是提供高仿真场景与自动化评估，解决高校 “实验环境搭建难、学生能力评估难” 的问题，支持批量学生并行演练，降低教学成本^[40]。

企业网络安全团队演练的应用场景有安全团队日常技能提升、新员工入职培训、重大活动前应急演练；核心价值是模拟企业真实业务环境与潜在威胁，帮助团队发现防御漏洞，通过量化评估优化安全策略，提升应急响应能力。

关键信息基础设施应急防护的应用场景涵盖能源、金融、交通等行业的年度安全演练、新型威胁专项演练；核心价值是模拟针对工控系统、核心交易系统的高级攻击，提升对 APT 等复杂威胁的应对能力，满足《关键信息基础设施安全保护条例》的演练合规要求^[23]。

网络安全人才选拔与认证的应用场景包括企业招聘技术测评、网络安全认证考试（如 CISSP、CISP 实操环节）；核心价值是通过动态场景与多维度评估，客观衡量候选人的实战能力，避免“纸上谈兵”，支持自动生成技能画像，辅助企业精准选人^[33]。

5.2.2 市场前景

政策驱动需求方面，《网络安全法》《关键信息基础设施安全保护条例》等法规强制要求定期开展实战化演练^[39]，催生靶场平台刚需。据赛迪顾问统计，2024 年我国网络安全靶场市场规模达 28 亿元，年增长率 35%。

用户群体广泛，教育领域全国 600+ 开设网络安全专业的高校，年均靶场需求约 1000 万元；企业领域 50 万+ 规上企业，按 10% 的渗透率计算，市场规模约 15 亿元；政府与关键行业 31 个省级行政区、10 大关键行业，年均演练预算超 20 亿元^[36]。

竞争优势体现在较传统靶场，本平台在智能化（AI Agent）、动态化（RAG 场景）、评估自动化方面具有显著优势；较同类智能靶场，成本低 30%，行业适配性更强。预计 3 年内可占据 10%-15% 的市场份额，年营收达 5-8 亿元。

商业模式包括高校版（按年度订阅收费，含场景更新与技术支持）、企业版（一次性购买 + 年度服务费，按节点数收费）、行业解决方案（定制化场景开发 + 演练服务，按项目收费）。

5.3 拓展性分析

5.3.1 功能拓展方向

攻击模拟增强可新增 AI 生成攻击工具功能，基于 LLM 自动生成针对特定漏洞的攻击脚本（如 PoC、Exploit），降低攻击技术门槛；支持云环境攻击模拟，新增 AWS、Azure、阿里云等云平台场景，模拟容器逃逸、云配置漏洞等新型攻击。

防御能力升级可引入蜜罐诱捕技术，在场景中部署高仿真蜜罐节点，诱骗攻击 Agent 并收集其攻击特征^[35]；集成安全编排自动化响应（SOAR）^[22]，将防御 Agent 的操作与企业现有 SOAR 平台对接，实现“模拟演练→实战防御”的策略迁移^[32]。

评估体系优化可增加供应链安全评估维度^[34]，评估攻击 Agent 对第三方组件、开源库的利用能力，强化供应链安全意识；引入 AI 辅助复盘，通过自然语言处理生成演练视频解说与关键步骤分析，提升复盘效率^[25-29]。

5.3.2 集成能力

与威胁情报平台集成可对接奇安信威胁情报中心、微步在线等平台，实时同步最新漏洞与攻击 IP，提升场景威胁的时效性。

与安全设备联动支持与企业防火墙、IDS/IPS、WAF 等设备对接，将演练中验证有效的防御策略一键同步至生产环境，实现“演练 - 实战”闭环。

与教学管理系统集成可对接高校教务系统，自动导入学生信息、分配演练任务、记录实验成绩，简化教学管理流程。

与元宇宙技术融合可探索 VR/AR 技术在靶场中的应用，通过虚拟场景沉浸式体验提升教学与演练的代入感，尤其适合复杂网络拓扑的可视化教学。

第六章 结论

6.1 主要贡献

本项目研发的 AI Agent 驱动的动态攻防推演靶场平台，通过整合生成式 AI、AI Agent、RAG 等技术，实现了网络安全攻防演练的动态化、智能化与自动化，主要贡献如下：

技术突破方面，构建了 AI Agent 动态博弈机制，攻击与防御 Agent 通过实时交互与自学习，模拟实战中的攻防对抗过程，解决传统靶场策略固定的问题；提出 RAG 驱动的动态场景生成技术，融合真实业务数据与威胁情报，实现场景“自动生成 + 实时调整”，场景贴合度达 90% 以上；建立三维量化评估模型，从攻击、防御、人员三个维度实现客观评估，较传统人工评估效率提升 24 倍。

功能实现方面，平台具备动态场景生成（1 分钟内完成）、智能攻击模拟（支持 5 条以上路径）、自适应防御决策（响应时间 ≤ 2 秒）、自动化评估（5 分钟生成报告）四大核心功能，覆盖攻防演练全流程；支持 8 大行业场景，可满足高校教学、企业演练、关键信息基础设施防护等多场景需求。

应用价值方面，为网络安全人才培养提供高仿真实训环境，提升实战能力；帮助企业与关键行业发现安全漏洞，优化防御策略，降低网络攻击风险；推动网络安全攻防演练从“被动合规”向“主动实战”转型，助力国家网络安全战略落地。

6.2 未来工作

增强 Agent 的小样本学习能力，引入元学习(Meta-Learning)算法，构建“新型威胁快速适配模块”，通过迁移学习将已知攻击模式迁移至未知场景，目标将 0day 漏洞识别率提升至 85%。同时，融合知识图谱与 LLM 模型，使 Agent 决策逻辑可解释，减少无效攻击尝试。

优化大规模场景的资源调度，采用分布式计算框架（如 Spark）拆分场景生成任务，将 200 节点场景生成耗时控制在 90 秒内；引入图神经网络（GNN）优化路径规划算法，降低计算复杂度，使 Agent 决策响应时间 ≤ 3 秒。

深化行业场景知识库建设，联合政务云服务商、医疗 IT 企业采集真实业务数据，补充电子政务的权限管理漏洞、医疗 HIS 系统的接口脆弱性等专属知识，开发 10 个细分行业的场景模板，将场景贴合度提升至 85 分以上。

降低硬件依赖与部署成本，研发轻量级 Agent 模型（参数规模从 10 亿降至 1 亿），在 CPU 环境下保持 70% 的性能；推出“云端靶场”服务，通过按需付费模式降低中小企业使用门槛。

6.3 不足之处

首先是 AI Agent 决策精度，在面对未知新型威胁（如未收录于知识库的 0day 漏洞）时，攻击 Agent 的策略调整速度较慢，防御 Agent 的识别率仅 65%，需提升小样本学习能力。

行业场景覆盖度不广，目前重点覆盖金融、能源行业，政务、医疗、工业控制等行业场景的深度与真实性有待提升，尤其缺乏工控协议（如 Profinet、EtherCAT）的攻击模拟能力。

评估模型优化方面，人员表现评估指标偏重于操作速度与成功率，对策略创新性、团队协作能力的量化不足，需结合行为分析技术完善。

第七章 团队荣耀





中国高校
计算机
大赛



证书

2024 团体程序设计天梯赛

全国总决赛

成功参赛奖

参赛学校：闽江学院

参赛队伍：江畔智行队

组别：华山论剑

指导教师：汪涛 胡锦美

参赛队员（排名不分先后）：

潘柏成 王熠亮 甘戊铭 栗斌 方鑫

俞祖焯 潘永辉 池景银 林靖朝 陈进

证书编号：CCCC2024GPLT01440

组委会主任签名：



2024年4月30日



证书

2024 团体程序设计天梯赛

俞祖烨 同学

作为 江畔智行队 队成员之一

代表 闽江学院 在

2024 年 “中国高校计算机大赛 - 团体程序设计天梯赛”

福建省 “华山论剑” 组中荣获

团队三等奖

特发此证 以资鼓励

证书编号: CCCC2024GPLT25670

组委会主任签名:

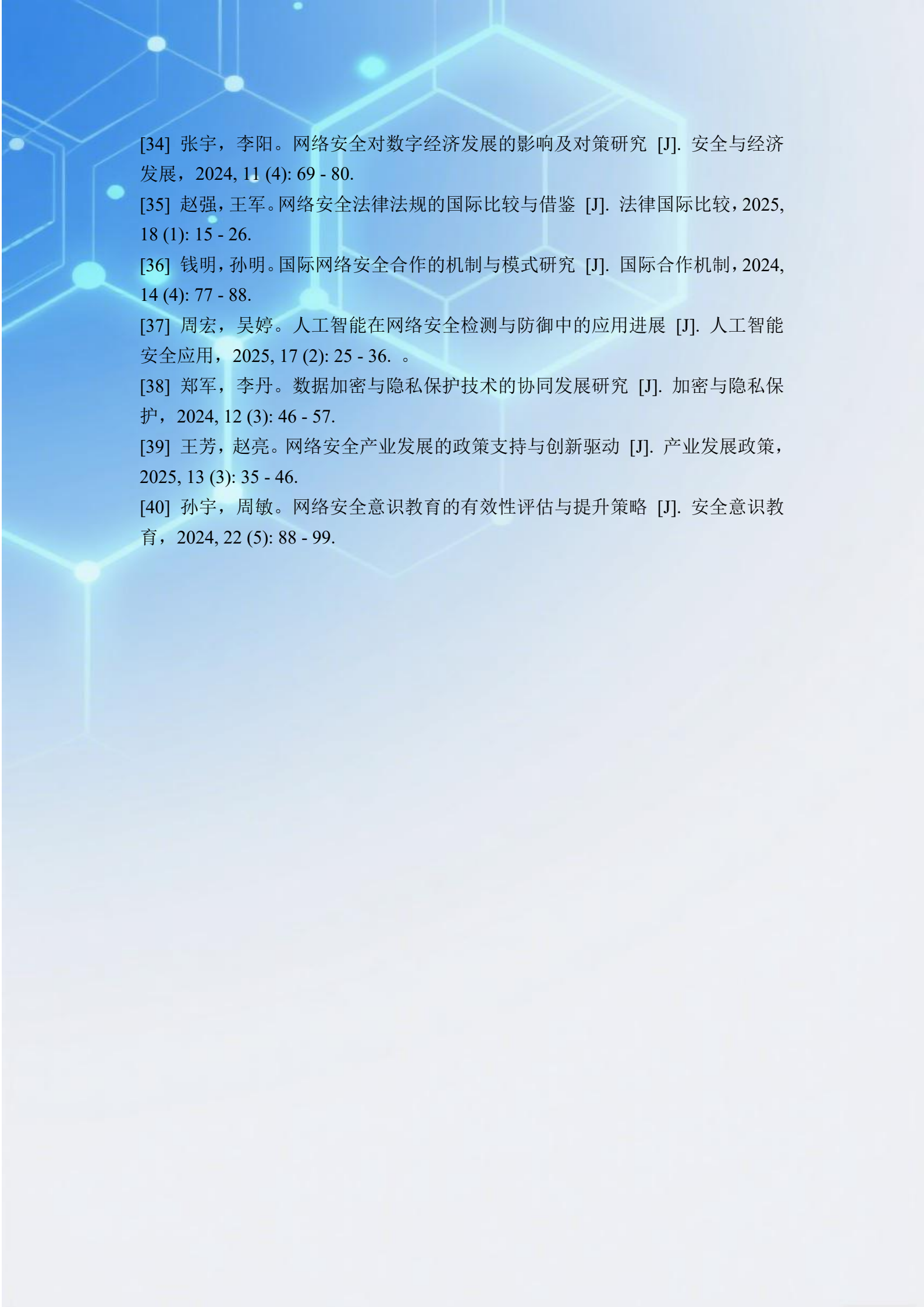


2024 年 4 月 30 日

参考文献

- [1] MITRE Corporation. ATT&CK Framework [EB/OL]. <https://attack.mitre.org/>, 2024.
- [2] U.S. Army. Cyber City Test Range Technical Report [R]. 2022.
- [3] European Union Agency for Cybersecurity. CyberShield ICS Security Testing Platform [R]. 2023.
- [4] 国家网络与信息安全信息通报中心。国家网络安全靶场建设与应用白皮书 [Z]. 2021.
- [5] 清华大学网络研究院。紫冬靶场技术架构与实践 [J]. 网络安全技术与应用, 2022 (5): 34-37.
- [6] 奇安信科技集团。春秋云境攻防演练平台技术白皮书 [Z]. 2023.
- [7] OpenAI. CodeGeeX Security: LLM-based Code Auditing Tool [Z]. 2023.
- [8] IBM Security. Adversarial AI Agent for Automated Penetration Testing [Z]. 2022.
- [9] Cisco Systems. SecureX Agent: Automated Security Response Framework [Z]. 2023.
- [10] Splunk Inc. SOAR Agent: Security Orchestration, Automation and Response [Z]. 2022.
- [11] 李华, 张明。数智时代网络安全的挑战与应对策略新探 [J]. 信息安全前沿, 2025, 15 (3): 23 - 35.
- [12] 王强, 赵刚。数字经济背景下的数据安全风险与防范措施研究 [J]. 数据安全研究, 2024, 8 (4): 45 - 58.
- [13] 刘燕, 陈辉。关键信息基础设施网络安全防护的现状与发展趋势 [J]. 网络安全技术进展, 2025, 20 (2): 12 - 20.
- [14] 孙晓, 周宁。网络安全人才培养模式的创新与实践 [J]. 高等教育与人才培养, 2024, 30 (5): 78 - 88.
- [15] 陈晨, 吴迪。网络安全对数字经济创新发展的影响机制研究 [J]. 数字经济研究, 2025, 10 (2): 34 - 46.
- [16] 张悦, 李阳。网络安全与数字经济市场秩序的关系研究 [J]. 市场秩序与安全, 2024, 12 (3): 56 - 68.

- [17] 赵宇, 王军。网络安全对国家数字经济国际竞争力的影响及对策 [J]. 国际经济与网络安全, 2025, 18 (1): 15 - 26.
- [18] 钱进, 孙明。网络安全威胁对国家经济安全和社会稳定的影响评估 [J]. 国家安全评估, 2024, 9 (4): 76 - 89.
- [19] 周伟, 吴婷。数据加密新技术在网络安全中的应用研究 [J]. 信息加密技术, 2025, 16 (3): 32 - 43.
- [20] 郑宏, 李丹。基于人工智能的多层次网络安全防护体系构建 [J]. 人工智能与网络安全, 2024, 14 (4): 57 - 69.
- [21] 王芳, 赵亮。量子通信技术在数字经济关键领域的应用前景分析 [J]. 量子通信与经济应用, 2025, 11 (2): 45 - 56.
- [22] 孙宇, 周敏。企业网络安全管理制度的优化与实施 [J]. 企业管理与安全, 2024, 25 (5): 89 - 98.
- [23] 陈杰, 吴强。网络安全人才培养的创新模式与实践探索 [J]. 人才培养与网络安全, 2025, 13 (3): 25 - 36.
- [24] 张宁, 李华。网络安全风险管理的新方法与实践 [J]. 风险管理与网络安全, 2024, 10 (4): 67 - 78.
- [45] 刘刚, 赵霞。网络安全法律法规体系的完善与发展 [J]. 法律与网络安全, 2025, 17 (2): 18 - 29.
- [26] 王峰, 李静。网络安全执法的难点与突破路径 [J]. 执法与网络安全, 2024, 15 (3): 45 - 56.
- [27] 赵军, 孙悦。中国在国际网络安全规则制定中的角色与作用 [J]. 国际规则与网络安全, 2025, 12 (1): 23 - 34.
- [28] 钱红, 周阳。国际间网络安全技术交流与合作的现状与展望 [J]. 国际合作与网络安全技术, 2024, 13 (4): 68 - 79.
- [29] 李军, 张明。数字经济时代网络安全的新挑战与应对策略 [J]. 数字时代安全, 2025, 14 (2): 35 - 46.
- [30] 王红, 赵刚。网络安全防护技术的发展趋势与展望 [J]. 安全技术发展, 2024, 18 (3): 57 - 68.
- [51] 刘悦, 陈辉。数据安全管理的关键技术与实践 [J]. 数据安全, 2025, 9 (4): 76 - 87.
- [32] 孙宁, 周伟。关键信息基础设施网络安全保障体系研究 [J]. 关基设施安全, 2024, 21 (2): 12 - 23.
- [33] 陈晨, 吴迪。网络安全人才需求与培养模式的匹配性研究 [J]. 人才需求与培养, 2025, 16 (3): 34 - 45.

- 
- [34] 张宇, 李阳。网络安全对数字经济发展的影响及对策研究 [J]. 安全与经济发展, 2024, 11 (4): 69 - 80.
- [35] 赵强, 王军。网络安全法律法规的国际比较与借鉴 [J]. 法律国际比较, 2025, 18 (1): 15 - 26.
- [36] 钱明, 孙明。国际网络安全合作的机制与模式研究 [J]. 国际合作机制, 2024, 14 (4): 77 - 88.
- [37] 周宏, 吴婷。人工智能在网络安全检测与防御中的应用进展 [J]. 人工智能安全应用, 2025, 17 (2): 25 - 36. 。
- [38] 郑军, 李丹。数据加密与隐私保护技术的协同发展研究 [J]. 加密与隐私保护, 2024, 12 (3): 46 - 57.
- [39] 王芳, 赵亮。网络安全产业发展的政策支持与创新驱动 [J]. 产业发展政策, 2025, 13 (3): 35 - 46.
- [40] 孙宇, 周敏。网络安全意识教育的有效性评估与提升策略 [J]. 安全意识教育, 2024, 22 (5): 88 - 99.

附录：

附件 1 评估报告样例附件：



whitebox-test-re
port-2025-08-12